Editor: Vina Lusiana

penamuda media

Keamanan Siber

Melindungi Data di Dunia Digital

Widia Febriyani, S.Kom., M.Kom., Mira Wulandari, S.Kom., M.Kom., Yudha Riwanto,M.Kom., Muhamad Masjun Efendi, M.Kom, Dwi Vernanda, S.T., M.Pd., Zatin Niqotaini, S.Tr.Kom., M.Kom, Vina Lusiana, M.Si, Ir. Aliy Hafiz, S.Kom., M.T.I., CEH., Fitri Wibowo, S.S.T., M.T., M.Sc., Ir. Pujo Hari Saputro, S.Kom., M.T., Prof. Setiawan Assegaff, ST, MMSI, Ph.D, Bayu Hananto, S.Kom., M.Kom., Samsinar., S.Kom., MMSI, Muhammad Razi A., S.T., MMSI., Renny Afriany. N, S.Kom.,M.S.I



KEAMANAN SIBER: MELINDUNGI DATA DI DUNIA DIGITAL

Penulis:
Widia Febriyani, S.Kom., M.Kom.
Mira Wulandari, S.Kom., M.Kom.
Yudha Riwanto,M.Kom.
Muhamad Masjun Efendi, M.Kom
Dwi Vernanda, S.T., M.Pd.
Zatin Niqotaini, S.Tr.Kom., M.Kom
Vina Lusiana, M.Si
Ir. Aliy Hafiz, S.Kom., M.T.I., CEH.
Fitri Wibowo, S.S.T., M.T., M.Sc.
Ir. Pujo Hari Saputro, S.Kom., M.T.
Prof. Setiawan Assegaff, ST, MMSI, Ph.D
Bayu Hananto, S.Kom., M.Kom.
Samsinar., S.Kom., MMSI
Muhammad Razi A., S.T., MMSI.
Renny Afriany. N, S.Kom.,M.S.I

Editor: Vina Lusiana, M.Si

PENAMUDA MEDIA

KEAMANAN SIBER: MELINDUNGI DATA DI DUNIA DIGITAL

Penulis:
Widia Febriyani, S.Kom., M.Kom.
Mira Wulandari, S.Kom., M.Kom.
Yudha Riwanto,M.Kom.
Muhamad Masjun Efendi, M.Kom
Dwi Vernanda, S.T., M.Pd.
Zatin Niqotaini, S.Tr.Kom., M.Kom
Vina Lusiana, M.Si
Ir. Aliy Hafiz, S.Kom., M.T.I., CEH.
Fitri Wibowo, S.S.T., M.T., M.Sc.
Ir. Pujo Hari Saputro, S.Kom., M.T.
Prof. Setiawan Assegaff, ST, MMSI, Ph.D
Bayu Hananto, S.Kom., M.Kom.
Samsinar., S.Kom., MMSI
Muhammad Razi A., S.T., MMSI.
Renny Afriany. N, S.Kom.,M.S.I

Editor: Vina Lusiana, M.Si

Penyunting dan Penata Letak:
Tim PT Penamuda Media
Desain Sampul:
Tim PT Penamuda Media
Penerbit:
PT Penamuda Media

ISBN: 9786347269362

Redaksi:
Casa Sidoarum RT03 Ngentak, Sidoarum Godean Sleman Yogyakarta
Web: www.penamudamedia.com
E-mail: penamudamedia@gmail.com
Instagram: @penamudamedia
WhatsApp: +6285700592256

Cetakan Pertama, Juni 2025
viii + 243 halaman; 15 x 23 cm

Hak cipta dilindungi undang-undang
Dilarang memperbanyak maupun mengedarkan buku dalam bentuk dan dengan cara apapun tanpa izin tertulis dari penerbit maupun penulis

KATA PENGANTAR

Puji dan syukur penulis panjatkan ke hadirat Tuhan Yang Maha Esa karena atas limpahan rahmat dan karunia-Nya, buku ini yang berjudul *Keamanan Siber: Melindungi Data di Dunia Digital* akhirnya dapat diselesaikan.

Di tengah arus transformasi digital yang melanda hampir seluruh aspek kehidupan mulai dari pendidikan, ekonomi, pemerintahan hingga kehidupan pribadi perlindungan terhadap data dan sistem informasi menjadi sesuatu yang mutlak. Keamanan siber bukan lagi urusan teknis para profesional TI semata, melainkan sudah menjadi kebutuhan mendesak bagi individu, organisasi, dan negara.

Buku ini disusun untuk memberikan gambaran komprehensif mengenai berbagai aspek penting dalam keamanan siber. Dimulai dari pengantar umum dan identifikasi ancaman digital, pembaca akan diajak memahami dasar-dasar kriptografi, keamanan jaringan, serta perlindungan aplikasi dan perangkat lunak. Di dalamnya juga dibahas manajemen risiko, privasi data pribadi, serta sistem deteksi dan respons terhadap insiden. Topik-topik lanjutan seperti keamanan cloud, serangan

siber terbesar dalam sejarah hingga peran kecerdasan buatan dan tren masa depan turut melengkapi pembahasan.

Dengan bahasa yang sederhana, namun tetap ilmiah, penulis berharap buku ini dapat diakses oleh pembaca dari berbagai latar belakang, baik akademisi, praktisi, pelajar, maupun masyarakat umum yang ingin memahami pentingnya menjaga keamanan data dan informasi pribadi di dunia digital.

Ucapan terima kasih penulis sampaikan kepada semua pihak yang telah mendukung proses penulisan buku ini, baik secara langsung maupun tidak langsung. Masukan, kritik, dan saran dari pembaca sangat penulis harapkan untuk penyempurnaan edisi selanjutnya.

Akhir kata, semoga buku ini dapat memberikan kontribusi positif bagi peningkatan literasi digital di Indonesia dan menjadi rujukan yang bermanfaat dalam membangun ekosistem digital yang aman dan terpercaya.

Tim Penulis

DAFTAR ISI

KATA PENGANTAR v
DAFTAR ISI vii
BAB 1 PENGANTAR KEAMANAN SIBER 1
Widia Febriyani, S.Kom., M.Kom. 1
BAB 2 ANCAMAN DAN KERENTANAN DALAM DUNIA DIGITAL 19
Mira Wulandari, S.Kom., M.Kom. 19
BAB 3 DASAR-DASAR KRIPTOGRAFI 32
Yudha Riwanto,M.Kom. 32
BAB 4 KEAMANAN JARINGAN 46
Muhamad Masjun Efendi, M.Kom 46
BAB 5 KEAMANAN APLIKASI DAN PERANGKAT LUNAK 64
Dwi Vernanda, S.T., M.Pd. 64
BAB 6 MANAJEMEN RISIKO KEAMANAN SIBER 78
Zatin Niqotaini, S.Tr.Kom., M.Kom 78
BAB 7 PERLINDUNGAN DATA PRIBADI DAN PRIVASI 96
Vina Lusiana, M.Si 96
BAB 8 Sistem Deteksi dan Respons Insiden 110
Ir. Aliy Hafiz, S.Kom., M.T.I., CEH. 110
BAB 9 KEAMANAN CLOUD DAN VIRTUALISASI 132
Fitri Wibowo, S.S.T., M.T., M.Sc. 132
BAB 10 SERANGAN SIBER TERBESAR DALAM SEJARAH 147
Ir. Pujo Hari Saputro, S.Kom., M.T. 147
BAB 11 PENDIDIKAN DAN KESADARAN KEAMANAN SIBER 164
Prof. Setiawan Assegaff, ST, MMSI, Ph.D 164
BAB 12 REGULASI DAN KEBIJAKAN KEAMANAN SIBER 186
Bayu Hananto, S.Kom., M.Kom. 186

BAB 13 KEAMANAN KOMPUTER TERKINI 202
Samsinar., S.Kom., MMSI 202
BAB 14 PERAN AI DALAM KEAMANAN SIBER 216
Muhammad Razi A., S.T., MMSI. 216
BAB 15 MASA DEPAN KEAMANAN SIBER 230
Renny Afriany. N, S.Kom.,M.S.I 230



BAB 1
PENGANTAR KEAMANAN SIBER

Widia Febriyani, S.Kom., M.Kom.

Keamanan siber adalah disiplin yang fokus pada perlindungan sistem komputer, jaringan, perangkat, dan data dari ancaman digital yang terus berkembang. Di era transformasi digital, hampir semua aspek kehidupan dan bisnis bergantung pada teknologi informasi yang terhubung secara luas. Hal ini menjadikan keamanan siber sebagai kebutuhan utama untuk menjaga kerahasiaan, integritas, dan ketersediaan informasi.

Ancaman siber dapat berupa malware, ransomware, serangan phishing, serangan *Distributed Denial of Service* (DDoS), dan eksploitasi kerentanan sistem oleh peretas. Selain itu, kemajuan teknologi seperti kecerdasan buatan (*Artificial Intelligence*/AI) dan *Internet of Things* (IoT) membawa peluang sekaligus tantangan baru dalam keamanan siber. AI digunakan untuk memperkuat sistem pertahanan dengan kemampuan deteksi ancaman otomatis dan respons cepat. Namun, di sisi lain, teknologi ini juga bisa dimanfaatkan oleh pelaku kejahatan untuk melancarkan serangan yang lebih canggih dan sulit dideteksi.

Keamanan siber tidak hanya berkutat pada teknologi, melainkan juga melibatkan kebijakan, prosedur, dan kesadaran pengguna untuk menciptakan lingkungan digital yang aman. Pendekatan holistik diperlukan untuk mengelola risiko siber secara efektif, termasuk pengelolaan identitas dan akses, enkripsi data, *monitoring* aktivitas, serta perencanaan pemulihan bencana.

Pada bab ini akan menguraikan prinsip-prinsip dasar keamanan siber, berbagai jenis ancaman yang dihadapi, dan strategi serta teknologi yang digunakan untuk melindungi aset digital. Pemahaman yang mendalam tentang keamanan siber menjadi kunci agar individu, organisasi maupun pemerintah dapat menjalankan aktivitas digitalnya dengan aman dan terpercaya di tengah dunia yang semakin terkoneksi.

A. Ruang Lingkup Keamanan Siber

Keamanan siber merupakan bidang ilmu dan praktik yang secara khusus berfokus pada upaya perlindungan sistem teknologi informasi, perangkat keras, perangkat lunak, jaringan komunikasi, serta data digital dari ancaman yang bersifat elektronik atau siber (Budi *et al.*, 2025). Seiring dengan pesatnya perkembangan teknologi informasi dan komunikasi, hampir seluruh aspek kehidupan manusia dan aktivitas organisasi kini bergantung pada sistem digital yang saling terhubung secara luas, mulai dari layanan perbankan, pemerintahan, industri hingga aktivitas sosial.

Dalam konteks ini, keamanan siber bertujuan menjaga tiga pilar utama kerahasiaan (*confidentiality*), integritas (*integrity*), dan ketersediaan (*availability*) informasi yang dikenal sebagai CIA Triad. Kerahasiaan menjamin bahwa hanya pihak berwenang yang dapat mengakses data, integritas memastikan data dan sistem tidak berubah tanpa

izin, dan ketersediaan menjamin informasi serta layanan dapat diakses ketika dibutuhkan oleh pengguna yang sah (Hacker, Tengah and Siber, 2025a; Muzaqi, 2025).

Namun, ruang lingkup keamanan siber tidak terbatas pada aspek teknis, seperti konfigurasi firewall, penggunaan enkripsi, atau pengaturan akses jaringan, melainkan juga melibatkan kebijakan organisasi, regulasi, prosedur operasional, dan perilaku manusia yang menjadi komponen esensial dalam membentuk benteng pertahanan menyeluruh terhadap berbagai risiko yang muncul dalam lingkungan digital. Dengan demikian, keamanan siber mencakup pendekatan multidisiplin yang mengintegrasikan teknologi, proses bisnis, dan faktor manusia untuk menciptakan ekosistem digital yang aman serta andal.

Ancaman siber merupakan segala bentuk tindakan atau kejadian yang dapat merusak, mengganggu, atau mencuri sistem dan data digital yang dapat berasal dari berbagai sumber, mulai dari aktor kriminal, pesaing bisnis hingga kelompok peretas yang terorganisir (Hacker, Tengah and Siber, 2025b). Salah satu kategori ancaman yang paling sering ditemui adalah malware yaitu perangkat lunak yang dirancang secara khusus untuk tujuan jahat. Malware terdiri dari berbagai jenis, seperti virus yang menyebar dengan menempel pada program lain, worm yang dapat menggandakan dirinya dan menyebar melalui jaringan, trojan yang menyamar sebagai aplikasi sah, serta

ransomware yang mengenkripsi data korban dan menuntut pembayaran tebusan untuk pemulihan akses (Bakar, 2025).

Selain itu, ancaman *phishing* menggunakan rekayasa sosial untuk memanipulasi pengguna agar memberikan informasi sensitif, seperti kata sandi dan nomor kartu kredit, biasanya melalui email atau pesan palsu yang tampak meyakinkan. Serangan *Distributed Denial of Service* (DDoS) bertujuan membuat sebuah layanan digital tidak dapat diakses dengan membanjiri jaringan atau server dengan lalu lintas yang sangat besar sehingga melumpuhkan sistem.

Pencurian data (*data breach*) adalah ancaman serius lainnya, dalam hal ini pelaku berusaha mendapatkan informasi rahasia dan sensitif yang jika bocor dapat menimbulkan kerugian finansial, reputasi, dan dampak hukum bagi organisasi. Selain ancaman klasik tersebut, munculnya teknologi baru turut memperkenalkan ancaman yang lebih kompleks, seperti serangan berbasis kecerdasan buatan yang dapat beradaptasi secara otomatis dan serangan rantai pasok (*supply chain attacks*) yang memanfaatkan kerentanan pada vendor atau mitra bisnis untuk menyerang target utama secara tidak langsung.

B. Peran Teknologi dalam Keamanan Siber

Dalam upaya melindungi sistem dan data dari ancaman siber, teknologi memegang peranan krusial sebagai alat utama dalam mendeteksi, mencegah, dan merespons



serangan yang terus berkembang. Firewall adalah salah satu teknologi fundamental yang berfungsi sebagai penghalang antara jaringan internal yang aman dan jaringan eksternal yang tidak terpercaya, dengan mengatur aliran data berdasarkan aturan yang ditentukan untuk mencegah akses yang tidak sah (Pinandhita *et al.*, 2024).

Antivirus dan solusi anti-malware bertugas untuk mendeteksi dan menghapus perangkat lunak berbahaya yang telah masuk ke dalam sistem, menggunakan teknik *signature-based* maupun *behavior-based detection* untuk mengenali ancaman baru maupun yang sudah diketahui. Sistem Deteksi dan Pencegahan Intrusi (IDS/IPS) meningkatkan kemampuan *monitoring* dengan mengawasi aktivitas jaringan secara *real-time* dan mengambil tindakan otomatis ketika menemukan aktivitas mencurigakan yang berpotensi sebagai serangan.

Enkripsi data menjadi pilar penting dalam keamanan, dengan mengubah data asli menjadi format yang hanya dapat dibaca melalui kunci khusus, baik saat data disimpan (*data at rest*) maupun saat dikirimkan (*data in transit*) sehingga menjaga kerahasiaan informasi meskipun data tersebut disadap atau dicuri.

Seiring dengan kemajuan teknologi, kecerdasan buatan (AI) dan *machine learning* mulai diterapkan dalam sistem keamanan untuk meningkatkan kemampuan analisis pola serangan, mendeteksi anomali yang sulit diidentifikasi

oleh manusia, dan melakukan respons secara otomatis serta *real-time*. Di samping itu, keamanan pada perangkat *Internet of Things* (IoT) menjadi tantangan tersendiri karena keterbatasan sumber daya dan standar yang belum seragam sehingga perangkat ini sering menjadi pintu masuk bagi penyerang jika tidak dikelola dengan benar. Oleh karena itu, teknologi keamanan harus diintegrasikan secara holistik dan disesuaikan dengan kebutuhan organisasi untuk menciptakan sistem pertahanan yang kuat dan adaptif (Dwi *et al.*, 2017; Wijaya, Setiawan and Hermawan, 2024).

Kecerdasan buatan (*artificial intelligence*) telah merevolusi pendekatan dalam keamanan siber dengan menghadirkan kemampuan analisis yang jauh lebih cepat dan mendalam dibandingkan metode tradisional. AI mampu memproses data dalam jumlah besar secara efisien dan mengenali pola-pola perilaku yang mencurigakan atau tidak biasa yang mungkin mengindikasikan adanya ancaman, bahkan pada serangan yang sebelumnya belum pernah terjadi (Julianto, Hikmah and Yasa, 2024).

Teknologi *machine learning* memungkinkan sistem keamanan untuk belajar dari data historis dan terus memperbarui model deteksi ancaman sehingga meningkatkan kemampuan prediksi dan respons insiden secara proaktif. Implementasi AI dalam keamanan siber meliputi deteksi otomatis terhadap malware baru,

identifikasi serangan phishing yang kompleks, serta analisis *traffic* jaringan untuk menemukan potensi serangan DDoS.

Namun demikian, penggunaan AI juga menghadirkan risiko baru. Pelaku kejahatan siber kini dapat memanfaatkan AI untuk mengembangkan serangan yang lebih canggih, seperti malware yang mampu beradaptasi dengan sistem pertahanan, *deepfake* untuk manipulasi informasi, atau kampanye *phishing* otomatis yang lebih meyakinkan. Selain itu, algoritma AI sendiri rentan terhadap serangan seperti *adversarial attacks* yang bertujuan mengelabui model agar salah mengklasifikasikan ancaman.

C. Manajemen Risiko Keamanan Siber

Keamanan siber yang efektif tidak dapat dicapai tanpa pendekatan manajemen risiko yang sistematis dan kebijakan yang komprehensif. Manajemen risiko siber melibatkan serangkaian proses, mulai dari identifikasi aset digital dan kerentanannya terhadap ancaman, evaluasi potensi dampak dan kemungkinan terjadinya insiden keamanan hingga perancangan strategi mitigasi yang mencakup kontrol teknis, kebijakan, dan prosedur operasional.

Dengan penilaian risiko yang tepat, organisasi dapat memprioritaskan upaya perlindungan pada aset dan area yang paling kritikal sehingga sumber daya dapat digunakan secara efisien. Selain aspek teknis, kebijakan keamanan siber

berfungsi sebagai pedoman yang mengatur penggunaan teknologi, pengelolaan akses, dan tata cara penanganan insiden keamanan (Kwon *et al.*, 2020).

Kebijakan ini harus disusun dengan memperhatikan regulasi dan standar internasional yang relevan, seperti ISO 27001, *General Data Protection Regulation* (GDPR), dan aturan lokal yang berlaku untuk memastikan bahwa organisasi tidak hanya melindungi diri secara teknis, tetapi juga memenuhi kewajiban hukum dan etika (Sarker, Furhad and Nowrozy, 2021; Yusif and Hafeez-Baig, 2021). Implementasi manajemen risiko dan kebijakan ini harus dilengkapi dengan mekanisme pemantauan, audit, dan evaluasi secara terus-menerus agar mampu beradaptasi terhadap perubahan ancaman dan lingkungan bisnis yang dinamis.

Meskipun kemajuan teknologi telah memperkuat sistem pertahanan digital, faktor manusia tetap menjadi salah satu titik paling rentan dalam keamanan siber. Banyak serangan yang berhasil karena kesalahan pengguna, seperti membuka tautan *phishing*, menggunakan kata sandi yang lemah, atau mengabaikan prosedur keamanan yang telah ditetapkan.

Pelatihan keamanan secara rutin dan kampanye edukasi membantu membekali pengguna dengan pengetahuan dan keterampilan yang diperlukan untuk mengenali ancaman serta menerapkan praktik keamanan

yang benar dalam aktivitas sehari-hari. Pengembangan budaya keamanan yang kuat dalam organisasi juga membantu menciptakan lingkungan, dalam hal ini setiap individu merasa bertanggung jawab terhadap perlindungan data dan sistem. Kesadaran pengguna yang tinggi dapat mengurangi risiko yang muncul dari serangan berbasis rekayasa sosial (*social engineering*) dan kesalahan manusia yang sering menjadi celah utama bagi pelaku kejahatan siber untuk masuk ke dalam sistem.

D. Strategi dan Praktik Terbaik dalam Keamanan Siber

Menghadapi kompleksitas dan dinamika ancaman siber yang semakin meningkat, organisasi perlu mengadopsi strategi keamanan yang holistik dan berlapis untuk melindungi aset digital secara efektif. Konsep *defense in depth* menekankan perlunya beberapa lapisan pertahanan yang saling melengkapi sehingga jika satu lapisan mengalami kegagalan, lapisan lain masih dapat memberikan perlindungan.

Selain itu, model *zero trust architecture* kini menjadi tren dalam keamanan modern dengan prinsip "jangan percaya siapa pun, selalu verifikasi" yang mewajibkan autentikasi dan otorisasi ketat tanpa mempercayai perangkat atau pengguna hanya berdasarkan lokasi jaringan. Pendekatan ini mengurangi risiko akses tidak sah bahkan di dalam perimeter organisasi (Bolbot *et al.*, 2022).

Strategi keamanan yang baik juga mengutamakan *continuous monitoring* untuk mendeteksi aktivitas mencurigakan secara dini dan menyediakan respons insiden yang cepat dan terkoordinasi.

Tabel 1 Strategi Implementasi Keamanan Siber

Strategi	Deskripsi	Contoh Implementasi	Manfaat
Defense in Depth	Pendekatan berlapis untuk perlindungan sistem agar jika satu lapisan gagal, lapisan lain tetap aman	Firewall, IDS/IPS, enkripsi data, kontrol akses pengguna	Meningkatkan redundansi keamanan dan mengurangi risiko
Zero Trust Architecture	Prinsip "jangan percaya siapa pun, selalu verifikasi" untuk akses sistem dan data	*Multi-factor authentication* (MFA), segmentasi jaringan	Meminimalkan akses tidak sah, bahkan dari dalam jaringan
Continuous Monitoring	Pemantauan sistem dan jaringan secara *real-time* untuk mendeteksi aktivitas mencurigakan	*Security Information and Event Management* (SIEM), *log analysis*	Deteksi dini ancaman dan respons cepat
Incident Response Plan	Rencana terstruktur untuk menangani	Tim tanggap insiden, prosedur eskalasi,	Meminimalkan dampak dan mempercepat pemulihan

Strategi	Deskripsi	Contoh Implementasi	Manfaat
	insiden keamanan secara cepat dan efektif	latihan simulasi	
Disaster Recovery & Business Continuity	Rencana untuk memastikan kelangsungan operasional saat terjadi insiden besar	*Backup* data rutin, sistem failover, prosedur pemulihan	Memastikan ketersediaan layanan dan data kritis
User Awareness & Training	Edukasi dan pelatihan pengguna untuk meningkatkan kesadaran dan mengurangi risiko kesalahan manusia	Pelatihan keamanan berkala, simulasi *phishing*	Mengurangi risiko *human error* dan *social engineering*
Patch Management	Pengelolaan dan penerapan pembaruan perangkat lunak secara teratur	*Otomasi patching*, manajemen kerentanan	Menutup celah keamanan dan mengurangi risiko serangan
Access Control & Least Privilege	Memberikan hak akses minimum yang diperlukan sesuai peran pengguna	*Role-Based Access Control* (RBAC), *review* akses berkala	Membatasi potensi penyalahgunaan akses

Organisasi harus memiliki rencana pemulihan bencana (*disaster recovery*) dan kontinuitas bisnis yang matang agar dapat segera pulih dan melanjutkan operasional setelah menghadapi insiden siber yang serius. Seluruh praktik ini harus didukung dengan kebijakan yang jelas, pelatihan berkelanjutan, dan penggunaan teknologi terbaru agar keamanan tidak hanya menjadi penghalang, tetapi juga memungkinkan kelangsungan dan pertumbuhan bisnis secara aman.

E. Tantangan dan Tren Keamanan Siber

Keamanan siber merupakan bidang yang sangat dinamis dan terus berkembang seiring dengan perubahan teknologi dan pola ancaman yang semakin kompleks. Tantangan utama saat ini termasuk meningkatnya kompleksitas infrastruktur TI yang memperbesar permukaan serangan, dan munculnya ancaman berbasis kecerdasan buatan serta otomasi yang dapat menyerang dengan kecepatan maupun skala yang sulit ditandingi oleh pertahanan tradisional (Gratia *et al.*, 2024; Nurain, Gultom and Indrajit, 2024).

Selain itu, proliferasi perangkat *Internet of Things* (IoT) yang tersebar luas dan sering kali memiliki keterbatasan sumber daya dan standar keamanan, menimbulkan risiko baru yang memerlukan pendekatan pengamanan khusus. Perubahan regulasi global mengenai privasi dan keamanan data juga menambah tekanan pada



organisasi untuk menjaga kepatuhan sambil mempertahankan efektivitas keamanan.

Melihat tren tersebut, masa depan keamanan siber akan semakin menuntut kolaborasi lintas sektor, inovasi teknologi yang berkelanjutan, dan pengembangan sumber daya manusia yang kompeten serta adaptif. Organisasi yang mampu bertransformasi secara proaktif dalam strategi dan teknologi keamanan siber akan memiliki keunggulan kompetitif serta dapat membangun kepercayaan yang kuat dalam ekosistem digital yang semakin kompleks maupun terbuka.

Daftar Pustaka

Bakar, K.A. (2025) 'Penerapan Teori Kontrol Sosial Dalam Penanggulangan Kejahatan', (January).

Bolbot, V. *et al.* (2022) 'Developments and research directions in maritime cybersecurity: A systematic literature review and bibliometric analysis', *International Journal of Critical Infrastructure Protection*, 39(November), p. 100571. Available at: https://doi.org/10.1016/j.ijcip.2022.100571.

Budi, P. *et al.* (2025) 'Analisis Model Hot-Fit Terhadap Kinerja Keamanan Siber Dengan Mediasi Kesiapan Keamanan Siber Di Rsud Ajibarang 1 Agustyarum', 15(1), pp. 42–49.

Dwi, Y. *et al.* (2017) 'Analisis Malware Menggunakan Metode Analisis Statis dan Dinamis untuk Pembuatan IOC Berdasarkan STIX Versi 2 . 1', (1).

Gratia, M. *et al.* (2024) 'Tinjauan Literatur Manajemen Risiko Cyber dalam Proyek : Identifikasi , Evaluasi , dan Mitigasi Ancaman Literature Review Cyber Risk Management in Projects : Threat Identification , Evaluation and Mitigation', 14, pp. 187–198.

Hacker, E., Tengah, D.I. and Siber, A. (2025a) 'Etika Profesi It Dalam Menjaga Privasi Dan Keamanan : Peran Etika Profesi It Dalam Menjaga Privasi Dan Keamanan : Peran Ethical Hacker Di Tengah Ancaman Siber

Disusun untuk Tugas Etika Profesi Semester Genap Tahun Ajaran 2024 / 2025 HERI', (May), pp. 0–18.

Hacker, E., Tengah, D.I. and Siber, A. (2025b) 'Etika Profesi It Dalam Menjaga Privasi Dan Keamanan : Peran Etika Profesi It Dalam Menjaga Privasi Dan Keamanan : Peran Ethical Hacker Di Tengah Ancaman Siber Disusun untuk Tugas Etika Profesi Semester Genap Tahun Ajaran 2024 / 2025 HERI', (May), pp. 0–18.

Julianto, A.S., Hikmah, I.R. and Yasa, R.N. (2024) 'Cyber-Risk Management Menggunakan NIST Cyber Security Framework (CSF) dan Cobit 2019 pada Instansi XYZ', *Info Kripto*, 18(2), pp. 41–47. Available at: https://doi.org/10.56706/ik.v18i2.99.

Kwon, R. *et al.* (2020) 'Cyber threat dictionary using MITRE ATTCK matrix and NIST cybersecurity framework mapping', *2020 Resilience Week, RWS 2020*, 75, pp. 106–112. Available at: https://doi.org/10.1109/RWS50334.2020.9241271.

Muzaqi, A. Al (2025) 'Peran Literasi Digital Tingkat Lanjut dalam Membangun Keamanan Siber yang Kuat', (March).

Nurain, A., Gultom, R.A.G. and Indrajit, R.E. (2024) 'Manajemen Ketahanan Risiko Siber pada Internet of Things dan Cyber Physical System', *Journal on Education*, 06(02), pp. 13271–13281.

Pinandhita, T.D. *et al.* (2024) 'Desain Dan Analisis Arsitektur Data Warehouse Untuk Optimalisasi Manajemen Perhotelan Data Warehouse Architectural Analysis and Design Optimization for Hospitality Enterprises', (December). Available at: https://doi.org/10.28932/jutisi.vXiX.X.

Sarker, I.H., Furhad, M.H. and Nowrozy, R. (2021) 'AI-Driven Cybersecurity: An Overview, Security Intelligence Modeling and Research Directions', *SN Computer Science*, 2(3), pp. 1–18. Available at: https://doi.org/10.1007/s42979-021-00557-0.

Wijaya, M.R., Setiawan, D. and Hermawan, M.A. (2024) 'Manajemen Risiko Keamanan Siber dalam Implementasi Teknologi 5G di Universitas Bhayangkaraya Jakarta Raya', 5(2), pp. 119–132.

Yusif, S. and Hafeez-Baig, A. (2021) 'A Conceptual Model for Cybersecurity Governance', *Journal of Applied Security Research*, 16(4), pp. 490–513. Available at: https://doi.org/10.1080/19361610.2021.1918995.



Tentang Penulis



Widia Febriyani, S.Kom., M.Kom. lahir di Temanggung. Penulis adalah seorang akademisi yang menyelesaikan pendidikan sarjana dan magister di bidang Sistem Informasi dari Telkom University. Saat ini penulis aktif sebagai dosen Program Studi S1 Sistem Informasi di Telkom University, penulis mengampu berbagai mata kuliah, termasuk Manajemen Data Enterprise, Manajemen Risiko, Rekayasa Proses Bisnis, Sistem Enterprise, dan Sistem Informasi Akuntansi dan lain-lain.

Di samping tugas pengajaran, penulis juga aktif terlibat dalam kegiatan tridharma perguruan tinggi. Selain itu, beliau terlibat dalam penyusunan Rencana Strategis Fakultas Rekayasa Industri Telkom University untuk periode 2024–2028. Tidak hanya fokus pada pengajaran, penulis juga aktif dalam dunia penelitian, dengan beberapa publikasi jurnal ilmiah dan presentasi di seminar internasional yang terkait dengan bidang keahliannya. Untuk informasi lebih lanjut atau untuk menjalin kerja sama, penulis dapat dihubungi melalui email di widiafeeyy@telkomuniversity.ac.id atau widiafebriyani@gmail.com.



BAB 2
ANCAMAN DAN KERENTANAN DALAM DUNIA DIGITAL

Mira Wulandari, S.Kom., M.Kom.

Perkembangan era teknologi digital yang sudah berkembang dan semakin maju memberikan dampak pengaruh besar dari berbagai aspek dalam kehidupan masyarakat. Teknologi digital sebuah teknologi informasi yang lebih mengutamakan kegiatan dilakukan secara komputer atau digital dibandingkan dengan menggunakan tenaga manusia (Danuri, 2019). Teknologi digital pada dasarnya sistem pengoperasian yang serba otomatis dan canggih dengan sistem komputerisasi atau format yang dapat dibaca oleh komputer.

Dengan berkembangnya era digital juga berdampak bagi yang sedang berada di fase remaja dan dewasa. Selain itu, era teknologi digital membawa dampak perubahan yang besar dalam berkomunikasi dan teknologi memberikan kemudahan mencari informasi dan konektivitas secara global. Penggunaan media digital sudah menjadi bagian dalam kehidupan remaja saat ini, sebesar 130 juta atau 48% dari total populasi remaja menggunakan media sosial *mobile* atau *gadget* (Zubair, Khan and Albashari, 2023).

Keamanan siber merupakan sebuah aktivitas yang dilakukan untuk menjaga pengguna ruang siber dari berbagai ancaman atau serangan yang ada di ruang siber (Sumartias *et al.*, 2018). Keamanan siber menjadi salah satu Upaya untuk memastikan bahwa pengguna ruang siber

dapat menggunakan teknologi denga naman dari ancaman siber (Fitriati, 2016).

Keberadaan internet akibat dari perkembangan teknologi informasi dan komunikasi menjadi tantangan sekaligus peluang dalam segala aspek kehidupan mengingat Indonesia memiliki minat terhadap internet yang cukup tinggi (Toni *et al.*, 2021). Dengan berkembangnya penggunaan dunia digital, membuat para pemakainya membutuhkan internet untuk dapat mengakses informasi.

Ancaman dan kerentanan dalam dunia digital terhadap pengguna sangat beragam, terutama pada objek atau file dalam dunia digital semakin berkembang. Penjahat dunia maya menjadi lebih pintar dan mahir dalam mengeksploitasi kerentanan dalam sistem digital, termasuk serangan malware, peretasan, dan serangan jaringan canggih (Bram Ronald Sanjaya et al., 2022). Sementara kerentanan bisa berasal dari perangkat lunak yag ketinggalan zaman, kata sandi yang lemah atau jaringan yag tidak aman.

Ancaman terhadap keamanan digital dapat memengaruhi dampak yang sangat signifikan terhadap penggunanya, mulai dari kerugian finansial, pencurian dan pemalsuan data bagi setiap masing-masing individu dan juga Perusahaan terhadap fasilitas yang mendukung terhadap keseharian. Berikut in ancaman utama dalam dunia digital.



1. Malware

Malware memiliki singkatan dari Malicious Software yang merupakan perangkat lunak mencurigakan (Adenansi and Novarina, 2017). Malware dibuat dengan tujuan untuk merusak dan membobol suatu sistem operasi melalui script rahasia atau dapat dianggap dapat disisipkan oleh penyerang secara tersembunyi. Hampir setiap kejahatan melibatkan malware sebuah malware (malicious software) untuk bisa melakukan kejahatan dalam sebuah program (Adenansi dan Novarina, 2017). Berikut ini beberapa jenis malware menurut perilaku.

a. Virus

   Malware yang menempel pada file dan menyebar saat file tersebut akan dijalankan.

b. Worm

   Malware yang dapat menyebar sendiri melalui jaringan tanpa membutuhkan pengguna untuk menjalankan file atau program.

c. Trojan

   Malware yang dapat menyamar sebagai program yang sah, seperti pembaruan, *game* atau virus agar dapat mengelabui pengguna agar dapat menginstal.

d. Spyware

   Malware yang dapat memantau segala aktivitas pengguna secara diam-diam, seperti merekam aktivitas

browsing, mencuri informasi data pribadi atau dapat memantau aktivitas di keyboard.

e. Ransomware

Malware yang dapat mengenkripsi data dan meminta sebuah tebusan (rabsom) untuk membebaskan data tersebut.

f. Adware

Malware yang dapat menampikan iklan yang tidak diinginkan tanpa sepengetahuan oleh penggunanya.

g. Keylogger

Malware yang dapat merekam di setiap ketukan pada sebuah keyboard, yang dapat digunakan untuk mencuri kata sandi dan nomor kartu kredit.

h. Botnet

Jaringan komputer yang dapat terinfeksi malware dan dapat diatur secara bersamaan oleh hacker dengan melakukan berbagai serangan seperti spam dan DDoS.

i. Logic Bombs

Malware yang dipicu oleh kondisi tertentu seperti tanggal, waktu, dan kegiatan tertentu.

2. *Phishing*

Phisher berusaha melakukan penipuan untuk mendapatkan informasi sensitif, seperti username, password, dan rincian kartu kredit dengan menyamar sebagai entitas terpercaya untuk sebuah komunikasi elektronik (N.P.Singh, 2007). Faktor yang berkontribusi terhadap maraknya *phising*



adalah kurangnya pemahaman pengguna terhadap teknologi yang digunakan (Gulo, Lasmadi and Nawawi, 2021).

3. Ransomware

Ransomware merupakan sebuah perangkat lunak berbahaya yang dapat mengenkripsi data atau file pengguna secara eksplisit atau secara langsung dengan menuntut tebusan dengan mendeskripsikan sebuah tampilan pesan untuk mendeskripsikan data dalam jangka waktu spesifik.

4. dDoS (*Distribute Denial of Service*)

Distribute Denial of service (DDoS) adalah serangan yang membanjiri jaringan dengan paket atau permintaan yang merusak server dan sistem (Sumayyah *et al.*, 2024). Beberapa jenis serangan DDos di antaranya seperti ICMP flood, SYN flood dan IP packet flood, mengidentifikasi serangan DDoS menjadi lebih sulit karena ada berbagai jenis strategi (Zidane, 2022).

5. *Data Breach*

Data breaches atau pelanggaran data merupakan segala aktivitas yang menyebarluaskan data dan informasi yang bersifat rahasia, sensitif, dan dilindungi kepada pihak-pihak yang tidak berwenang (Manajemen *et al.*, 2025). Kebocoran data atau *data breach* merupakan salah satu kasus *cyber crime* atau pencurian data personal yang bisa dilihat dan dapat diakses oleh pihak yang tidak bertanggug jawab.

6. SQL Injection

Sql injection adalah teknik serangan dilakukan oleh hacking yang dilakukan di aplikasi client dengan cara menggabungkan perintah SQL yang ada di memori aplikasi client, Sql Injection merupakan teknik mengeksploitasi aplikasi berbasis web yang menggunakan database atau di dalamnya menggunakan basis data dengan menambahkan kode berbahaya ke dalam perintah SQL (Bastian, Sujadi and Abror, 2020).

Para hacker menyerang dengan memasukkan kode SQL ke dalam input aplikasi web melalui formular, pencarian ataupun parameter URL, dengan menginput berbagai aplikasi ini akan diteruskan ke dalam database untuk dijalankan sebagai perintah SQL. Yang sangat lebih berbahaya adalah mematikan database itu sendiri, sehingga tidak bisa memberi layanan kepada web server (Yudistira, 2012). Berikut ini jenis-jenis *phishing*.

a. Whaling

   Menargetkan orang penting dalam organisasi seperti direktur sebuah perusahaan.

b. Smishing

   Dapat menyerang melalui pesan singkat atau SMS.

c. Viching

   Dapat menyerang melalui telepon.



7. Serangan *Man-in-the-Middle* (MitM)

Keamanan pada jaringan komputer menjadi perhatian yang sangat penting, terutama dalam mengalami serangan dari *Man in the Middle* (MITM). *Man in the middle attacks* adalah salah satu serangan pada jaringan denga akses terbuka (Saputra, 2019). *Man in the middle attacks* merupakan serangan yang pada dasarnya penyerang memasukkan dirinya di antara dua pihak atau perangkat dalam mode sembunyi sehingga semua paket yang berlintas antara kedua pihak yang sah akan dialihkan melalui penyerangan tersebut (Riadi, Umar and Busthomi, 2020).

Perkembangan era teknologi digital membantu kemudahan aktivitas manusia sehingga memberikan dampak kejahatan siber. Dengan meningkatnya pendidikan digital, ekonomi digital, dan bekerja dari rumah, semuanya menjadi *online* dalam semalam yang telah memunculkan kasus-kasus kejahatan siber (Bhattacharya et al., 2021). Berikut ini kerentanan yang perlu diwaspadai oleh pengguna digital.

1. Kata sandi lemah atau identik
2. Perangkat lunak ketinggalan zaman
3. Jaringan yang tidak aman
4. Kerentanan pada IoT (*Internet of Things*)
5. Kurangnya kesadaran pengguna

Setiap perkembangan pada teknologi digital pasti memiliki dampak ancaman dan kerentanan terhadap

penggunaanya. Selain itu, bisa menerapkan autentikasi multi-faktor, enkripsi, dan audit keamanan rutin untuk mendeteksi dan memitigasi kerentanan (Kafi & Akter, 2023). Ada beberapa dampak ancaman dan kerentanan dalam dunia digital.

1. Kehilangan data
2. Kerugian finansial
3. Gangguan operasional
4. Kerugian reputasi
5. Dampak hukum



Daftar Pustaka

Adenansi, R. and Novarina, L.A. (2017) 'Malware Dynamic', *JOEICT (Jurnal of Education and Information Communication Technology)*, 1(1), pp. 37–43.

Bastian, A., Sujadi, H. and Abror, L. (2020) 'Analisis Keamanan Aplikasi Data Pokok Pendidikan (Dapodik) Menggunakan Penetration Testing Dan Sql Injection', *INFOTECH Journal*, 6(2), pp. 65–70.

Bhattacharya, C.D. S., Sachdev, B., Kundu, A., & Bansal, K. (2021). Impact of Cyber Law in Modern Era with Advancement in Technology and Protection from Rising Threats of Cyber Crimes in Our Socio Economic Sector. International Journal of Advanced Research, 9, 274-279.

Danuri, M. (2019) 'Development and transformation of digital technology', *Infokam*, XV(II), pp. 116–123.

Fitriati, R. (2016) 'Membangun Model Kebijakan Nasional Keamanan Siber Dalam Sistem Pertahanan Negara', pp. 1–235.

Gulo, A.S., Lasmadi, S. and Nawawi, K. (2021) 'Cyber Crime dalam Bentuk Phising Berdasarkan Undang-Undang Informasi dan Transaksi Elektronik', *PAMPAS: Journal of Criminal Law*, 1(2), pp. 68–81.

Kafi, M. A., Akter, N. (2023). Securing information in the digital realm: case studies in cybersecurity for accounting data protection. American Journal of Trade

and Policy, 10(1), 15-26.

Manajemen, J. *et al.* (2025) 'Strategi Mengatasi Data Breaches di Era Industri 4 . 0 : Kasus Data Breaches Bank Rakyat Indonesia 2021 lalu . Bank Rakyat Indonesia atau BRI adalah badan usaha milik Indonesia yang', 3(April).

N. P. Singh, P., (2007). online Frauds in Banks wirh Phishing. Journal of Internet Banking and Commerce, p.4.

Riadi, I., Umar, R. and Busthomi, I. (2020) 'Optimasi Keamanan Autentikasi dari Man in the Middle Attack (MiTM) Menggunakan Teknologi Blockchain', *Journal of Information Engineering and Educational Technology*, 4(1), pp. 15–19.

Saputra, D. (2019) 'Network Forensics Analysis of Man in the Middle Attack Using Live Forensics Method', *International Journal of Cyber-Security and Digital Forensics*, 8(1), pp. 66–73.

Sumartias, S. *et al.* (2018) 'Keamanan siber dan pembangunan demokrasi di Indonesia', *Jurnal Ilmiah Indonesia*, p. 181.

Sumayyah, Z.I. *et al.* (2024) 'Penerapan dan Mitigasi Teknik Slowloris dalam Serangan Distributed Denial-of-Service (DDos) terhadap Website Ilegal dengan Kali Linux', *Journal of Internet and Software Engineering*, 1(2), p. 14.

Toni, H. *et al.* (2021) 'Fenomena Cyber Religion sebagai



Ekspresi Keberagamaan di Internet pada Komunitas Shift (Cyber Religion Phenomenon as a Religious Expression on the Internet in the Shift Community)', *Jurnal Dakwah Risalah*, 32(1), p. 56.

Zidane, M. (2022) 'Klasifikasi Serangan Distributed Denial-of-Service (DDoS) menggunakan Metode Data Mining Naïve Bayes', *Jurnal Pengembangan Teknologi Informasi dan Ilmu Komputer*, 6(1), pp. 172–180.

Zubair, U., Khan, M.K. and Albashari, M. (2023) 'Link between excessive social media use and psychiatric disorders', *Annals of Medicine and Surgery*, 85(4), pp. 875–878.

Tentang Penulis



Mira Wulandari, S.Kom., M.Kom. merupaka lulusan S1 di Program Studi Sistem Informasi Fakultas Teknik Universitas BSI Bandung tahun 2016 dan lulusan S2 di Program Magister Sistem Informasi STMIK LIMI Bandung pada tahun 2021. Saat ini penulis adalah dosen aktif di Program Studi Teknologi Informasi Politeknik Aisyiyah Pontianak. Penulis aktif menjabat sebagai Sekretaris Prodi Teknologi Informasi Politeknik Aisyiyah Pontianak.

Selain itu, penulis aktif menulis buku dan berbagai jurnal ilmiah. Penulis juga telah mengikuti Pelatihan Pekerti Universitas Muhammadiyah Prof. Dr.HAMKA pada tahun 2023. Penulis pernah menjadi pembicara dalam kegiatan pengabdian masyarakat internasional yang bekerja sama antara Politeknik Aisyiyah Pontianak dengan Badan Koordinasi KKN Internasional dan Pengabdian Internasional (BKKPI) Pimpinan Cabang Istimewa Muhammadiyah (PCIM) Malaysia dan Pimpinan Cabang Istimewa Aisyiyah (PCIA) Malaysia pada tahun 2025



BAB 3
DASAR-DASAR KRIPTOGRAFI

Yudha Riwanto,M.Kom.

A. Pengantar Kriptografi

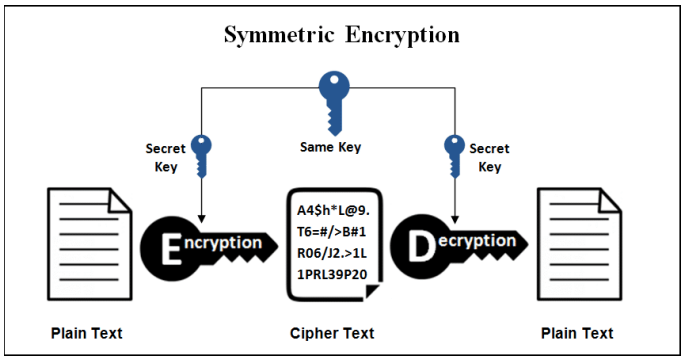
Kriptografi adalah sains dan seni untuk mengamankan informasi dari teknik pengodean, serta hanya mereka yang memiliki akses yang dapat membacanya. Di era digital saat ini, enkripsi adalah pilar utama mempertahankan keamanan data, yang meluas ke komunikasi pribadi mengenai transaksi keuangan (Stallings, 2017). Dalam kehidupan sehari -hari, kami menggunakan enkripsi secara tidak sadar.

Berikut ini tujuan utama kriptografi.

1. Kerahasiaan (*Confidentiality*): Menjamin bahwa informasi hanya dapat diakses oleh pihak yang berwenang.
2. Integritas (*Integrity*): Memastikan bahwa data tidak diubah tanpa izin selama proses transmisi atau penyimpanan.
3. Autentikasi (*Authentication*): Memverifikasi identitas pihak yang terlibat dalam komunikasi.
4. Non-Repudiasi (*Non-repudiation*): Mencegah pihak yang terlibat menyangkal keterlibatan mereka dalam suatu transaksi atau komunikasi (Paar & Pelzl, 2010).



Berikut ini ilustrasi tujuan kriptografi.



Sumber: selembardigital.com

B. Sejarah Singkat Kriptografi

1. Era Kuno

Kriptografi bukanlah hal baru. Bukti pertama dari penggunaannya adalah orang Mesir kuno sekitar tahun 1900 SM. Ditemukan dalam bentuk hieroglifik yang tidak biasa yang digunakan untuk mengirim pesan rahasia (Singh, 2000). Di Mesopotamia, tablet tanah liat telah menemukan simbol khusus untuk menyembunyikan informasi penting.

2. Zaman Klasik dan Abad Pertengahan

Selama era Romawi, Julius Caesar menciptakan metode enkripsi sederhana yang dikenal sebagai kriptografi Caesar dengan mengganti setiap huruf dengan huruf lain yang tetap jauh dari alfabet (Kahn, 1996). Ini adalah bentuk awal glikologi alternatif yang masih digunakan sebagai dasar untuk pembelajaran kriptografi. Pada abad ke-6, Vigenère

Cipher, sebuah teknologi fasilitas Polyali Fabe, muncul pada abad ke-16, menggunakan kata-kata dalam bentuk kata-kata untuk menyandikan pesan. Cipher ini sangat sulit untuk diselesaikan pada saat itu dan hanya dijelaskan dengan baik berabad-abad kemudian.

Di bagian timur dunia Islam juga berkontribusi pada banyak hal untuk pengembangan enkripsi. Ilmuwan Arab Al-Kindi menulis buku pertamanya tentang analisis crypt dan memperkenalkan metode analisis frekuensi. Ini adalah dasar dari banyak teknik solusi kata sandi yang akan digunakan nanti

3. Era Modern

Selama Perang Dunia II, Jerman menggunakan mesin enigma untuk mengenkripsi pesan militer. Mesin ini dianggap sangat rumit, tetapi berhasil diselesaikan oleh tim crypto Inggris di Bletchley Park di bawah arahan Alan Turing (Singh, 2000). Keberhasilan ini dianggap sebagai salah satu faktor di balik kemenangan aliansi.

Setelah perang, enkripsi mulai berkembang dengan cepat, terutama ketika komputer digital tersebar luas. Pada tahun 1977, algoritma RSA diperkenalkan oleh Ron Rivest, Adi Shamir dan Leonard Adleman, yang menjadi pondasi penting dalam sistem keamanan digital modern (Rivest et al., 1978).



C. Konsep Dasar dalam Kriptografi

1. Plaintext dan Ciphertext

Plaintext adalah pesan asli, dan ciphetext adalah hasil dari enkripsi yang tidak dapat dipahami.

2. Enkripsi dan Dekripsi

Teks polos dikonversi ke ciphertext. Ada decoding. Keduanya dapat dilakukan secara manual (klasik) atau digital (modern) (Stallings, 2017).

3. Kunci Kriptografi

- Simetris: Satu kunci untuk enkripsi dan dekripsi (contoh: AES). Cepat, namun distribusi kunci sulit.
- Asimetris: Menggunakan kunci publik dan privat (contoh: RSA). Cocok untuk komunikasi tanpa pertukaran kunci langsung (Diffie & Hellman, 1976).

4. Fungsi Hash

Mengonversi data menjadi output tetap dan satu arah yang digunakan untuk memastikan integritas data (Schneier, 2015). Properti penting: output tetap, tidak bisa dibalik, avalanche effect, tahan tabrakan.

Contoh algoritma hash:

- MD5: Sekarang dianggap tidak aman.
- SHA-1: Tidak lagi direkomendasikan karena kelemahan keamanan.
- SHA-256: Umum digunakan untuk verifikasi integritas data, termasuk dalam sistem blockchain.

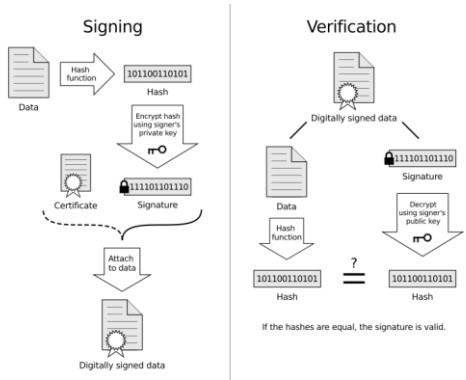
5. Tanda Tangan Digital

Tanda tangan digital adalah kombinasi dari fungsi hash dan asimetris yang digunakan untuk memastikan keandalan dan integritas data Anda. Proses ini dapat dijelaskan dalam beberapa langkah berikut ini.

- Hashing Data: Pengirim pertama kali membuat sidik jari digital yang dibuat dengan data asli menggunakan algoritma hash seperti SHA-256. Proses ini membuat versi tetap (hash) yang mewakili konten data.
- Pembuatan Tanda Tangan: Hash dihasilkan dan kemudian dienkripsi dengan kunci pribadi pengirim. Hasil dari enkripsi ini disebut tanda tangan digital.
- Pengiriman Data: Data asli dan tanda tangan digital dikirim ke penerima.
- Verifikasi oleh Penerima: Untuk memastikan keandalan dan integritas data penerima menjalankan proses peninjauan dalam dua fase. Pertama, penerima mendekripsi tanda tangan digital dengan kunci publik pengirim. Proses ini menghasilkan nilai hash yang sebelumnya dibuat oleh pengirim. Selain itu, penerima menghitung nilai hash data yang diterima menggunakan algoritma yang sama, misalnya SHA-256. Jika nilai hash dari hasil decoding dan hasil perhitungan ulang adalah sama, kita dapat menarik kesimpulan bahwa data tidak berubah selama pengiriman dan pada kenyataannya berasal dari pengirim yang sah.



- Validasi: Jika hasil tanda tangan digital dan hash yang dihitung oleh penerima menentukan nilai yang sama, proses validasi dianggap berhasil. Ini berarti bahwa data yang diterima selama pengiriman tetap tidak berubah untuk memastikan konsistensi. Selain itu, kompatibilitas ini juga membuktikan bahwa data sebenarnya berasal dari pengirim yang sah karena hanya kunci pribadi pengirim yang dapat membuat tanda tangan digital yang valid untuk kunci publik. Ini berarti bahwa keandalan (autentikasi) dan integritas data dapat ditentukan.



Sumber: https://commons.wikimedia.org/wiki/File%3ADigital_Signature_diagram. svg?

D. Algoritma Kriptografi

1. Algoritma Simetris

- Caesar Cipher: Salah satu metode enkripsi tertua menggunakan teknik penggantian sederhana. Setiap karakter dalam pesan asli ditangguhkan pada jumlah

abjad tetap. Misalnya, dengan pergeseran 3, huruf A menjadi D, B menjadi E, dan seterusnya. Caesar Cipher mudah dipecahkan, tetapi penting dalam sejarah enkripsi sebagai dasar untuk konsep enkripsi.

- Vigenère Cipher: Menggunakan kunci dalam bentuk kata atau frasa untuk menentukan pergeseran karakter dalam pesan. Teknik ini adalah alternatif yang bagus untuk sopan. Ini berarti bahwa karakter yang berbeda dapat bergeser secara berbeda tergantung pada karakter utama yang digunakan. Kode ini dianggap lebih aman daripada caesar cipher dan pernah dianggap tidak terputus di zamannya.
- AES (*Advanced Encryption Standard*): AES adalah algoritma simetris modern yang sangat andal dan efisien. AES menggunakan patogen 128-bit dan mendukung panjang kunci 128, 192, atau 256-bit. Karena keamanannya yang tinggi dan kinerja kecepatan tinggi, AES adalah standar enkripsi internasional dan digunakan dalam berbagai aplikasi seperti VPN, jaringan Wi-Fi, komunikasi seluler, enkripsi file, dan basis data (Stallings, 2017).

2. Algoritma Asimetris

- RSA: RSA adalah algoritma enkripsi asimetris yang menggunakan konsep kunci publik dan kunci pribadi(Rivest et al., 1978). Data dienkripsi dengan kunci publik dan hanya dapat didekripsi dengan kunci



pribadi yang sesuai. RSA sangat cocok untuk melindungi email, transaksi digital, dan bursa saham kritis melalui internet.

- Diffie-Hellman: Bukanlah algoritma enkripsi langsung, tetapi protokol untuk membentuk kunci umum antara dua pihak yang belum pernah bertemu. Komunikasi dilakukan melalui saluran yang tidak aman, tetapi kedua belah pihak masih dapat membuat kunci rahasia dan kunci rahasia yang sama. Protokol ini sering digunakan sebagai dasar untuk sistem enkripsi sesi.
- ECC (*Elliptic Curve Cryptography*): Algoritma asimetris yang menggunakan kurva elips untuk menghasilkan mitra penting. ECC memberikan tingkat keamanan yang mendukung RSA, tetapi ukuran kuncinya jauh lebih kecil, misalnya, kunci ECC 256-bit mendukung RSA 3072-bit. ECC populer di perangkat IoT, kartu pintar dan perangkat seluler karena mereka adalah sumber daya yang efisien dan efisien.

E. Aplikasi Kriptografi

1. Komunikasi Aman

WhatsApp dan sinyal menggunakan enkripsi *end-to-end* untuk memastikan bahwa hanya pengirim dan penerima yang dapat membaca pesan (Paar & Pelzl, 2010).

2. Transaksi *Online*

SSL/TLS digunakan untuk mengenkripsi data antara browser dan server (Stallings, 2017). Simbol pada bilah alamat menunjukkan koneksi yang aman. Transaksi *e-commerce* dan perbankan *online* sangat bergantung pada teknologi ini.

3. Mata Uang Digital

Cryptocurrency memainkan peran penting dalam teknologi blockchain, termasuk cryptocurrency seperti Bitcoin dan Ethereum (NIST, 2023). Blockchain menggunakan hashing, tanda tangan digital dan konsensus algorithms untuk memastikan integritas dan keamanan jaringan Anda.

4. Identitas Digital

Tanda tangan digital digunakan dalam dokumen elektronik dan *e-government*, seperti e-KTP di Indonesia. Di banyak negara, identitas digital telah menjadi bagian penting dari layanan publik.

5. Penyimpanan dan Transfer File

Layanan seperti Google Drive, Dropbox, dan OneDrive menggunakan enkripsi untuk melindungi data pengguna selama proses penyimpanan dan transfer file.

F. Tantangan dan Masa Depan Kriptografi

1. Komputasi Kuantum

Komputer kuantum dapat menyelesaikan algoritma enkripsi tradisional seperti RSA dan ECC. Ini memicu perlombaan



yang menciptakan algoritma pasca-kuantum. Secara teori, algoritma seperti Shor dan Grover dapat mengurangi efektivitas banyak skema enkripsi.

2. Kriptografi Pasca-Kuantum

NIST saat ini mengembangkan standar baru untuk algoritma yang tahan terhadap serangan kuantum. Beberapa kandidat setelah algoritma kuantum termasuk enkripsi berbasis grid, tanda tangan berbasis hash, dan enkripsi polinomial multivariat (NIST, 2023).

3. Etika dan Regulasi

Peraturan seperti GDPR dan undang -undang perlindungan data di berbagai negara menekankan pentingnya keamanan dan privasi (EU, 2018). Namun, ada juga dilema antara hak perlindungan data dan kebutuhan pemerintah untuk akses data dalam kebijakan kriminal. Teknologi seperti enkripsi backdoor sering kali kontroversial bagi para ahli keamanan dan pembuat kebijakan.

Daftar Pustaka

Diffie, W., & Hellman, M. (1976). New Directions in Cryptography. IEEE Transactions on Information Theory, 22(6), 644–654.

European Union. (2018). General Data Protection Regulation (GDPR). https://gdpr.eu

Kahn, D. (1996). The Codebreakers: The Comprehensive History of Secret Communication from Ancient Times to the Internet. Scribner.

National Institute of Standards and Technology (NIST). (2023). Post-Quantum Cryptography Standardization. https://csrc.nist.gov/projects/post-quantum-cryptography

Paar, C., & Pelzl, J. (2010). Understanding Cryptography: A Textbook for Students and Practitioners. Springer.

Rivest, R., Shamir, A., & Adleman, L. (1978). A Method for Obtaining Digital Signatures and Public-Key Cryptosystems. Communications of the ACM, 21(2), 120–126.

Stallings, W. (2017). Cryptography and Network Security: Principles and Practice (7th ed.). Pearson Education.

Schneier, B. (2015). Applied Cryptography: Protocols, Algorithms, and Source Code in C (20th Anniversary Edition). Wiley.



Singh, S. (2000). The Code Book: The Science of Secrecy from Ancient Egypt to Quantum Cryptography. Anchor Books.

Tentang Penulis



Yudha Riwanto,M.Kom., lahir di Bantul, 18 Maret 1997. Penulis merupakan lulusan S1 Teknik Informatika dan S2 Informatika dari Islam Negeri Sunan Kalijaga. Saat ini penulis sebagai dosen yang ber-*homebase* di Program studi S1 Informatika Universitas Amikom Yogyakarta, penulis juga sebagai dosen luar biasa di Program studi Teknologi Informasi serta Informatika Universitas Jendral Achmad Yani Yogyakarta. Peneliti juga aktif dalam industri *software engineer.*



BAB 4
KEAMANAN JARINGAN

Muhamad Masjun Efendi, M.Kom

A. Pengertian Jaringan Komputer

Jaringan komputer adalah sekumpulan perangkat elektronik, seperti komputer, server, printer, dan perangkat jaringan lainnya yang saling terhubung satu sama lain dalam rangka berbagi data, informasi, serta sumber daya. Konektivitas ini dapat diwujudkan melalui media kabel (*wired*) atau nirkabel (wireless). Tujuan utama dari jaringan komputer adalah mempermudah komunikasi antarperangkat dan pengguna, serta meningkatkan efisiensi dalam penggunaan sumber daya teknologi informasi (Kurose & Ross, 2017).

Menurut Tanenbaum dan Wetherall (2011), jaringan komputer tidak hanya mencakup infrastruktur fisik, seperti kabel, router, dan switch, tetapi juga protokol dan perangkat lunak yang mengatur alur komunikasi antarperangkat. Protokol seperti TCP/IP menjadi fondasi penting dalam pengiriman data secara akurat dan efisien di dalam jaringan. Dengan adanya protokol standar tersebut, berbagai jenis perangkat dari vendor berbeda dapat saling berkomunikasi tanpa hambatan signifikan.

Jaringan komputer juga dikelompokkan berdasarkan cakupan geografisnya, seperti *Local Area Network* (LAN), *Metropolitan Area Network* (MAN), dan *Wide Area Network* (WAN). Setiap jenis jaringan memiliki karakteristik dan kebutuhan infrastruktur yang berbeda sesuai dengan tujuan penggunaannya. Sebagai contah, LAN digunakan untuk area



kecil seperti kantor atau rumah, sedangkan WAN mencakup wilayah yang lebih luas seperti antarkota atau negara (Hakim, 2018). Perkembangan jaringan komputer telah menjadi tulang punggung bagi transformasi digital di berbagai sektor, termasuk pendidikan, bisnis, dan pemerintahan.

B. Jenis-Jenis Jaringan

Berikut beberapa jenis jaringan umum yang digunakan saat ini.

1. LAN (*Local Area Network*)

Local Area Network (LAN) adalah jenis jaringan yang mencakup area kecil, seperti rumah, kantor, laboratorium, atau kampus. Jaringan ini memungkinkan perangkat saling terhubung untuk berbagi data dan sumber daya seperti printer atau file server. LAN biasanya menggunakan media kabel (seperti kabel UTP) atau teknologi nirkabel seperti Wi-Fi. Jaringan ini dikenal memiliki kecepatan transfer data yang tinggi dan latensi rendah (Hakim, 2018).

2. WAN (*Wide Area Network*)

Wide Area Network (WAN) adalah jaringan yang mencakup area geografis yang sangat luas, seperti antarkota, negara hingga benua. Contoh paling nyata dari WAN adalah internet yang menghubungkan jutaan perangkat di seluruh dunia. WAN biasanya menggunakan infrastruktur milik penyedia

layanan telekomunikasi, seperti satelit, kabel serat optik, atau jalur *leased line* (Tanenbaum & Wetherall, 2011).

3. MAN (*Metropolitan Area Network*)

Metropolitan Area Network (MAN) merupakan jaringan yang menjangkau wilayah metropolitan atau sebuah kota. MAN biasanya digunakan oleh instansi atau perusahaan besar untuk menghubungkan beberapa kantor atau cabang yang berada dalam satu kawasan perkotaan. Jaringan ini berfungsi sebagai penghubung antara beberapa LAN dalam cakupan yang lebih luas, namun tidak sampai skala nasional atau global (Kurose & Ross, 2017).

4. WLAN (*Wireless LAN*)

Wireless Local Area Network (WLAN) adalah versi nirkabel dari LAN. Jaringan ini memungkinkan perangkat terhubung tanpa kabel menggunakan gelombang radio, seperti melalui teknologi Wi-Fi. WLAN banyak digunakan di tempat-tempat umum, seperti kafe, hotel, dan kantor karena memberikan fleksibilitas mobilitas yang tinggi bagi pengguna. Keamanan menjadi faktor penting dalam pengaturan jaringan nirkabel ini (Hakim, 2018).

5. PAN (*Personal Area Network*)

Personal Area Network (PAN) adalah jaringan yang mencakup area sangat kecil, biasanya hanya sekitar 10 meter dari pengguna. PAN digunakan untuk menghubungkan perangkat pribadi, seperti smartphone, headset Bluetooth, keyboard, atau mouse nirkabel.



Teknologi yang sering digunakan dalam PAN, antara lain, Bluetooth, Zigbee, dan infrared. Jaringan ini sangat berguna dalam mendukung pengalaman komputasi *mobile* dan personal (Tanenbaum & Wetherall, 2011).

C. Arsitektur Jaringan Dasar

Arsitektur jaringan modern biasanya mengacu pada model OSI (*Open Systems Interconnection*) yang terdiri dari tujuh lapisan.

1. *Physical Layer*

Physical Layer bertanggung jawab atas transmisi data mentah secara fisik melalui media seperti kabel, fiber optik, atau gelombang nirkabel. Lapisan ini menentukan spesifikasi listrik, mekanis, dan fungsional dari perangkat serta cara data dikirim sebagai sinyal bit (0 dan 1). Contohnya termasuk kabel jaringan, hub, dan repeater (Kurose & Ross, 2017).

2. *Data Link Layer*

Data Link Layer bertugas mengatur transmisi data yang dapat diandalkan antara dua node yang terhubung langsung dalam jaringan lokal. Lapisan ini memastikan pengiriman frame data tanpa kesalahan melalui kontrol aliran dan deteksi error, serta menyediakan alamat fisik (MAC address). Perangkat seperti switch dan bridge bekerja pada lapisan ini (Tanenbaum & Wetherall, 2011).

3. *Network Layer*

Network Layer berfungsi untuk menentukan jalur terbaik dalam pengiriman paket data dari satu host ke host lain, bahkan melalui jaringan yang berbeda. Lapisan ini menggunakan protokol seperti IP (Internet Protocol) untuk memberikan alamat logis dan routing. Router adalah perangkat utama yang bekerja pada lapisan ini (Hakim, 2018).

4. *Transport Layer*

Transport Layer mengelola komunikasi *end-to-end* antara host, termasuk kontrol aliran, multiplexing, dan penyediaan layanan transport yang andal atau tidak andal. Protokol utamanya adalah TCP (*Transmission Control Protocol*) untuk koneksi yang andal dan UDP (*User Datagram Protocol*) untuk transmisi cepat tanpa koneksi (Kurose & Ross, 2017).

5. *Session Layer*

Session Layer mengatur sesi komunikasi antar-aplikasi, termasuk pembukaan, pemeliharaan, dan penutupan koneksi. Lapisan ini juga menyinkronkan dialog antara aplikasi, serta mengelola token untuk menghindari konflik akses bersamaan (Tanenbaum & Wetherall, 2011).

6. *Presentation Layer*

Presentation Layer bertanggung jawab atas format data agar dapat dipahami oleh aplikasi penerima. Tugasnya meliputi enkripsi, kompresi, dan konversi data ke format standar. Contohnya adalah ketika browser menerima file HTML terenkripsi dan kemudian mendekripsinya (Hakim, 2018).



7. *Application Layer*

Application Layer adalah lapisan teratas dalam model OSI yang berinteraksi langsung dengan pengguna akhir melalui aplikasi, seperti web browser, email, dan FTP. Lapisan ini menyediakan layanan jaringan berbasis aplikasi dan menggunakan protokol seperti HTTP, SMTP, dan FTP (Kurose & Ross, 2017).

D. Keamanan Jaringan

Keamanan jaringan merujuk pada sekumpulan langkah, teknologi, dan kebijakan yang dirancang untuk melindungi integritas, ketersediaan, dan kerahasiaan data serta sumber daya dalam sebuah jaringan komputer. Tujuan utamanya adalah mencegah akses tidak sah, serangan *cyber*, serta penggunaan yang tidak diizinkan terhadap sistem jaringan. Dalam dunia yang semakin terhubung, keamanan jaringan menjadi sangat penting untuk menjaga operasi bisnis, melindungi informasi sensitif, dan memastikan kepercayaan pengguna (Whitman & Mattord, 2019).

Komponen utama dalam keamanan jaringan meliputi firewall, sistem deteksi intrusi (IDS), sistem pencegahan intrusi (IPS), enkripsi data, autentikasi multi-faktor, dan kontrol akses berbasis peran. Setiap elemen ini bekerja bersama untuk membentuk lapisan pertahanan yang kuat terhadap berbagai ancaman, seperti malware, *phishing, denial-of-service* (DoS), dan serangan lainnya. Selain itu,

pemantauan aktif dan analisis log juga diperlukan untuk mendeteksi dan merespons insiden keamanan secara *real-time* (Stallings, 2017).

Penerapan keamanan jaringan yang efektif tidak hanya bergantung pada teknologi, tetapi juga pada kesadaran dan pelatihan pengguna, manajemen konfigurasi sistem, serta kebijakan keamanan yang jelas dan konsisten. Organisasi harus melakukan evaluasi berkala terhadap risiko keamanan, serta uji penetrasi untuk mengidentifikasi dan memperbaiki kerentanan sebelum dimanfaatkan oleh pelaku kejahatan *cyber.* Tanpa strategi keamanan yang matang, jaringan akan rentan terhadap pelanggaran data dan gangguan operasional (Ciampa, 2020).

E. Aspek Keamanan Jaringan

Keamanan jaringan mencakup berbagai aspek penting yang harus diperhatikan untuk memastikan bahwa sistem tetap terlindungi dari ancaman internal maupun eksternal. Aspek-aspek ini tidak hanya melibatkan teknologi keamanan, tetapi juga kebijakan, prosedur operasional, dan kesadaran pengguna. Berikut ini penjelasan mengenai beberapa aspek utama dalam keamanan jaringan.

1. Kerahasiaan (*Confidentiality*)

Kerahasiaan menjamin bahwa informasi hanya dapat diakses oleh pihak-pihak yang memiliki izin. Ini dicapai



melalui mekanisme, seperti autentikasi, kontrol akses, dan enkripsi data. Tanpa kerahasiaan yang baik, data sensitif seperti informasi pribadi, dokumen bisnis, atau rahasia perusahaan rentan terhadap pencurian atau pengungkapan ilegal (Stallings, 2017).

2. Integritas (*Integrity*)

Integritas memastikan bahwa data tetap akurat dan tidak dimodifikasi secara tidak sah selama transmisi atau penyimpanan. Untuk menjaga integritas, digunakan metode, seperti checksum, hashing, dan *digital signature*. Tanpa integritas yang terjaga, data bisa menjadi tidak dapat dipercaya dan menyebabkan keputusan salah (Whitman & Mattord, 2019).

3. Ketersediaan (*Availability*)

Ketersediaan berarti sistem dan layanan jaringan harus selalu dapat diakses oleh pengguna yang sah kapan pun dibutuhkan. Untuk mendukung ketersediaan, diperlukan infrastruktur yang andal, *backup* data, serta perlindungan terhadap serangan seperti DDoS (*Distributed Denial of Service*) (Ciampa, 2020).

4. Autentikasi (*Authentication*)

Autentikasi adalah proses verifikasi identitas pengguna atau sistem sebelum diberikan akses ke sumber daya jaringan. Metode autentikasi yang kuat seperti *Multi-Factor Authentication* (MFA) membantu mencegah akses ilegal ke sistem, bahkan jika kata sandi bocor (Buchanan, 2020).

5. Otorisasi (*Authorization*)

Setelah pengguna berhasil diautentikasi, otorisasi menentukan hak akses apa saja yang dimiliki oleh pengguna tersebut. Prinsip *least privilege* biasanya diterapkan untuk membatasi akses hanya pada sumber daya yang benar-benar diperlukan (Anderson, 2018).

6. Audit dan *Monitoring* (*Accountability*)

Monitoring aktivitas jaringan dan pencatatan log (*logging*) sangat penting untuk mendeteksi ancaman secara dini serta menyelidiki insiden keamanan. Tools seperti SIEM (*Security Information and Event Management*) digunakan untuk analisis dan pelacakan aktivitas mencurigakan (Cherdantseva et al., 2016).

F. Istilah dalam Keamanan Jaringan

Berikut ini istilah-istilah yang umum ditemui dalam keamanan jaringan.

1. *Hacking*

Setiap usaha atau kegiatan yang dilakukan tanpa izin atau tanpa sepengetahuan pengelola jaringan telekomunikasi untuk memasuki suatu jaringan dan mencoba mencuri file, seperti file password dan lainnya. Pelakunya disebut hacker, yaitu individu atau kelompok yang berusaha menembus sistem pengamanan jaringan telekomunikasi.



2. *Cracking*

Setiap usaha atau kegiatan yang dilakukan untuk memasuki suatu jaringan telekomunikasi dan mencoba merusak serta menghancurkan integritas jaringan tersebut. Pelakunya disebut cracker, yaitu individu atau kelompok yang merusak dan menghancurkan integritas seluruh jaringan telekomunikasi.

3. *Denial of Service* (DoS)

Usaha untuk membanjiri suatu IP Address dengan informasi sehingga menyebabkan *crash* atau jaringan telekomunikasi kehilangan koneksi ke internet.

4. *Distributed Denial of Service* (DDoS)

Distributed Denial of Service (DDoS) adalah serangan DoS yang menggunakan banyak perangkat komunikasi dalam jaringan telekomunikasi yang berbeda untuk melancarkan ancaman keamanan. Seorang hacker dapat mengambil alih beberapa perangkat dan menggunakannya sebagai platform untuk menjalankan serangan tersebut.

5. *Theft of Information*

Tindakan mencuri informasi rahasia dari suatu perusahaan dengan menggunakan program pembobol password atau sejenisnya.

6. *Corruption of Data*

Serangan yang dilakukan dengan merusak data yang disimpan dalam harddisk suatu host.

7. Spoofing

Bentuk kegiatan pemalsuan di mana seorang hacker memalsukan identitas pengguna sehingga dapat login secara ilegal ke dalam suatu jaringan telekomunikasi seolah-olah sebagai pengguna asli.

8. Sniffer

Alat lain dari *"network analyser"* yang berfungsi untuk memantau jaringan telekomunikasi. Alat ini dapat dioperasikan pada hampir semua jenis protokol, seperti Ethernet, TCP/IP, IPX, dan lainnya.

9. Password Cracker

Program yang dapat membuka enkripsi suatu password atau sebaliknya mematikan sistem pengamanan password.

10. Destructive Devices

Sekumpulan program virus yang dibuat khusus untuk menghancurkan informasi, seperti Trojan, Worm, Email Bombs, dan Nukes.

11. Scanner

Program yang secara otomatis akan mendeteksi kelemahan (*security weaknesses*) pada suatu perangkat dalam jaringan lokal (*local host*) atau perangkat dalam jaringan telekomunikasi di lokasi lain (*remote host*). Dengan program ini, seorang hacker yang berada di Inggris, misalnya, dapat dengan mudah menemukan kelemahan keamanan pada server di Amerika atau di belahan dunia lainnya tanpa harus meninggalkan ruangannya.



G. *Best Practices* dalam Keamanan Jaringan

Berikut ini beberapa langkah terbaik yang dapat diambil agar jaringan tetap aman.

1. Gunakan firewall dan *update* secara berkala

Firewall berfungsi sebagai penghalang antara jaringan internal yang aman dan ancaman eksternal dari internet. Dengan mengaktifkan firewall dan memperbarui aturannya secara berkala, organisasi dapat melindungi sistem dari serangan yang diketahui serta celah keamanan baru. Firewall juga membantu menyaring lalu lintas jaringan berdasarkan kebijakan keamanan yang telah ditentukan (Stallings, 2017).

2. Terapkan enkripsi untuk data saat transit

Enkripsi memastikan bahwa data yang dikirim melalui jaringan tidak dapat dibaca oleh pihak ketiga meskipun disadap. Protokol seperti TLS (*Transport Layer Security*) digunakan untuk mengenkripsi komunikasi web, sehingga melindungi informasi sensitif seperti kata sandi dan data transaksi. Enkripsi adalah salah satu cara paling efektif untuk menjaga kerahasiaan dan integritas data (Schneier, 2020).

3. Lakukan segmentasi jaringan

Segmentasi jaringan membagi jaringan menjadi bagian-bagian kecil yang lebih terkendali sehingga jika satu segmen diserang, serangan tersebut tidak langsung menyebar ke seluruh jaringan. Hal ini meningkatkan kontrol atas lalu

lintas dan meminimalkan dampak dari potensi pelanggaran keamanan (Whitman & Mattord, 2019).

4. Batasi akses pengguna dengan prinsip *least privilege*

Prinsip *least privilege* memastikan bahwa pengguna hanya memiliki akses minimum yang diperlukan untuk menjalankan tugasnya. Ini mengurangi risiko penyalahgunaan hak akses atau eskalasi *privilege* oleh peretas. Pengaturan hak akses yang tepat adalah bagian penting dari strategi keamanan modern (Ciampa, 2020).

5. Lakukan *monitoring* dan log aktivitas secara rutin

Monitoring aktif dan pencatatan log (*logging*) memungkinkan identifikasi aktivitas mencurigakan secara real-time, serta membantu investigasi pasca insiden. Tools seperti SIEM (*Security Information and Event Management*) digunakan untuk menganalisis log dari berbagai sumber dalam jaringan (Cherdantseva et al., 2016).

6. *Backup* konfigurasi dan data secara berkala

Backup reguler memastikan bahwa data dan konfigurasi kritis dapat dipulihkan dalam kasus bencana, serangan ransomware, atau kesalahan manusia. *Backup* harus dilakukan secara berkala, dienkripsi, dan disimpan di lokasi yang aman (offsite atau cloud) untuk memaksimalkan pemulihan (Zwicky et al., 2020).

7. Latih pengguna tentang keamanan siber

Pengguna sering menjadi titik lemah dalam keamanan jaringan. Pelatihan keamanan siber secara berkala



membantu pengguna mengenali ancaman seperti *phishing*, *social engineering*, dan praktik keamanan yang baik dalam penggunaan perangkat dan aplikasi (Anderson, 2018).

8. Uji keamanan jaringan secara berkala (*penetration testing*)

Penetration testing atau uji penetrasi dilakukan untuk mengidentifikasi kerentanan dalam infrastruktur jaringan sebelum dimanfaatkan oleh penyerang. Uji ini biasanya dilakukan oleh ethical hacker menggunakan pendekatan serangan nyata untuk mengevaluasi pertahanan jaringan (O'Gorman & Camp, 2019).

9. Gunakan *multi-factor authentication* (MFA)

Multi-Factor Authentication (MFA) meningkatkan keamanan dengan memerlukan lebih dari satu metode verifikasi identitas pengguna, seperti kata sandi dan kode OTP (*One-Time Password*). MFA secara signifikan mengurangi risiko akun diretas meskipun kata sandi bocor (Buchanan, 2020).

10. Susun dan implementasikan kebijakan keamanan yang jelas

Kebijakan keamanan yang jelas memberikan panduan bagi semua pengguna tentang apa yang boleh dan tidak boleh dilakukan dalam lingkungan jaringan. Kebijakan ini mencakup penggunaan perangkat, akses data, tanggung jawab pengguna, dan prosedur respons insiden. Tanpa kebijakan formal, keamanan jaringan akan sulit diterapkan secara konsisten (Whitman & Mattord, 2019).

Daftar Pustaka

Kurose, J. F., & Ross, K. W. (2017). Computer Networking: A Top-Down Approach (7th ed.). Pearson.

Tanenbaum, A. S., & Wetherall, D. J. (2011). Computer Networks (5th ed.). Prentice Hall.

Hakim, L. (2018). Dasar-Dasar Jaringan Komputer . Jakarta: Penerbit Informatika.

Peltier, T. R. (2016). Information Security Fundamentals (2nd ed.). CRC Press.

Stallings, W. (2017). Data and Computer Communications (10th ed.). Pearson Education.

Whitman, M. E., & Mattord, H. J. (2019). Principles of Information Security (6th ed.). Cengage Learning.

Cisco. (2021). Introduction to Networks v7.0 (ITN) . Cisco Networking Academy.

OWASP Foundation. (2022). OWASP Top 10 Web Application Security Risks . Diakses dari https://owasp.org/www-project-top-ten/

National Institute of Standards and Technology (NIST). (2020). NIST Cybersecurity Framework . Diakses dari https://www.nist.gov/cyberframework

Whitman, M. E., & Mattord, H. J. (2019). Principles of Information Security (6th ed.). Cengage Learning.

Stallings, W. (2017). Network Security Essentials: Applications and Standards (5th ed.). Pearson.



Ciampa, M. (2020). CompTIA Security+ Guide to Network Security Fundamentals (6th ed.). Cengage Learning.

Tentang Penulis



Muhamad Masjun Efendi, M.Kom merupakan Alumni S2 Magister Informatika Universitas Islam Indonesia tahun 2018. Sekarang ia aktif mengajar di Universitas Teknologi Mataram pada Fakultas Teknologi Informasi dan Komunikasi. Selain itu, ia aktif pula dalam berkegiatan sebagai Dosen Koordinator Program Magang dan Studi Independen Bersertifikat (MSIB) angkatan ke-5 dan Ke-6.

Dalam kesehariannya, ia aktif sebagai penggiat media sosisal, khususnya menyuarakan tentang bermedia sosisal dengan baik dan bijak. Hingga saat ini, ia aktif dalam keanggotaan Ikatan Ahli Informatika Indonesia (IAII), Asosiasi Pendidikan Tinggi Informatika dan Komputer (APTIKOM), Asosiasi Keamanan Sistem Informasi (ISSA), dan Asosiasi Dosen Indonesia (ADI). Ia telah berkontribusi dalam penelitian dan penerbitan jurnal terakreditasi secara nasional dan internasional.



BAB 5
KEAMANAN APLIKASI DAN PERANGKAT LUNAK

Dwi Vernanda, S.T., M.Pd.

Saat ini hampir semua organisasi, baik pemerintahan maupun swasta telah memanfaatkan aplikasi dan perangkat lunak sebagai tulang punggung operasional. Sejalan dengan tingginya kebutuhan akan pemanfaatan aplikasi dan sistem informasi maka juga menimbulkan risiko baru yang dapat mengancam data dan layanan dari aplikasi dan perangkat lunak.

Keamanan aplikasi dapat diartikan sebagai langkah-langkah yang dilakukan untuk melindungi aplikasi dari ancaman, baik internal maupun eksternal termasuk serangan siber, eksploitasi kerentanan dan juga penyalahgunaan akses (Naresh and Ayyappa, 2025).

Keamanan perangkat lunak mencakup praktik, alat, dan juga pendekatan untuk memastikan bahwa perangkat lunak tidak memiliki celah yang dapat merugikan. Keamanan perangkat lunak ditujukan untuk melindungi data dari pencurian, terjadinya modifikasi data yang tidak diinginkan, dan penghapusan data penting, selain itu untuk menjaga fungsionalitas perangkat lunak tetap berjalan sesuai tujuannya serta menghindari penyusupan (Saeed *et al.*, 2025) .

A. Jenis Ancaman dan Serangan

Berikut ini berbagai jenis ancaman dan serangan yang berpotensi mengancam keamanan aplikasi dan perangkat lunak.



1. Kerentanan

Tahapan pengembangan aplikasi dan perangkat lunak menimbulkan adanya kerentanan atau celah, yaitu pada saat desain, pengodean, ataupun konfigurasi perangkat lunak.

2. Injeksi Kode

Penyerang bisa menyisipkan perintah-perintah berbahaya, salah satunya untuk menyerang basis data yaitu menyisipkan perintah SQL. Perintah SQL dapat diinput pada tampilan aplikasi yang mana jika aplikasi tidak menerapkan filter dengan baik.

3. Masalah Autentikasi dan Otorisasi

Mekanisme autentikasi atau manajmen sesi harus diatur dan diolah karena dapat memungkinkan penyerang untuk membajak sesi pengguna, menyamar sebagai pengguna asli, dan dapat masuk ke aplikasi tanpa proses login.

4. *Dependency Risk*

Saat menggunakan aplikasi adakalanya akan melibatkan komponen dari pihak ketiga, seperti pustaka/*library*, *framework,* atau modul lainnya. Hal ini juga diawali dengan penggunaan pustaka *open source* pada tahapan pengembangan dengan maksud untuk mempercepat proses, namun ternyata kebergantungan ini bisa menimbulkan berbagai ancaman.

5. Rekayasa Sosial Melalui Aplikasi

Rekayasa sosial yang dimaksud yaitu memanipulasi psikologis untuk menipu pengguna. Pada hal ini penipuan

menggunakan aplikasi lainnya, yaitu berupa antarmuka aplikasi, notifikasi palsum atau mekanisme interaksi yang dapat mengecoh pengguna.

B. Prinsip-Prinsip Desain Aman

Bagi sebagian pengembang perangkat lunak, keamanan merupakan sesi tambahan dan diatur pada saat akhir proses pengembangan. Namun, ternyata itu adalah prinsip yang keliru, desain pengamanan diperlukan dari mulai awal siklus hidup perangkat lunak. Berikut ini prinsip keamanan perangkat lunak.

1. Tahap Perencanaan

Pada saat tahapan awal yaitu desain maka perlu menganalisis segala ancaman/*threat* modeling dan merencanakan keamanan untuk meminimalisi ancaman tersebut. Perlu menambahkan persyaratan keamanan ke dalam dokumen *software requirement specification* (SRS), memilih dan menentukan tipe arsitektur dan protocol yang sudah terjamin aman, dan menggunakan pendekatan *secure software development lifecycle* (SSDLC).

2. Hak Akses Minimum

Setiap komponen dari aplikasi terutama penggua hanya diberikan hak akses minimun yang diperlukan saja. Selain itu, fungsionalitas aplikasi atau layanan hanya bisa mengakses basis data tertentu bukan seluruh server.

3. Pertahanan Berlapis

Diperlukannya pertahanan berlapis dan tidak bergantung pada satu mekanisme saja, hal ini diupayakan untuk dapat melindungi aplikasi lebih baik. Sebagai contoh yang dimaksud yaitu penggunaan *firewall* + WAF + validasi input dalam aplikasi atau *backup* sistem + deteksi intrusi + respons insiden.

4. Pengaturan *Default*

Sudah seharusnya sistem dikonfigurasi untuk memblokir akses secara default dan hanya memberikan izin apa yang secara eksplisit diperbolehkan. Sebagai contoh, akun pengguna baru tidak diberikan akses secara keseluruhan, sistem dikonfigurasi untuk tidak mengekspos direktori atau *log* secara terbuka.

5. Validasi Input dan Ouput

Validasi diperketat, semua data yang diinput, baik oleh pengguna, sistem lain, atau sumber eksternal lainnya harus divalidasi lebih ketat. Hal ini dilakukan untuk mencegah injeksi, mendeteksi kesalahan format, dan memastikan batasan panjang data yang diminta (Mothanna *et al.*, 2024).

C. Pendekatan Strategis

Tim pengembang perlu menerapkan pendekatan strategis untuk menjamin keamanan aplikasi dan perangkat lunak salah satu caranya dengan pengujian dan audit keamanan. Pengujian dan audit keamanan merupakan proses penting

untuk memastikan bahwa aplikasi dan perangkat lunak tidak mengandung celah ataupun kelemahan yang dapat dimanfaatkan oleh para penyusup. Tujuan utama pengujian dan audit yaitu mengidentifikasi kerentanan keamanan yang mungkin tidak terlihat pada saat awal pengembangan, menilai efektivitas kontrol keamanan terhadap aplikasi dan perangkat lunak, memastikan kepatuhan terhadap standar yang dipakai misalnya ISO 27001.

Pengujian aplikasi bisa dilakukan dengan beberapa cara berikut ini.

1. *Static Application Security Testing* (SAST)

Tujuan utama dilakukan SAST yaitu untuk menemukan kerentanan, seperti adanya *buffer overflow, hardcoded password,* dan kesalahan logika. SAST dilakukan pada semua tahapan pengembangan perangkat lunak, yaitu dengan menganalisis kode sumber, *bytecode*, atau binary secara statis (Aloraini *et al.*, 2019), pengujian ini dapat dibantu dengan *tools* SonarQube, Checkmarx, Fortify.

2. *Dynamic Application Security Testing* (DAST)

DAST merupakan pengujian untuk mendeteksi kerencatan yang muncul saat aplikasi telah digunakan oleh pengguna, pengujian ini untuk menemukan celah, seperti XSS, SQL *injection*, atau menemukan kesalahan saat konfigurasi otentikasi (Alidoosti, Nowroozi and Nickabadi, 2022). Pengujian DAST dapat menggunakan alat seperti OWASP ZAP, Burp Suite, dan Acunetix.

3. *Interactive Application Security Testing* (IAST)

Pengujian IAST adalah penggabungan pengujian SAST dan DAST, pengujian ini dijalankan di *runtime* untuk mendapatkan konteks yang lebih kaya. Pengujian ini dapat mengurangi kesalahan positives yaitu dengan pemahaman lebih baik terhadap logika aplikasi (Lazarov *et al.*, 2025). *Tools* yang dapat digunakan untuk pengujian IAST yaitu *Contrast Security* dan *Seeker*.

4. *Penetration Testing*

Penetrasion testing merupakan pengujian dengan menyimulasikan serangan dunia nyata yang dilakukan oleh tim internal ataupun pihak ketiga dengan tujuan untuk mengevaluasi pertahanan aplikasi atau menilai sejauh mana aplikasi dapat bertahan terhadap serangan aktual. Pada pengujian *penetration* terdapat langkah-langkah yang dimulai dari pengumpulan informasi, pemindaian dan enumerasi, eksploitasi, dan terakhir pelaporan. Pengujian ini dapat dilakukan secara berkala ataupun pada *moment* tertentu seperti sebelum dirilis atau setelah adanya perubahan besar pada aplikasi (Lazarov *et al.*, 2025).

Audit keamanan merupakan proses untuk mengevaluasi keamanan sistem dan perangkat lunak yang berdasarkan suatu kebijakan, standar, dan kerangka kerja yang ditetapkan (Aydos *et al.*, 2022). Tujuan utama adanya audit keamanan perangkat lunak yaitu mengidentifikasi

kelemahan dalam kebijakan dan proses keamanan, menjamin bahwa kontrol keamanan telah diterapkan secara efektif, dan menyediakan dokumentasi untuk keperluan audit eksternal dan kepatuhan regulasi. Alat dan kerangka audit yang sering digunakan, yaitu NIST Cybersecurity Framework, ISO/ IEC 27001 Controls, CIS Controls, dan OWASP Application Security Verification Standard (ASVS).

Komponen audit perangkat lunak mencakup beberapa hal berikut ini.

1. Dokumentasi, kebijakan keamanan, manual pengembangan, dan prosedur pengujian.
2. Kode sumber, tinjauan terhadao praktik pengembangan yang aman.
3. Konfigurasi sistem, keamanan server, basis data, dan *middleware.*
4. Log dan jejak audit, verfikasi mekanisme *logging* dan jejak aktivitas pengguna.

D. Tindak Lanjut Pengujian dan Audit Keamanan

Setelah dilakukannya pengujian dan audit maka perlu adanya tindak lanjut, hal ini bertujuan mengelola risiko, memperbaiki kerentanan, dan mencegah insiden keamanan di masa depan. Karena kalau tidak adanya tindak lanjut maka hasil pengujian dan audit yang telah dilakukan hanya akan menjadi dokumen tanpa adanya dampak nyata (Pan, Zhu and Mao, 2017).

Setelah ditemukannya kerentanan, selanjutnya adalah mengklasifikasikan tingkat keparahannya, level keparahan dapat diklasifikasikan menjadi empat.

1. Kritis, yaitu level yang paling parah ketika celah yang ada memungkinkan adanya pengambilalihan sistem, eksekusi perintah jarak jauh (RCE), atau pembobolan data.
2. Tinggi, yaitu saat celah yang ada dapat dimanfaatkan untuk mengakses data sensitif tanpa adanya otorisasi.
3. Sedang, yaitu adanya celah yang membutuhkan kondisi khusus untuk dapat mengeksploitasi.
4. Rendah, yaitu adanya celah, namun memiliki dampak terbatas atau sulit untuk memanfaatkannya.

Keamanan aplikasi dan perangkat lunak merupakan aspek yang sangat krusial pada era digital saat ini. Aplikasi dan perangkat lunak saat ini sangat dibutuhkan oleh semua tingkatan organisasi, untuk itu perlu adanya penjagaan terhadap data, sistem, dan privasi pengguna. Fungsionalitas perangkat lunak merupakan unsur terpenting, namun perlu juga dirancang dan dikembangkan prinsip-prinsip keamanan sejak awal proses pengembangan perangkat lunak hingga perangkat lunak digunakan oleh *user*.

Dengan adanya integrasi keamanan ke dalam semua tahapan siklus hidup pengembangan perangkat lunak maka dapat menghasilkan suatu perangkat lunak yang tidak hanya andal dan berkualitas, namun juga mampu bertahan

menghadapi berbagai ancaman siber yang saat ini semakin kompleks.

E. Studi Kasus

Sistem Informasi Akademik–Kebocoran Data Mahasiswa

Salah satu perguruan tinggi menggunakan sistem informasi akademik (SIAKAD), sistem informasi ini berbasis *website* yang dikembangkan oleh tim internal perguruan tinggi. SIAKAD diakses oleh mahasiswa, dosen, dan staf untuk berbagai kepentingan akademik, misalnya data pribadi, KRS, KHS, jadwal kuliah, transkrip nilai, dan lain-lain.

Insiden terungkap setelah salah satu mahasiswa mengadukan ke bagian akademik terkait data pribadi berserta transakrip nilainya tersebar di media sosial, mahasiswa tersebut memastikan tidak pernah memberikan informasi apa pun kepada siapa pun terkait data login.

Setelah dilakukan audit kemaanan oleh tim internal, diketahui bahwa terdapat beberapa kelemahan dari SIAKAD.

1. SIAKAD tidak memiliki control hak akses pengguna, sistem tidak memverifikasi apakah pengguna yang mengakses data tersebut memang memiliki hak akses.
2. URL Parameter tidak ada validasi, termasuk pada halaman transkrip data mahasiswa. Siapa pun dapat mengakses tanpa harus login dengan menggunakan parameter URL seperti “transktip.php?nim=20253004”.



3. Tim internal pengembang tidak melakukan uji keamanan sebelum sistem di *deployment*, hal ini terbukti karena tidak adanya pengujian keamanan dari semua dokumen pengembangan.

Dari insiden yang terjadi, menimbulkan beberapa dampak di antaranya hilangnya kepercayaan mahasiswa terhadap SIAKAD, tersebarnya data pribadi yang berisiko pencurian dan penyalahgunaan data, perguruan tinggi terancam sanksi dari regulator perlindungan data karena melanggar prinsip keamanan dan privasi.

Tindak lanjut dari insiden di atas sebagai berikut.

1. Mengimplementasikan control akses berbasis peran untuk memastikan hanya pemilik akun yang dapat mengakses data.
2. Menambahkan validasi dan enkripsi pada parameter URL untuk mencegah eksploitasi berbasis parameter.
3. Diadakan pelatihan keamanan untuk tim internal dan pengembang sistem agar memahami prinsip dasar keamanan/*secure coding*.
4. Menerapkan SSDLC, terutama setiap adanya perubahan pada sistem harus dilakukan pengujian keamanan terlebih dahulu.

Daftar Pustaka

Alidoosti, M., Nowroozi, A. and Nickabadi, A. (2022) 'Semantic web Racer: Dynamic security testing of the web application against race condition in the business

layer', *Expert Systems with Applications*, 195, p. 116569. Available at: https://doi.org/10.1016/J.ESWA.2022.116569.

Aloraini, B. *et al.* (2019) 'An empirical study of security warnings from static application security testing tools', *Journal of Systems and Software*, 158, p. 110427. Available at: https://doi.org/10.1016/J.JSS.2019.110427.

Aydos, M. *et al.* (2022) 'Security testing of web applications: A systematic mapping of the literature', *Journal of King Saud University - Computer and Information Sciences*, 34(9), pp. 6775–6792. Available at: https://doi.org/10.1016/J.JKSUCI.2021.09.018.

Lazarov, W. *et al.* (2025) 'Penterep: Comprehensive penetration testing with adaptable interactive checklists', *Computers & Security*, 154, p. 104399. Available at: https://doi.org/10.1016/J.COSE.2025.104399.

Mothanna, Y. *et al.* (2024) 'Adopting security practices in software development process: Security testing framework for sustainable smart cities', *Computers & Security*, 144, p. 103985. Available at: https://doi.org/10.1016/J.COSE.2024.103985.

Naresh, V.S. and Ayyappa, D. (2025) 'Enhancing security in software defined networks: Privacy-preserving intrusion detection with Homomorphic Encryption',



Journal of Information Security and Applications, 92, p. 104084. Available at: https://doi.org/10.1016/J.JISA.2025.104084.

Pan, P., Zhu, X. and Mao, X. (2017) 'Research on Security Test for Application Software Based on SPN', *Procedia Engineering*, 174, pp. 1140–1147. Available at: https://doi.org/10.1016/J.PROENG.2017.01.267.

Saeed, H. *et al.* (2025) 'Review of Techniques for Integrating Security in Software Development Lifecycle', *Computers, Materials and Continua*, 82(1), pp. 139–172. Available at: https://doi.org/10.32604/CMC.2024.057587.

Tentang Penulis



Dwi Vernanda adalah seoraang dosen dan peneliti di bidang sistem informasi dan pengembangan perangkat lunak. Saat ini aktif mengajar dan melakukan penelitian di Politeknik Negeri Subang serta terlibat dalam berbagai proyek pengembangan perangkat lunak yang aman dan inovatif. Ia juga telah menulis dan menyunting beberapa karya ilmiah terkait pengembangan sistem informasi cerdas, deteksi non-destruktif berbasis kecerdasan buatan, serta penguatan keamanan sistem informasi kampus.



BAB 6
MANAJEMEN RISIKO KEAMANAN SIBER

Zatin Niqotaini, S.Tr.Kom., M.Kom

A. Pendahuluan

Dalam era transformasi digital yang semakin pesat, keamanan siber telah menjadi salah satu aspek fundamental yang harus diperhatikan oleh setiap organisasi. Meningkatnya kebergantungan pada teknologi informasi dan komunikasi membawa konsekuensi berupa eksposur terhadap berbagai ancaman siber yang dapat menimbulkan kerugian signifikan bagi organisasi. Oleh karena itu, implementasi manajemen risiko keamanan siber yang komprehensif dan terstruktur menjadi kebutuhan yang tidak dapat ditawar lagi.

Manajemen risiko keamanan siber merupakan proses sistematis untuk mengidentifikasi, menganalisis, mengevaluasi, dan mengelola risiko-risiko yang berkaitan dengan keamanan informasi dan sistem teknologi dalam suatu organisasi. Pendekatan ini tidak hanya berfokus pada aspek teknis semata, namun juga mengintegrasikan faktor manusia, proses bisnis, dan tata kelola organisasi untuk menciptakan pertahanan berlapis yang efektif terhadap ancaman siber.

Pentingnya manajemen risiko keamanan siber semakin terasa dengan meningkatnya frekuensi dan kompleksitas serangan siber yang menargetkan berbagai sektor industri. Organisasi yang tidak memiliki strategi manajemen risiko yang memadai akan menghadapi potensi



kerugian finansial, reputasi, dan operasional yang dapat mengancam keberlangsungan bisnis mereka.

A. Konsep Dasar Manajemen Risiko Keamanan Siber

1. Definisi dan Ruang Lingkup

Manajemen risiko keamanan siber didefinisikan sebagai pendekatan holistik untuk mengidentifikasi, mengukur, memprioritaskan, dan mengelola risiko-risiko yang dapat mempengaruhi kerahasiaan, integritas, dan ketersediaan informasi serta sistem teknologi informasi dalam suatu organisasi. Ruang lingkup manajemen risiko keamanan siber mencakup seluruh aset digital, infrastruktur teknologi, proses bisnis, dan sumber daya manusia yang terlibat dalam ekosistem teknologi informasi organisasi.

Dalam konteks yang lebih luas, manajemen risiko keamanan siber tidak hanya berkaitan dengan perlindungan terhadap serangan dari pihak eksternal, tetapi juga mencakup pengelolaan risiko internal, seperti kesalahan manusia, kegagalan sistem, dan kelemahan dalam proses operasional. Pendekatan ini memerlukan pemahaman mendalam tentang lanskap ancaman yang terus berkembang, vulnerabilitas sistem yang ada, serta dampak potensial dari berbagai skenario insiden keamanan.

2. Prinsip-Prinsip Fundamental

Implementasi manajemen risiko keamanan siber yang efektif didasarkan pada beberapa prinsip fundamental yang

harus dipahami dan diterapkan secara konsisten. Prinsip pertama adalah pendekatan berbasis risiko yang mengutamakan alokasi sumber daya pada area dengan risiko tertinggi. Prinsip kedua adalah integrasi yang menyeluruh, dalam hal ini manajemen risiko keamanan siber harus terintegrasi dengan strategi bisnis dan tata kelola organisasi secara keseluruhan.

Prinsip ketiga adalah peningkatan berkelanjutan yang menekankan pada perlunya evaluasi dan penyesuaian strategi manajemen risiko secara berkala untuk mengantisipasi perkembangan ancaman dan perubahan lingkungan bisnis. Prinsip keempat adalah keterlibatan seluruh *stakeholder* yang mengakui bahwa keamanan siber merupakan tanggung jawab bersama yang melibatkan seluruh lapisan organisasi mulai dari manajemen puncak hingga karyawan operasional.

B. Framework dan Metodologi Manajemen Risiko

1. Framework Internasional

Implementasi manajemen risiko keamanan siber dapat menggunakan berbagai framework internasional yang telah terbukti efektif dan diakui secara global. Framework NIST Cybersecurity Framework menyediakan pendekatan komprehensif yang terdiri dari lima fungsi utama yaitu Identify, Protect, Detect, Respond, dan Recover. Framework

ini memberikan struktur yang fleksibel dan dapat disesuaikan dengan kebutuhan spesifik organisasi.

ISO 27005 merupakan standar internasional yang memberikan panduan detail untuk manajemen risiko keamanan informasi. Standar ini menyediakan metodologi sistematis untuk melakukan assessment risiko, treatment risiko, dan monitoring berkelanjutan. Selain itu, framework COBIT juga dapat digunakan untuk mengintegrasikan manajemen risiko keamanan siber dengan tata kelola teknologi informasi yang lebih luas.

2. Metodologi *Risk Assessment*

Metodologi risk assessment merupakan komponen kritis dalam manajemen risiko keamanan siber yang melibatkan serangkaian aktivitas sistematis untuk mengidentifikasi dan mengevaluasi risiko. Tahap pertama adalah identifikasi aset, di mana organisasi perlu melakukan inventarisasi lengkap terhadap seluruh aset digital termasuk hardware, software, data, dan layanan yang mendukung operasional bisnis.

Tahap kedua adalah identifikasi ancaman dan vulnerabilitas yang dapat mempengaruhi aset-aset tersebut. Ancaman dapat bersifat internal maupun eksternal, sementara vulnerabilitas mencakup kelemahan teknis, prosedural, maupun manusia yang dapat dieksploitasi oleh pihak yang tidak berwenang. Tahap ketiga adalah analisis risiko yang melibatkan penilaian likelihood dan impact dari setiap skenario risiko yang telah diidentifikasi.

C. Proses Manajemen Risiko Keamanan Siber

1. Tahap Identifikasi Risiko

Proses identifikasi risiko merupakan langkah fundamental yang menentukan kualitas keseluruhan program manajemen risiko keamanan siber. Tahap ini melibatkan pengumpulan informasi komprehensif tentang aset organisasi, ancaman yang relevan, dan vulnerabilitas yang ada. Metode yang dapat digunakan dalam tahap ini meliputi *brainstorming* dengan *stakeholder* kunci, *review* dokumentasi sistem, analisis log keamanan, dan assessment teknis terhadap infrastruktur teknologi.

Identifikasi aset harus mencakup klasifikasi berdasarkan tingkat kritikalitas dan sensitivitas terhadap operasional bisnis. Data sensitif seperti informasi pribadi pelanggan, rahasia dagang, dan data finansial memerlukan perhatian khusus dalam proses identifikasi risiko. Selain itu, dependensi antarsistem dan proses bisnis juga perlu dipetakan untuk memahami dampak cascading yang mungkin terjadi akibat gangguan pada satu komponen sistem.

2. Tahap Analisis dan Evaluasi Risiko

Setelah risiko-risiko utama berhasil diidentifikasi, langkah selanjutnya adalah melakukan analisis mendalam untuk menentukan tingkat risiko masing-masing ancaman. Analisis risiko dapat dilakukan menggunakan pendekatan

kualitatif, kuantitatif, atau kombinasi keduanya. Pendekatan kualitatif menggunakan skala deskriptif, seperti rendah, sedang, dan tinggi untuk menilai *likelihood* dan *impact*, sementara pendekatan kuantitatif menggunakan nilai numerik dan perhitungan statistik.

Evaluasi risiko melibatkan perbandingan tingkat risiko yang telah dianalisis dengan kriteria risiko yang telah ditetapkan organisasi. Kriteria ini harus mencerminkan *risk appetite* dan *risk tolerance* organisasi yang telah ditetapkan oleh manajemen puncak. Hasil evaluasi akan menentukan prioritas penanganan risiko dan alokasi sumber daya yang diperlukan untuk implementasi kontrol keamanan yang efektif.

3. Tahap *Treatment* Risiko

Treatment risiko merupakan tahap implementasi strategi pengelolaan risiko berdasarkan hasil analisis dan evaluasi yang telah dilakukan. Terdapat empat strategi utama dalam *treatment* risiko, yaitu *risk acceptance*, *risk mitigation*, *risk transfer*, dan *risk avoidance*. Pemilihan strategi yang tepat harus mempertimbangkan *cost-benefit analysis*, tingkat risiko, dan kapabilitas organisasi dalam mengimplementasikan kontrol yang diperlukan.

Risk mitigation merupakan strategi yang paling umum digunakan dan melibatkan implementasi kontrol keamanan untuk mengurangi *likelihood* atau *impact* dari risiko yang diidentifikasi. Kontrol dapat berupa kontrol preventif,

detektif, atau korektif yang diimplementasikan pada level teknis, administratif maupun fisik. *Risk transfer* dapat dilakukan melalui asuransi siber atau *outsourcing* layanan keamanan kepada pihak ketiga yang memiliki *expertise* dan kapabilitas yang lebih baik.

D. Implementasi Kontrol Keamanan

1. Kontrol Teknis

Implementasi kontrol teknis merupakan fondasi perlindungan berlapis dalam manajemen risiko keamanan siber. Kontrol ini mencakup *firewall*, *intrusion detection system*, *antivirus*, *encryption, access control system*, dan berbagai solusi keamanan lainnya. Pemilihan dan konfigurasi kontrol teknis harus disesuaikan dengan profil risiko organisasi dan mengikuti *best practice* yang telah terbukti efektif.

Network security controls berperan penting dalam melindungi perimeter jaringan organisasi dari ancaman eksternal. Implementasi *network segmentation* dapat membatasi penyebaran serangan lateral dalam jaringan internal, sementara *monitoring traffic* secara *real-time* memungkinkan deteksi dini terhadap aktivitas mencurigakan. *Endpoint protection controls* juga sangat kritis mengingat *endpoint* merupakan target utama serangan siber modern.

2. Kontrol Administratif

Kontrol administratif meliputi kebijakan, prosedur, standar, dan *guidelines* yang mengatur perilaku dan aktivitas terkait keamanan informasi dalam organisasi. *Security awareness training* merupakan salah satu kontrol administratif yang paling penting mengingat faktor manusia sering menjadi *weakest link* dalam rantai keamanan siber. Program *training* harus disesuaikan dengan peran dan tanggung jawab masing-masing karyawan serta dilakukan secara berkala untuk memastikan efektivitasnya.

Incident response plan merupakan kontrol administratif kritis yang menentukan kemampuan organisasi dalam merespons dan memulihkan diri dari insiden keamanan. *Plan* ini harus mencakup prosedur komunikasi, eskalasi, *containment*, *eradication*, dan *recovery* yang jelas dan dapat diimplementasikan dengan cepat saat terjadi insiden. *Regular testing* dan *updating incident response plan* sangat penting untuk memastikan kesiapan organisasi menghadapi berbagai skenario insiden.

3. Kontrol Fisik

Meskipun sering diabaikan dalam era digital, kontrol fisik tetap memiliki peran penting dalam keseluruhan strategi keamanan siber. Proteksi fisik terhadap data center, *server room*, dan *workstation* dapat mencegah akses tidak sah yang dapat mengompromikan keamanan sistem secara keseluruhan. *Access control* fisik menggunakan *card reader*,

biometric scanner, atau kombinasi keduanya dapat memberikan lapisan perlindungan tambahan.

Environmental controls, seperti sistem pemadam kebakaran, kontrol suhu dan kelembaban, serta *uninterruptible power supply* berperan dalam memastikan ketersediaan sistem teknologi informasi. *Surveillance system* dan *security guard* dapat memberikan *monitoring* dan *response capability* terhadap ancaman fisik yang mungkin terjadi terhadap aset teknologi organisasi.

E. *Monitoring* dan *Review*

1. *Continuous Monitoring*

Implementasi *continuous monitoring* merupakan aspek kritis dalam memastikan efektivitas program manajemen risiko keamanan siber. Sistem monitoring harus mampu memberikan *visibility real-time* terhadap status keamanan organisasi dan memberikan *early warning* terhadap potensi ancaman. *Security Information and Event Management* (SIEM) *system* dapat mengintegrasikan data dari berbagai sumber untuk memberikan analisis komprehensif terhadap aktivitas keamanan.

Key Performance Indicators (KPI) dan *Key Risk Indicators* (KRI) harus ditetapkan untuk mengukur efektivitas program manajemen risiko secara kuantitatif. *Metrics* yang digunakan harus relevan dengan tujuan bisnis organisasi dan dapat memberikan insight yang *actionable*



bagi pengambilan keputusan manajemen. *Dashboard* dan *reporting system* yang efektif dapat memfasilitasi komunikasi status keamanan kepada berbagai *stakeholder*.

2. *Regular Assessment* dan *Audit*

Pelaksanaan *regular assessment* dan *audit* merupakan mekanisme *quality assurance* yang memastikan program manajemen risiko keamanan siber berjalan sesuai dengan standar dan *requirement* yang telah ditetapkan. *Vulnerability assessment* dan *penetration testing* harus dilakukan secara berkala untuk mengidentifikasi kelemahan baru yang mungkin muncul seiring dengan perubahan teknologi dan *threat landscape*.

Internal audit dapat memberikan *assurance independent* terhadap efektivitas kontrol keamanan yang telah diimplementasikan. *Audit findings* harus ditindaklanjuti dengan *corrective action plan* yang jelas dan *measurable*. *External audit* oleh *third party* dapat memberikan perspektif objektif dan benchmark terhadap *industry best practice.*

F. *Crisis Management* dan *Business Continuity*

1. *Incident Response Management*

Kemampuan organisasi dalam merespons insiden keamanan siber secara efektif menentukan seberapa besar dampak yang akan dialami akibat serangan atau gangguan sistem. *Incident response team* harus memiliki kompetensi teknis

dan non-teknis yang memadai untuk menangani berbagai jenis insiden. Struktur tim harus jelas dengan pembagian peran dan tanggung jawab yang spesifik untuk setiap anggota.

Communication strategy selama krisis sangat penting untuk mempertahankan kepercayaan *stakeholder* dan meminimalkan dampak reputasi. Komunikasi harus transparan, namun tetap mempertimbangkan aspek legal dan *regulatory compliance*. Koordinasi dengan pihak eksternal, seperti *law enforcement*, *regulator*, dan vendor teknologi mungkin diperlukan tergantung pada *nature* dan *scope insiden* yang terjadi.

2. *Business Continuity Planning*

Business continuity planning merupakan *extension* dari manajemen risiko keamanan siber yang fokus pada pemeliharaan operasional bisnis kritikalitas selama dan setelah insiden keamanan. *Business impact analysis* harus dilakukan untuk mengidentifikasi proses bisnis yang paling kritis dan menentukan *recovery time objective* serta *recovery point objective* yang dapat diterima organisasi.

Disaster recovery site dan *backup systems* merupakan komponen teknis penting dalam *business continuity planning*. *Testing* dan *maintenance regular* terhadap *disaster recovery capability* sangat penting untuk memastikan sistem dapat berfungsi dengan baik saat dibutuhkan. Selain itu, *alternative business process* dan *workaround procedures* juga

perlu disiapkan untuk mengantisipasi skenario di mana sistem teknologi tidak dapat dipulihkan dalam waktu yang diharapkan.

G. Tren dan Tantangan Masa Depan

1. *Emerging Threats*

Lanskap ancaman keamanan siber terus berkembang dengan munculnya teknologi baru dan perubahan modus operandi pelaku kejahatan siber. *Artificial Intelligence* dan *Machine Learning* mulai digunakan oleh attacker untuk mengotomatisasi dan meningkatkan efektivitas serangan. *Deepfake technology* dapat digunakan untuk *social engineering attack* yang lebih *sophisticated* dan sulit dideteksi.

Internet of Things (IoT) dan *Industrial IoT* membawa kompleksitas baru dalam manajemen risiko keamanan siber dengan memperluas *attack surface* organisasi. *Quantum computing* di masa depan dapat mengancam efektivitas algoritma enkripsi yang saat ini digunakan sehingga organisasi perlu mempersiapkan transisi ke *quantum-resistant cryptography*.

2. *Regulatory Compliance*

Regulasi keamanan siber semakin ketat di berbagai yurisdiksi dengan penerapan sanksi yang signifikan bagi organisasi yang tidak *comply. General Data Protection Regulation* (GDPR) di Eropa telah menjadi *benchmark* untuk

regulasi *privacy* dan *data protection* di seluruh dunia. Indonesia juga telah mengeluarkan Undang-Undang Perlindungan Data Pribadi yang menuntut organisasi untuk mengimplementasikan praktik keamanan data yang lebih baik.

Compliance management harus diintegrasikan dengan program manajemen risiko keamanan siber untuk memastikan organisasi memenuhi seluruh *requirement* regulasi yang berlaku. *Regular compliance assessment* dan *documentation* merupakan aspek penting yang harus dipertimbangkan dalam desain dan implementasi kontrol keamanan.

Manajemen risiko keamanan siber merupakan *discipline* yang kompleks dan multifaset yang memerlukan pendekatan holistik dan terintegrasi. Keberhasilan implementasi program manajemen risiko tidak hanya bergantung pada teknologi yang digunakan, tetapi juga pada komitmen manajemen, keterlibatan seluruh *stakeholder*, dan kemampuan organisasi dalam beradaptasi dengan perubahan lingkungan ancaman.

Organisasi yang mampu mengimplementasikan manajemen risiko keamanan siber secara efektif akan memiliki *competitive advantage* dalam era digital yang semakin kompetitif. Investasi dalam program manajemen risiko keamanan siber harus dipandang sebagai *strategic investment* yang dapat memberikan return dalam bentuk



perlindungan aset, reputasi, dan keberlangsungan bisnis jangka panjang.

Perkembangan teknologi dan evolusi *threat landscape* menuntut organisasi untuk terus belajar dan menyesuaikan strategi manajemen risiko mereka. *Collaboration* dan information sharing dengan industri peers, *government agencies*, dan *security community* menjadi semakin penting untuk menghadapi ancaman yang semakin *sophisticated* dan c*oordinated*.

Daftar Pustaka

Zatin Niqotaini, Indah Purnamasari, Cholid Fauzi, Yoga Sahria, Dartono, Dian Nursantika I, Afriliana, Cahyo Prihantoro, Petrus Christo, Andi Wijaya, Anang Anggono Lutfi M, Robihul Mufid, Arif Rizki Marsa YW. Rekayasa Perangkat Lunak [Internet]. Mardiani E, editor. Yogyakarta: PT Penamuda Media; 2023. 143 p. Available from: www.penamuda.com

Rachmat Destriana M.Kom., Rizki Suwanda, S.T., M.Kom., Ade Oktarino, S.Kom., M.S.I., Dr. (H.C) Zaid Romegar Mair, S.T., M.Cs., Zatin Niqotaini, S.Tr.Kom., M.Kom., Fransiskus Mario Hartono Tjiptabudi, S.Kom., M.M., Farid, M.Kom., Nur Oktavin Idris, M.Eng., P. Strategi Sistem Informasi [Internet]. Yuniana Cahyaningrum, S.Kom. MK, editor. 2024. Yogyakarta: PT Penamuda Media; 2024. 220 p. Available from: https://penamuda.com/product/strategi-sistem-informasi-2/

Arif Rizki Marsa, S.Kom., M.Kom., Rosda Syelly, S.Kom., M.Kom., Riska Amelia, Ajang Sopandi, S.Kom., M.Kom, Suharsono, S.Kom. M.Kom., Rifka Dwi Amalia, S.Pd., M.Kom., Ranti Irsa, Widiyawati, S.Kom , M.Kom., Nurhuda Maulana, Nindy Irzavika, Musthofa Galih MP. KONSEP SISTEM INFORMASI [Internet]. Cetakan Pe. Dr. Dwi Prasetyo, Dipl.Inf, S.Kom MS, editor. Yogyakarta: PT Penerbit Penamuda Media; 2023. 164

p. Available from: https://penamuda.com/product/konsep-sistem-informasi/

Sri Tria Siska, S.Kom, M.Kom., Diwahana Mutiara Candrasari Hermanto, S. Kom, M.Kom., Andri Nofiar. Am, S.Kom., M.Kom., Inggrid Yanuar Risca Pratiwi, S.S.T., M.Tr.T., Rima Maulini, M. Kom., Rosalina Yani Widiastuti, S.Kom., M.M.SI., Nur Fitrianingsih, S.Ko MK. Pengantar Teknologi Informasi [Internet]. Anita, S.Kom. MK, editor. PT Penamuda Media. Yogyakarta: PT Penamuda Media; 2023. 157 p. Available from: https://penamuda.com/product/pengantar-teknologi-informasi/

Tentang Penulis



Zatin Niqotaini, S.Tr.Kom., M.Kom, lahir pada 10 Februari 1993 di Brebes, Provinsi Jawa Tengah. Penulis menyelesaikan pendidikan D4 Teknik Informatika di Politeknik Pos Indonesia Bandung dan S2 Sistem Informasi di STMIK Likmi Bandung. Penulis memulai karier di dunia pendidikan pada tahun 2016. Saat ini penulis merupakan Dosen Pegawai Negeri Sipil di Fakultas Ilmu Komputer Universitas Pembangunan Nasional Veteran Jakarta dan *homebase*-nya di Program Studi S1 Sistem Informasi. Bidang peminatan penulis berkaitan dengan Sistem Informasi Bisnis.



BAB 7
PERLINDUNGAN DATA PRIBADI DAN PRIVASI

Vina Lusiana, M.Si

A. Mengapa Perlindungan Data Pribadi Menjadi Pilar Penting di Era Digital?

Di tengah derasnya arus transformasi digital yang melanda seluruh aspek kehidupan, perlindungan data pribadi telah muncul sebagai isu kritis yang menentukan masa depan kemanusiaan. Setiap detik, miliaran data pribadi mengalir melalui jaringan digital global, mulai dari transaksi keuangan, catatan kesehatan hingga jejak aktivitas di media sosial. Fenomena ini bukan sekadar evolusi teknologi, melainkan perubahan paradigma dalam memandang hak privasi dan keamanan identitas individu di ruang maya. Kasus-kasus besar seperti kebocoran data 87 juta pengguna Facebook ke Cambridge Analytica pada 2018 membuktikan bagaimana data pribadi dapat menjadi senjata ampuh yang memengaruhi, bahkan hasil pemilihan umum suatu negara.

Perlindungan data pribadi di Indonesia telah memasuki babak baru dengan disahkannya Undang-Undang Nomor 27 Tahun 2022 tentang Perlindungan Data Pribadi (UU PDP). Regulasi ini tidak hanya sekadar memenuhi kebutuhan hukum, tetapi menjadi respons atas meningkatnya kasus penyalahgunaan data yang mencapai 143,8 juta serangan sepanjang 2022 menurut Badan Siber dan Sandi Negara. Buku ini hadir untuk menjawab tiga pertanyaan mendasar, yaitu bagaimana konsep perlindungan data pribadi berkembang secara global dan lokal? Tantangan apa yang dihadapi dalam

implementasinya? Solusi seperti apa yang dapat ditawarkan untuk membangun ekosistem digital yang lebih aman dan bertanggung jawab?

Struktur bab dalam buku ini sengaja dirancang untuk memberikan pemahaman komprehensif, dimulai dari pembahasan konseptual tentang hak privasi di awal sub hingga penyajian panduan praktis perlindungan data bagi individu dan organisasi, dan juga mengajak pembaca merenungkan dimensi etika serta masa depan privasi digital. Melalui pendekatan multidisiplin yang menggabungkan perspektif hukum, teknologi, dan sosial, bab ini bertujuan tidak hanya untuk memberi pengetahuan, tetapi juga membangun kesadaran kritis bahwa perlindungan data pribadi adalah tanggung jawab bersama dalam membangun peradaban digital yang berkelanjutan dan manusiawi.

B. Konsep Dasar Data Pribadi dan Privasi

Data pribadi merupakan segala informasi yang terkait dengan identitas individu, baik secara langsung maupun tidak langsung, seperti nama, alamat, nomor identitas, atau bahkan data digital seperti alamat IP dan riwayat browsing. Dalam konteks hukum, definisi ini diatur secara berbeda di berbagai negara, tetapi pada intinya bertujuan melindungi hak individu atas informasi yang melekat pada dirinya. Misalnya, Uni Eropa melalui GDPR menekankan bahwa data pribadi mencakup segala hal yang dapat mengidentifikasi

seseorang, sementara Indonesia dalam UU PDP mengklasifikasikannya meliputi data elektronik maupun non-elektronik. Perlindungan data pribadi bukan hanya kewajiban hukum, tetapi juga bagian dari penghormatan terhadap hak asasi manusia, sebagaimana diakui dalam instrumen global seperti *Universal Declaration of Human Rights.*

Privasi dan keamanan data sering kali disalahartikan sebagai konsep yang sama, padahal keduanya memiliki peran yang berbeda. Privasi merujuk pada hak individu untuk mengontrol bagaimana informasi pribadinya dikumpulkan, digunakan, dan dibagikan, sementara keamanan data lebih berkaitan dengan langkah teknis untuk melindungi informasi tersebut dari ancaman seperti peretasan atau kebocoran. Contohnya, ketika sebuah aplikasi meminta izin mengakses lokasi pengguna, hal ini menyangkut persoalan privasi, tetapi jika data lokasi tersebut disimpan tanpa enkripsi, ini menjadi masalah keamanan data. Tantangan di era digital adalah menjaga keseimbangan antara keduanya, dalam hal ini kemudahan teknologi sering kali berhadapan dengan risiko pelanggaran privasi.

Data pribadi dapat dikategorikan menjadi data umum dan data sensitif, masing-masing memerlukan tingkat perlindungan yang berbeda. Data umum seperti nama atau alamat mungkin tidak terlalu berisiko jika terpapar, tetapi

data sensitif seperti informasi kesehatan, rekam jejak keuangan, atau keyakinan agama dapat menimbulkan dampak serius jika disalahgunakan. Regulasi seperti GDPR dan UU PDP memberikan perlindungan ekstra terhadap data sensitif, termasuk persyaratan persetujuan eksplisit dari pemilik data sebelum diproses. Namun, di tengah perkembangan teknologi yang pesat, muncul tantangan baru seperti paradoks privasi di mana masyarakat mengkhawatirkan pelanggaran privasi, tetapi sering mengabaikannya demi kenyamanan dan ambigu.

C. Tantangan dan Ancaman terhadap Privasi di Era Digital

Perkembangan teknologi digital telah membawa kemudahan dalam kehidupan sehari-hari, tetapi sekaligus menciptakan kerentanan baru terhadap privasi dan keamanan data pribadi. Ancaman seperti pelanggaran data (*data breach*), pengumpulan informasi tanpa izin (*data harvesting*), dan manipulasi psikologis melalui *social engineering* semakin marak terjadi. Kasus-kasus besar seperti kebocoran data Facebook-Cambridge Analytica dan serangan *ransomware* terhadap rumah sakit menunjukkan betapa rapuhnya sistem perlindungan data yang ada. Teknologi seperti *Artificial Intelligence* (AI) dan *Internet of Things* (IoT) memperumit situasi ini karena kemampuan mereka untuk mengumpulkan, menganalisis, dan

memanfaatkan data pribadi dalam skala besar sering kali melampaui regulasi dan kesadaran pengguna.

Selain ancaman eksternal, perilaku pengguna juga menjadi faktor risiko utama dalam pelanggaran privasi. Banyak orang tidak menyadari bahwa informasi yang mereka bagikan secara sukarela di media sosial atau platform digital dapat disalahgunakan oleh pihak yang tidak bertanggung jawab. Praktik seperti *phishing*—di mana penipu menyamar sebagai institusi resmi untuk mencuri data sensitif—semakin canggih dan sulit dikenali. Di sisi lain, perusahaan sering kali mengumpulkan data pengguna secara berlebihan (*overcollection*) dengan alasan personalisasi layanan, tetapi tanpa transparansi yang memadai tentang bagaimana data tersebut disimpan dan digunakan. Hal ini menciptakan ketidakseimbangan kekuatan antara individu dan entitas bisnis, dalam hal ini pengguna hanya memiliki sedikit kendali atas data mereka sendiri.

Masa depan privasi di era digital akan semakin kompleks seiring dengan munculnya teknologi baru seperti *quantum computing* dan *augmented reality* yang berpotensi mengikis batas-batas privasi lebih jauh lagi. Tantangan terbesar adalah menciptakan kerangka regulasi yang mampu mengimbangi kecepatan inovasi teknologi, sambil tetap menjunjung tinggi hak-hak dasar individu. Edukasi tentang literasi digital dan kesadaran privasi harus



menjadi prioritas, baik bagi pengguna biasa maupun pelaku industri. Tanpa upaya kolektif untuk memperkuat perlindungan data, masyarakat akan terus menghadapi risiko kehilangan kendali atas informasi pribadi, di mana itu sebuah aset yang semakin berharga di dunia yang semakin terhubung.

D. Regulasi Perlindungan Data Pribadi di Berbagai Negara

Dunia telah menyadari pentingnya perlindungan data pribadi sehingga banyak negara mengembangkan kerangka hukum khusus untuk mengaturnya. Uni Eropa mempelopori dengan *General Data Protection Regulation* (GDPR) yang diterapkan sejak tahun 2018, dianggap sebagai standar emas perlindungan data global. Regulasi ini menetapkan prinsip-prinsip ketat seperti hak untuk dilupakan *(right to be forgotten*), portabilitas data, dan kewajiban pelaporan pelanggaran data dalam 72 jam. Sementara itu, Amerika Serikat mengambil pendekatan sektoral dengan *California Consumer Privacy Act* (CCPA) sebagai regulasi negara bagian paling komprehensif yang memberikan hak kontrol data kepada konsumen.

Di Asia, perkembangan regulasi juga menunjukkan kemajuan signifikan. Indonesia baru saja mengesahkan Undang-Undang Perlindungan Data Pribadi (UU PDP) No. 27 Tahun 2022 setelah melalui proses panjang. UU ini mengatur

tentang kewajiban pengendali data, hak subjek data, dan sanksi bagi pelanggar. Negara lain seperti Singapura dengan *Personal Data Protection Act* (PDPA) dan Jepang dengan APPI (*Amended Personal Information Protection Act*) juga telah memiliki sistem perlindungan data yang matang. Namun, implementasi di berbagai negara menghadapi tantangan unik, terutama dalam penegakan hukum dan harmonisasi dengan sektor digital yang berkembang pesat.

Perbandingan berbagai regulasi global menunjukkan adanya kebutuhan akan standar internasional yang dapat memfasilitasi arus data lintas batas negara sambil tetap menjaga hak privasi individu. Inisiatif seperti *Privacy Shield* antara AS dan UE (yang kemudian dibatalkan) serta kerja sama ASEAN *Framework on Personal Data Protection* mencerminkan upaya menciptakan interoperabilitas sistem perlindungan data. Tantangan ke depan adalah bagaimana menciptakan keseimbangan antara perlindungan privasi yang ketat dengan kebutuhan inovasi digital dan pertumbuhan ekonomi.

E. Praktik Terbaik untuk Melindungi Data Pribadi

Perlindungan data pribadi memerlukan kolaborasi antara individu, organisasi, dan pemerintah. Bagi individu, langkah-langkah dasar seperti menggunakan password yang kuat, mengaktifkan autentikasi dua faktor (2FA), serta berhati-hati dalam membagikan informasi pribadi di media sosial



dapat secara signifikan mengurangi risiko pelanggaran data. Pemahaman tentang teknik *phishing* dan *social engineering* juga penting untuk menghindari jebakan pencurian data. Tools seperti *password manager*, VPN, dan enkripsi *end-to-end* untuk komunikasi digital semakin menjadi kebutuhan dasar di era digital ini.

Di tingkat organisasi, penerapan prinsip *privacy by design* dan *privacy by default* menjadi kunci dalam membangun sistem yang aman. Perusahaan perlu melakukan pemetaan alur data (*data mapping*), menerapkan klasifikasi data, serta membatasi akses berdasarkan prinsip *least privilege*. Pelatihan kesadaran keamanan bagi karyawan dan prosedur tanggap darurat untuk pelanggaran data harus menjadi bagian dari budaya organisasi. Sertifikasi seperti ISO 27001 untuk manajemen keamanan informasi dan persiapan sertifikasi UU PDP di Indonesia dapat membantu organisasi mencapai standar perlindungan yang memadai.

Pemerintah memiliki peran penting dalam menciptakan ekosistem perlindungan data yang sehat melalui regulasi yang jelas, pengawasan efektif, dan kerja sama internasional. Pembentukan otoritas perlindungan data yang independen seperti diamanatkan UU PDP menjadi langkah krusial. Di sisi lain, edukasi publik tentang literasi digital dan hak-hak atas data pribadi perlu digencarkan melalui berbagai saluran. Kolaborasi tripartit antara pemerintah, sektor swasta, dan masyarakat sipil akan

menentukan keberhasilan perlindungan data pribadi di Indonesia dan global.

F. Etika dan Masa Depan Perlindungan Privasi

Perdebatan tentang privasi di era digital telah melampaui aspek hukum dan teknis, masuk ke ranah etika filosofis yang mendalam. Konsep privasi sebagai hak asasi manusia bertabrakan dengan logika ekonomi digital yang mengandalkan data sebagai komoditas baru. Teknologi seperti *facial recognition*, AI prediktif, dan *big data analytics* menantang batas-batas etis dalam pengumpulan dan penggunaan data pribadi. Kasus-kasus seperti eksperimen psikologis Facebook terhadap pengguna tanpa persetujuan atau penggunaan data kesehatan untuk komersialisasi memicu pertanyaan mendasar tentang sejauh mana teknologi boleh mengintervensi privasi individu.

Masa depan perlindungan privasi akan diwarnai oleh perkembangan teknologi seperti komputasi kuantum yang dapat mematahkan sistem enkripsi saat ini, serta metaverse yang mengaburkan batas antara dunia fisik dan digital. Di sisi lain, munculnya konsep seperti *federated learning* dan *differential privacy* menawarkan solusi teknis untuk melindungi privasi sambil tetap memungkinkan analisis data. Perkembangan regulasi juga diprediksi akan semakin mengglobal dengan munculnya standar-standar baru yang mungkin dipelopori oleh blok ekonomi besar, seperti UE, AS, dan China.



Tantangan terbesar ke depan adalah menciptakan keseimbangan antara inovasi teknologi dan perlindungan hak dasar manusia. Prinsip-prinsip seperti data minimalisasi, *purpose limitation*, dan akuntabilitas algoritmik perlu menjadi fondasi pengembangan teknologi baru. Pendidikan etika digital harus dimasukkan dalam kurikulum pendidikan untuk membangun kesadaran sejak dini. Pada akhirnya, perlindungan privasi di era digital bukan hanya tentang regulasi atau teknologi, tetapi tentang membangun tatanan sosial baru yang menghargai martabat manusia di tengah percepatan transformasi digital yang tak terhindarkan.

G. Menjaga Martabat Manusia di Era Digital

Perjalanan panjang pembahasan tentang perlindungan data pribadi dan privasi dalam buku ini mengantarkan kita pada satu kesadaran mendasar bahwa data pribadi bukan sekadar kumpulan informasi, melainkan representasi digital dari identitas dan martabat manusia. Di era ketika data menjadi minyak baru yang menggerakkan ekonomi digital, perlindungan terhadapnya telah berubah dari sekadar kebutuhan teknis menjadi imperatif moral. Kasus-kasus pelanggaran data yang terus bermunculan membuktikan bahwa tanpa sistem perlindungan yang kuat, kemajuan teknologi justru berpotensi menjadi alat eksploitasi yang mengikis hak-hak dasar manusia.

Tantangan utama yang kita hadapi adalah menciptakan keseimbangan dinamis antara inovasi digital dan perlindungan privasi. Regulasi seperti GDPR dan UU PDP memberikan fondasi hukum yang penting, namun implementasinya memerlukan komitmen kolektif dari semua pemangku kepentingan. Individu perlu meningkatkan literasi digital dan kesadaran privasi, organisasi harus mengadopsi praktik terbaik perlindungan data, sementara pemerintah perlu memperkuat kerangka hukum dan penegakannya. Teknologi sendiri bukanlah musuh privasi, justru dengan pendekatan seperti *privacy by design*, teknologi dapat menjadi solusi perlindungan yang paling efektif.

Masa depan perlindungan data pribadi akan terus berkembang seiring kemajuan teknologi. Namun, prinsip dasarnya tetap tidak berubah bahwa setiap individu berhak atas kontrol terhadap data pribadinya sebagai bagian dari hak asasi manusia. Buku ini diharapkan dapat menjadi pemantik kesadaran dan panduan praktis bagi pembaca untuk lebih kritis dan proaktif dalam melindungi privasi di dunia digital. Pada akhirnya, perlindungan data pribadi yang efektif hanya mungkin terwujud ketika kita semua–sebagai individu, pelaku bisnis, dan masyarakat–memutuskan untuk menjadikannya sebagai nilai bersama yang patut diperjuangkan.



Daftar Pustaka

Sihombing, J. O. (2022). Perlindungan Data Pribadi di Indonesia: Teori dan Praktik Setelah Pengesahan UU No. 27 Tahun 2022. Jakarta: Gramedia Pustaka Utama.

Rahardjo, B. (2020). Keamanan Siber: Konsep, Strategi, dan Implementasi di Indonesia. Bandung: Informatika.

Yani, L. M. (2021). Perlindungan Privasi dan Data Pribadi di Era Digital. Jakarta: Kencana Prenada Media Group.

Widodo, H. (2022). Hukum Siber: Perlindungan Data Pribadi dan Kejahatan Dunia Maya. Yogyakarta: Deepublish.

Saragih, R. A. (2023). UU Perlindungan Data Pribadi: Penjelasan dan Implikasi Bagi Dunia Usaha dan Konsumen. Jakarta: Sinar Grafika.

Sutedi, A. (2022). Aspek Hukum Perlindungan Data Pribadi di Indonesia. Jakarta: RajaGrafindo Persada.

Gunawan, S. (2019). Etika dan Hukum Informasi Teknologi dalam Era Digital. Bandung: Refika Aditama.

Yuliana, M. (2020). Keamanan Informasi dan Perlindungan Data Pribadi di Era Digital. Jakarta: Ghalia Indonesia.

Kusnadi, R. (2021). Digital Forensik dan Kejahatan Siber: Analisis, Deteksi dan Pencegahan. Malang: Intrans Publishing.

Pratama, R. A. (2023). Mengenal dan Memahami UU No. 27 Tahun 2022 tentang Perlindungan Data Pribadi. Jakarta: Penerbit Andi.

Tentang Penulis



Vina Lusiana lahir di Ronga-ronga, Aceh tengah. Ia lulus S-1 di Program Studi Vina Lusiana lahir di Ronga-ronga, Aceh tengah. Ia lulus S-1 di Program Studi Pendidikan Matematika, Fakultas Keguruan dan Ilmu Pendidikan Universitas Al Muslim (UNIMAL) tahun 2011 dan lulus S-2 di Program Studi Magister Matematika Fakultas Sains dan Matematika Institut Teknologi Bandung (ITB) pada tahun 2016.

Ketika melanjutkan studi S2 Matematika di ITB, penulis aktif dalam kegiatan keorganisasian KAMIL (Keluarga Mahasiswa Islam) Pascasarjana ITB. Organisasi lainnya yang pernah diikuti adalah IGI (Ikatan Guru Indonesia) tahun 2018 dan IDI (Ikatan Dosen Indonesia) tahun 2022. Penulis juga menjadi salah satu narasumber dalam pelatihan kanal IGI.

Penulis merupakan dosen tetap Program Studi Matematika Fakultas MIPA Militer Universitas Pertahanan RI sejak tahun 2024 hingga saat ini. Bidang keahliannya yaitu Pemodelan Matematika, khususnya pada Bidang Epidemiologi. Sebelumnya, penulis menjadi dosen tetap di Program Studi Matematika Fakultas Sains dan Teknologi Universitas Wanita Internasional.



BAB 8
Sistem Deteksi dan Respons Insiden

Ir. Aliy Hafiz, S.Kom., M.T.I., CEH.

A. Pendahuluan: Mengapa Sistem Deteksi dan Respons Insiden Sangat Penting

Di era transformasi digital dan peningkatan kebergantungan pada sistem informasi, serangan siber telah menjadi ancaman strategis yang signifikan terhadap integritas, ketersediaan, dan kerahasiaan data. Organisasi dari berbagai sektor mengalami peningkatan intensitas dan kompleksitas ancaman digital, yang mencakup serangan ransomware, *phishing* hingga kebocoran data akibat celah keamanan. Dalam konteks ini, sistem deteksi dan respons insiden siber (*Cybersecurity Incident Detection and Response System*) menjadi sangat krusial.

1. Deteksi Dini: Pilar Pertahanan Utama

Deteksi insiden secara dini memungkinkan organisasi melakukan tindakan preventif sebelum insiden berkembang menjadi kerugian yang lebih besar. Menurut studi dari IBM Security (2023), waktu rata-rata untuk mengidentifikasi dan menanggapi pelanggaran data adalah 204 hari, dengan biaya rata-rata sebesar USD 4,45 juta per insiden. Semakin cepat insiden terdeteksi, semakin kecil potensi kerugian yang ditimbulkan.

Sebagai perbandingan, organisasi yang memiliki sistem deteksi otomatis mampu mengurangi waktu respons secara signifikan, menghemat hingga USD 1,76 juta

dibanding organisasi yang hanya bergantung pada deteksi manual (IBM, 2023).

2. Respons Insiden: Menjamin Pemulihan dan Keberlangsungan

Sistem respons insiden yang matang memberikan struktur dalam menghadapi serangan—dari isolasi insiden, mitigasi, hingga pemulihan. Menurut *National Institute of Standards and Technology* (NIST), proses respons insiden mencakup empat fase: *preparation, detection and analysis, containment eradication and recovery, dan post-incident activity* (NIST SP 800-61r2).

Selain aspek teknis, respons insiden juga mencakup dimensi komunikasi, hukum, dan manajerial. Kurangnya prosedur formal menyebabkan organisasi gagal merespons dengan cepat, memperpanjang waktu pemulihan, dan meningkatkan kerusakan reputasi (ENISA, 2021).

3. Dampak Serangan Siber: Pelajaran dari Kasus Nyata

Kasus serangan ransomware pada Colonial Pipeline (2021) menjadi titik balik bagi banyak organisasi di seluruh dunia. Serangan ini menyebabkan penghentian operasional distribusi bahan bakar di sebagian besar wilayah AS, memperlihatkan bagaimana insiden siber dapat berdampak langsung pada ekonomi dan keamanan nasional.

Di Indonesia, kasus peretasan Pusat Data Nasional (PDN) pada 2024 juga menunjukkan pentingnya sistem deteksi dan respons terintegrasi. Lambatnya deteksi dan

minimnya kesiapsiagaan tim teknis menyebabkan layanan publik terganggu secara masif, serta menimbulkan krisis kepercayaan dari masyarakat.

4. Urgensi Strategis Sistem Deteksi dan Respons

Dengan makin terintegrasinya dunia digital ke dalam fungsi-fungsi kritikal pemerintahan dan bisnis, maka sistem deteksi dan respons insiden menjadi bagian dari tata kelola keamanan informasi (*Information Security Governance*). Organisasi yang ingin bertahan di era digital harus mengembangkan kapabilitas ini tidak hanya dari sisi teknologi, tetapi juga dari sisi sumber daya manusia, kebijakan, dan prosedur operasional standar.

B. Klasifikasi Insiden Siber

Insiden siber merupakan kejadian yang mengganggu atau mengancam sistem informasi dan infrastruktur teknologi suatu organisasi. Klasifikasi insiden siber penting untuk memahami jenis ancaman yang dihadapi dan menentukan strategi respons yang tepat. Berikut ini beberapa kategori umum insiden siber.

1. Serangan Malware

Melibatkan perangkat lunak berbahaya, seperti virus, worm, trojan, dan ransomware yang dirancang untuk merusak, mengakses, atau mencuri data dari sistem korban. Ransomware, misalnya, mengenkripsi data korban dan menuntut tebusan untuk pemulihannya.

2. Akses Tidak Sah (*Unauthorized Access*)

Terjadi ketika individu atau entitas memperoleh akses ke sistem, jaringan, atau data tanpa izin. Ini mencakup peretasan akun, eskalasi hak akses, dan eksploitasi kerentanan sistem.

3. Serangan *Denial of Service* (DoS) dan *Distributed Denial of Service* (DDoS)

Serangan yang bertujuan membuat layanan atau sumber daya tidak tersedia bagi pengguna yang sah dengan membanjiri sistem dengan lalu lintas yang berlebihan.

4. *Phishing* dan Rekayasa Sosial

Upaya untuk menipu individu agar mengungkapkan informasi sensitif seperti kredensial login atau data keuangan melalui komunikasi palsu yang tampak sah (CSIRT Indonesia).

5. Kebocoran Data (*Data Leakage*)

Insiden di mana informasi sensitif atau rahasia terekspos kepada pihak yang tidak berwenang, baik melalui kesalahan manusia, kegagalan sistem, atau serangan siber.

6. Ancaman dari Orang Dalam (*Insider Threat*)

Melibatkan individu dalam organisasi yang menyalahgunakan akses mereka untuk mencuri data, merusak sistem, atau melakukan tindakan merugikan lainnya.

7. Serangan terhadap Aplikasi Web

Mencakup eksploitasi kerentanan dalam aplikasi web, seperti injeksi SQL, *cross-site scripting* (XSS), dan manipulasi parameter, untuk mendapatkan akses tidak sah atau mencuri data.

8. Serangan terhadap Infrastruktur Fisik

Melibatkan tindakan fisik yang merusak atau mengganggu perangkat keras, fasilitas jaringan, atau infrastruktur teknologi lainnya.

C. Prinsip Dasar Deteksi dan Respons Insiden

Sistem deteksi dan respons insiden merupakan inti dari upaya mempertahankan keamanan informasi organisasi. Prinsip-prinsip dasar yang mendasari mekanisme ini bertujuan memastikan bahwa insiden keamanan dapat dideteksi dengan cepat dan ditangani secara efektif untuk meminimalkan dampak terhadap operasional, reputasi, dan legalitas organisasi.

1. Deteksi Proaktif

Prinsip pertama adalah deteksi proaktif. Organisasi tidak boleh hanya mengandalkan laporan dari pengguna atau kerusakan yang terlihat. Sebaliknya, mereka harus mengimplementasikan sistem pemantauan berkelanjutan (*continuous monitoring*) dan deteksi berbasis ancaman seperti *Intrusion Detection Systems* (IDS) dan *Security*



Information and Event Management (SIEM). Deteksi proaktif ini memungkinkan identifikasi pola anomali sejak dini.

2. Kecepatan dan Ketepatan Respons

Prinsip kedua adalah kecepatan dan ketepatan dalam merespons insiden. Respons yang lambat dapat memperburuk dampak insiden dan memperpanjang waktu pemulihan. Maka, organisasi perlu memiliki *Standard Operating Procedures* (SOP) yang jelas dan tim respons insiden yang terlatih.

3. Prinsip *Least Privilege* dan Segregasi Akses

Prinsip ini mengatur bahwa pengguna hanya diberikan akses minimum yang diperlukan untuk melakukan tugas mereka. Hal ini membatasi potensi penyebaran kerusakan ketika insiden terjadi dan memudahkan proses investigasi. Segregasi akses juga mencegah terjadinya konflik kepentingan dan menyulitkan aktor jahat mengakses sistem kritis.

4. Pelaporan dan Dokumentasi

Setiap insiden yang terdeteksi harus didokumentasikan secara sistematis. Dokumentasi mencakup kronologi kejadian, sistem yang terdampak, tindakan yang diambil, dan hasil akhir. Hal ini penting untuk pembelajaran organisasi dan pelaporan kepada pihak regulator atau auditor.

5. Pemulihan dan Perbaikan (*Recovery and Lessons Learned*)

Setelah insiden ditangani, prinsip penting lainnya adalah proses pemulihan dan evaluasi. Tujuannya untuk mengembalikan sistem ke kondisi normal, mengidentifikasi akar masalah (*root cause analysis*), dan memperbaiki kelemahan sistem agar tidak terulang kembali.

6. Kepatuhan terhadap Kerangka Kerja dan Standar

Prinsip dasar lainnya adalah memastikan bahwa proses deteksi dan respons mengikuti standar yang berlaku, seperti NIST SP 800-61r2, ISO/IEC 27035, dan kerangka kerja lokal seperti Peraturan BSSN tentang Manajemen Insiden Keamanan Siber.

D. Teknologi untuk Deteksi Insiden Siber

Deteksi insiden siber bukan lagi bergantung pada pengawasan manual semata. Di era digital dengan serangan yang semakin canggih, teknologi berperan sangat penting dalam mengenali, menganalisis, dan memberi peringatan dini terhadap ancaman siber. Teknologi ini mampu mengumpulkan log, mendeteksi pola anomali, dan membantu respons otomatis terhadap insiden.

1. *Intrusion Detection System* (IDS) dan *Intrusion Prevention System* (IPS)

IDS adalah sistem yang memantau lalu lintas jaringan dan aktivitas sistem untuk mendeteksi aktivitas mencurigakan



yang menyerupai pola serangan. IDS bekerja pasif, memberikan peringatan kepada administrator. Sementara itu, IPS melakukan pencegahan aktif dengan memblokir atau menolak aktivitas yang teridentifikasi sebagai berbahaya.

- IDS terbagi dua jenis, yaitu *network-based* IDS (NIDS) dan *host-based* IDS (HIDS).
- IPS sering terintegrasi dengan firewall dan dapat beroperasi secara *real-time*.

2. *Security Information and Event Management* (SIEM)

SIEM menggabungkan *log management* dan *event correlation* untuk menyediakan gambaran menyeluruh terhadap keamanan sistem TI. SIEM mengumpulkan data dari berbagai sumber (firewall, antivirus, router, server, dll.), lalu mengidentifikasi pola serangan berdasarkan korelasi antar peristiwa.

Berikut ini fitur utama SIEM.

- *Real-time alerting.*
- Dashboards untuk visualisasi insiden.
- Analitik keamanan berbasis AI.
- Audit trail yang lengkap.

Contoh produk SIEM: Splunk, IBM QRadar, ArcSight, dan Elastic SIEM.

3. *Endpoint Detection and Response* (EDR)

EDR berfokus pada deteksi dan respons terhadap aktivitas mencurigakan di perangkat endpoint, seperti laptop, desktop, atau server. EDR mampu merekam perilaku

aplikasi, pemanggilan API mencurigakan, dan akses data abnormal.

Berikut ini beberapa kemampuan utama EDR.

- *Threat hunting* otomatis.
- Forensik insiden endpoint.
- Isolasi sistem dari jaringan saat insiden terdeteksi.

Produk EDR populer termasuk CrowdStrike, SentinelOne, dan Microsoft Defender for Endpoint.

4. *Network Detection and Response* (NDR)

NDR mengamati lalu lintas jaringan dan menggunakan kecerdasan buatan serta *machine learning* untuk mendeteksi anomali jaringan yang mencurigakan. Berbeda dari IDS/IPS yang berbasis *signature*, NDR lebih adaptif terhadap serangan *zero-day* atau pola yang belum dikenal. Contoh sistem NDR: Vectra AI, Darktrace, dan Corelight.

5. *Threat Intelligence Platform* (TIP)

TIP adalah sistem yang mengintegrasikan berbagai sumber informasi tentang ancaman (*threat feeds*) dan menggabungkannya dengan deteksi internal organisasi. Dengan informasi kontekstual ini, tim keamanan bisa memprioritaskan respons terhadap insiden berdasarkan ancaman yang sedang berkembang secara global.

E. Tahapan Umum dalam Proses Respons Insiden

Respons insiden merupakan proses sistematis yang dilakukan untuk mengidentifikasi, menganalisis, dan



menanggulangi insiden keamanan informasi. Pendekatan yang terstruktur diperlukan agar organisasi mampu meminimalisir dampak serangan, melindungi aset kritis, dan menjaga kepercayaan publik.

Beberapa standar seperti NIST SP 800-61r2 dan ISO/IEC 27035 membagi proses respons insiden ke dalam tahapan tertentu. Proses ini bersifat siklikal (iteratif), sehingga setiap insiden memberikan pelajaran untuk meningkatkan kesiapan di masa depan.

1. Persiapan (*Preparation*)

Tahapan ini merupakan fondasi dari respons insiden yang efektif. Organisasi harus menyiapkan kebijakan, prosedur, sumber daya manusia, dan teknologi sebelum insiden terjadi. Ini mencakup beberapa hal berikut.

- Pembentukan Tim Tanggap Insiden (IRT atau CSIRT).
- Penyusunan kebijakan penanganan insiden.
- Pelatihan dan simulasi berkala (*tabletop exercise*).
- Implementasi sistem pemantauan seperti SIEM, IDS, dan EDR.
- Dokumentasi aset penting (*critical asset inventory*).

2. Identifikasi (*Identification*)

Tahapan ini bertujuan mengenali apakah suatu kejadian merupakan insiden keamanan atau bukan. Tim akan melakukan beberapa hal berikut ini.

- Menganalisis log, alert, atau perilaku anomali.
- Menentukan cakupan dan tingkat keparahan insiden.

- Mencatat waktu kejadian, sistem yang terdampak, dan gejala teknis.
- Menggunakan alat bantu seperti SIEM, *threat intelligence*, dan analisis forensik.

Hasil dari tahap ini adalah konfirmasi bahwa insiden memang terjadi dan memerlukan respons segera.

3. Penahanan (*Containment*)

Setelah insiden diidentifikasi, langkah cepat harus dilakukan untuk menahan penyebaran dampaknya. Penahanan dapat bersifat jangka pendek dan jangka panjang.

- Jangka pendek: Memutus koneksi jaringan dari sistem yang terdampak, menonaktifkan akun, atau menghentikan proses berbahaya.
- Jangka panjang: Perubahan kredensial, patch sistem, hingga rekonstruksi sistem yang terdampak.

Strategi *containment* harus disesuaikan agar tidak menyebabkan gangguan operasional yang lebih besar.

4. Pemberantasan (*Eradication*)

Setelah penahanan, tim harus menghapus akar penyebab serangan seperti malware, backdoor, atau akses tidak sah yang masih tertinggal. Berikut ini beberapa langkah pembatasan.

- Scan menyeluruh terhadap sistem.
- Hapus file atau registry mencurigakan.
- Update sistem dan software.



- Blokir alamat IP atau domain yang digunakan penyerang.

5. Pemulihan (*Recovery*)

Pemulihan adalah proses mengembalikan sistem ke kondisi normal dan memastikan tidak ada lagi ancaman yang tersisa. Tindakan yang dilakukan bisa meliputi tindakan berikut.

- Restore dari backup.
- Monitoring ketat setelah sistem diaktifkan kembali.
- Validasi keamanan sistem sebelum *go-live.*

Waktu pemulihan dan metode yang digunakan harus disesuaikan dengan tingkat sensitivitas data atau layanan.

F. Pembentukan dan Peran Tim CSIRT (*Computer Security Incident Response Team*)

Dalam menghadapi meningkatnya ancaman siber yang semakin kompleks, organisasi tidak lagi cukup hanya mengandalkan teknologi deteksi semata. Dibutuhkan struktur tanggap insiden yang formal dan profesional, yaitu melalui *pembentukan Computer Security Incident Response Team* (CSIRT). CSIRT bertanggung jawab dalam menangani, mengelola, dan memitigasi insiden keamanan siber secara sistematis dan cepat.

1. Tujuan dan Fungsi CSIRT

CSIRT dibentuk untuk meningkatkan kesiapan organisasi terhadap insiden keamanan informasi. Berikut ini tujuan utama CSIRT.

- Merespons insiden siber secara efektif dan efisien.
- Meminimalkan dampak kerusakan akibat serangan.
- Melindungi aset informasi dan menjaga kepercayaan pemangku kepentingan.
- Menjadi titik koordinasi utama dalam penanggulangan insiden.
- Memberikan laporan, dokumentasi, dan evaluasi pasca insiden.

Fungsi CSIRT meliputi deteksi dini insiden, konfirmasi dan klasifikasi, koordinasi dengan unit terkait, komunikasi internal-eksternal, serta pengembangan kebijakan keamanan informasi.

Menurut NIST (2012), keberadaan tim CSIRT yang terlatih mampu mengurangi waktu tanggap insiden hingga lebih dari 50% dibandingkan organisasi yang tidak memilikinya.

2. Struktur Organisasi CSIRT

Struktur CSIRT dapat bervariasi bergantung skala organisasi, namun secara umum mencakup peran-peran berikut.

- Manajer CSIRT: Bertanggung jawab atas operasional dan strategi tim.
- Koordinator Insiden: Memimpin proses tanggap insiden dan pengambilan keputusan teknis.
- Analis Keamanan Siber: Bertugas mengumpulkan, memverifikasi, dan menganalisis data insiden.



- Spesialis Forensik Digital: Menangani bukti digital dan analisis mendalam.
- Liaison Officer/PR: Mengatur komunikasi dengan pihak luar (media, publik, regulator).

Dalam organisasi besar, CSIRT dapat bersifat permanen (*dedicated team*), sedangkan pada organisasi menengah atau kecil, bisa berupa tim ad-hoc yang dibentuk berdasarkan kebutuhan dan rotasi SDM.

3. Tipe-Tipe CSIRT

Menurut ENISA (2023), terdapat beberapa jenis tim CSIRT berdasarkan cakupan tanggung jawabnya.

- Internal CSIRT: dibentuk untuk kebutuhan organisasi sendiri (*enterprise*).
- National CSIRT (Gov-CSIRT): dibentuk oleh negara untuk menangani insiden pada skala nasional, seperti BSSN-CSIRT di Indonesia.
- Sectoral CSIRT: melayani sektor tertentu, seperti keuangan, kesehatan, atau pendidikan.
- Commercial CSIRT (*Managed Services*): disediakan oleh vendor sebagai layanan keamanan siber.

Pemilihan tipe CSIRT harus mempertimbangkan skala organisasi, risiko yang dihadapi, dan regulasi yang berlaku.

4. Langkah-Langkah Pembentukan CSIRT

Berikut tahapan penting dalam membentuk CSIRT.

a. Analisis kebutuhan: Identifikasi aset penting, ancaman dominan, dan risiko terbesar.

b. Penentuan model operasional: Pilih antara centralized, distributed, atau hybrid CSIRT.
c. Penetapan kebijakan: Tetapkan mandat, cakupan tugas, alur pelaporan, dan SOP.
d. Pengembangan kapasitas SDM: Rekrut personel yang kompeten dan latih secara berkala.
e. Investasi infrastruktur: Sediakan *tools* keamanan seperti SIEM, forensik, dan komunikasi aman.
f. Uji dan evaluasi: Lakukan simulasi insiden dan evaluasi kinerja secara berkala.

CSIRT juga perlu memiliki charter (dokumen mandat formal), yang menjelaskan posisi mereka dalam struktur organisasi, tanggung jawab, dan wewenangnya.

G. Strategi Pencegahan dan Deteksi Dini

Pencegahan dan deteksi dini merupakan dua pendekatan utama dalam menjaga keamanan siber yang berkelanjutan. Upaya pencegahan dilakukan sebelum insiden terjadi, sementara deteksi dini bertujuan mengidentifikasi potensi ancaman secepat mungkin agar dampaknya dapat diminimalisir. Keduanya menjadi tulang punggung sistem keamanan proaktif yang mendukung kerangka kerja deteksi dan respons insiden secara keseluruhan (Whitman & Mattord, 2022).



1. Strategi Pencegahan

Strategi pencegahan menitikberatkan pada kontrol keamanan untuk mengurangi kemungkinan terjadinya insiden. Pendekatan ini mencakup tiga aspek penting: kebijakan, teknologi, dan kesadaran pengguna.

a. Kebijakan Keamanan Informasi

Organisasi harus memiliki kebijakan tertulis yang menjelaskan aturan, prosedur, dan standar keamanan. ISO/IEC 27001 menekankan pentingnya manajemen risiko, pengendalian akses, dan perlindungan aset informasi sebagai bagian dari sistem manajemen keamanan informasi (ISO, 2022).

b. Penerapan Kontrol Teknis dan Fisik

Beberapa kontrol teknis yang terbukti efektif sebagai berikut.

- Firewall dan IDS/IPS: Menyaring lalu lintas jaringan yang mencurigakan.
- Enkripsi dan segmentasi jaringan: Mengurangi risiko kebocoran data.
- Patch management: Menutup celah keamanan perangkat lunak.
- Multi-Factor Authentication (MFA): Meningkatkan keamanan akses.

c. Pelatihan dan Kampanye Kesadaran Siber

Studi menunjukkan bahwa kesalahan manusia adalah faktor dominan dalam lebih dari 85% insiden siber

(Verizon, 2023). Oleh karena itu, pelatihan berkala tentang phishing, keamanan kata sandi, dan praktik terbaik penggunaan teknologi sangat diperlukan.

2. Strategi Deteksi Dini

Deteksi dini adalah proses mengidentifikasi aktivitas tidak biasa atau berpotensi berbahaya sebelum menjadi serangan serius. Pendekatan ini sangat bergantung pada pengumpulan data, pemantauan berkelanjutan, dan analisis kecerdasan ancaman (*threat intelligence*).

a. *Security Information and Event Management* (SIEM)
   SIEM mengumpulkan log dari berbagai sistem, lalu menganalisisnya secara *real time* untuk mendeteksi anomali atau pola serangan. Tools seperti Splunk, IBM QRadar, dan ELK Stack populer dalam ekosistem deteksi ini (Scarfone & Mell, 2021).
b. Threat Intelligence
   Informasi dari komunitas keamanan (misalnya CERT, Mitre ATT&CK) memberikan wawasan tentang TTP (*Tactics, Techniques, and Procedures*) dari aktor jahat yang bisa digunakan untuk mengenali indikasi serangan sejak dini.
c. *Endpoint Detection and Response* (EDR)
   Teknologi ini fokus pada aktivitas pengguna di *endpoint* (laptop, server, mobile) dan mampu mengidentifikasi perilaku mencurigakan, seperti eskalasi hak akses,

modifikasi file sistem, atau komunikasi abnormal ke internet.

d. *Behavioral Analytics* & AI

Deteksi berbasis perilaku menggunakan pembelajaran mesin untuk mengenali anomali aktivitas berdasarkan pola sebelumnya. Teknologi ini membantu mengurangi *false positive* dan mempercepat waktu respons.

Daftar Pustaka

ENISA. (2023). Good Practice Guide for Incident Management. https://www.enisa.europa.eu

ENISA. (2024). Future Trends in Cybersecurity: Threat Landscape and Response Strategies.

IBM Security. (2023). Cost of a Data Breach Report 2023.

LevelBlue. (2025). Security Incidents: Types of Attacks and Triage Options. https://levelblue.com/resource-center/ebook/insider-guide-to-incident-response/types-of-security-incidents

Mitre Corporation. (2023). MITRE ATT&CK Framework. https://attack.mitre.org

NIST. (2012). Computer Security Incident Handling Guide (SP 800-61 Revision 2). U.S. Department of Commerce.

NIST. (2018). Computer Security Incident Handling Guide (SP 800-61r2). National Institute of Standards and Technology.

PurpleSec. (2024). 14 Types Of Security Incidents (& How To Prevent Them).

SANS Institute. (2022). SIEM and EDR Comparison Guide.

SANS Institute. (2023). Incident Handler's Handbook.

Scarfone, K., & Mell, P. (2012). Guide to Intrusion Detection and Prevention Systems (IDPS).

Scarfone, K., & Mell, P. (2021). Guide to Intrusion Detection and Prevention Systems (IDPS). NIST.

SentinelOne. (2024). Cyber Security Incident Response: Best Practices.



Verizon. (2023). 2023 Data Breach Investigations Report (DBIR).

Whitman, M. E., & Mattord, H. J. (2022). Principles of Information Security (7th ed.). Cengage Learning.

ISO/IEC. (2016). ISO/IEC 27035: Information Security Incident Management. International Organization for Standardization.

ISO/IEC. (2022). ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems. International Organization for Standardization.

Tentang Penulis

Ir. Aliy Hafiz, S.Kom., M.T.I., CEH., CSA. adalah seorang dosen dan praktisi di bidang Teknologi Informasi yang berasal dari Lampung. Ia menempuh pendidikan sarjana di bidang

Sistem Informasi, kemudian melanjutkan studi magister pada bidang Teknik Informatika. Gelar insinyur diperolehnya sebagai bentuk pengakuan atas kontribusinya dalam bidang rekayasa informatika atau teknologi informasi. Sebagai seorang akademisi dan profesional, ia aktif mengajar di perguruan tinggi serta terlibat dalam berbagai proyek teknologi informasi, khususnya pada aspek keamanan sistem informasi dan rekayasa perangkat lunak.

Selain itu, ia memiliki sertifikasi internasional seperti *Certified Ethical Hacker* (CEH) dan *Certified System Analyst* (CSA) yang menegaskan kompetensinya dalam dunia keamanan siber. Fokus dan minat profesionalnya meliputi keamanan komputer, manajemen insiden siber, serta tata kelola keamanan informasi. Selain menulis dan mengajar, ia juga kerap menjadi pembicara dalam seminar, pelatihan, dan konferensi nasional di bidang teknologi informasi dan keamanan digital.



BAB 9
KEAMANAN CLOUD DAN VIRTUALISASI

Fitri Wibowo, S.S.T., M.T., M.Sc.

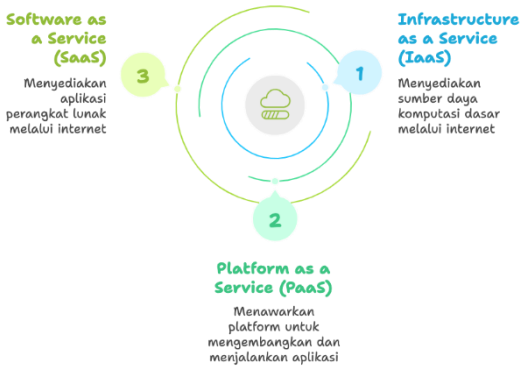
A. Pengantar Komputasi Awan

Komputasi awan (*cloud computing*) adalah model komputasi berbasis internet yang menyediakan akses ke sumber daya komputasi, seperti server, penyimpanan, database, jaringan, perangkat lunak, dan layanan lainnya secara fleksibel dan hemat biaya. Menurut *National Institute of Standards and Technology* (NIST), komputasi awan memiliki lima karakteristik utama, yaitu layanan mandiri sesuai permintaan, akses jaringan luas, *pooling* sumber daya, elastisitas cepat, dan layanan terukur.

Layanan mandiri sesuai permintaan memungkinkan pengguna secara mandiri menggunakan sumber daya komputasi tanpa perlu intervensi manusia dari penyedia layanan. Akses jaringan luas memastikan layanan tersedia melalui internet dan bisa diakses dari berbagai perangkat seperti laptop, *smartphone*, maupun tablet. *Pooling* sumber daya memungkinkan penyedia layanan *cloud* berbagi sumber daya secara dinamis untuk memenuhi kebutuhan banyak pengguna secara bersamaan. Elastisitas cepat mengacu pada kemampuan cepat menyesuaikan sumber daya sesuai kebutuhan pengguna. Terakhir, layanan terukur berarti penggunaan sumber daya diawasi dan dihitung secara transparan, umumnya dengan sistem pembayaran sesuai pemakaian (*pay-as-you-go*) (Mell and Grance, 2011).

Model Layanan Cloud





Gambar 1 Model Layanan *Cloud Computing*

Ada tiga model layanan utama dalam komputasi awan, yaitu *Infrastructure as a Service* (IaaS), *Platform as a Service* (PaaS), dan *Software as a Service* (SaaS). Dalam model IaaS, penyedia layanan menawarkan infrastruktur dasar, seperti mesin virtual, penyimpanan, dan jaringan, contohnya Amazon Web Services (AWS) dan Google Compute Engine. Model PaaS menyediakan platform yang memungkinkan pengguna mengembangkan, menguji, dan mengelola aplikasi tanpa harus mengurus infrastruktur yang mendasarinya, contohnya Heroku dan Google App Engine. Model SaaS adalah layanan perangkat lunak siap pakai yang diakses melalui internet, seperti Microsoft 365 dan Google Workspace (Gorelik, 2013).

Model *Cloud Deployment*

Cara penerapan *cloud* dapat dibedakan menjadi *public cloud*, *private cloud*, dan *hybrid cloud*. *Public cloud* merupakan

layanan *cloud* yang terbuka untuk publik dan dimiliki penyedia layanan pihak ketiga seperti AWS, Microsoft Azure, atau Google Cloud Platform. *Private cloud* adalah infrastruktur *cloud* yang hanya digunakan secara eksklusif oleh satu organisasi, menawarkan kontrol lebih baik terhadap keamanan dan privasi data. *Hybrid cloud* adalah kombinasi dari *public cloud* dan *private cloud*, memberikan fleksibilitas maksimal karena organisasi bisa memanfaatkan kelebihan dari kedua model ini (Savu, 2011).

B. Risiko Keamanan Cloud



Gambar 2 Risiko Keamanan *Cloud Computing*

Meskipun komputasi awan menawarkan fleksibilitas dan efisiensi, ia juga membawa sejumlah risiko keamanan yang perlu diwaspadai. Berikut ini beberapa risiko utama yang sering dihadapi dalam lingkungan *cloud*

1. Kebocoran dan Kehilangan Data

Data yang disimpan di *cloud* rentan terhadap kebocoran dan kehilangan akibat berbagai faktor, termasuk kesalahan konfigurasi, serangan siber, atau kegagalan sistem. Misalnya, kesalahan dalam pengaturan izin akses dapat memungkinkan pihak yang tidak berwenang mengakses data sensitif.

2. Tantangan Privasi dan Kepatuhan

Penyimpanan data di *cloud* sering kali melibatkan pemrosesan data pribadi yang tunduk pada berbagai regulasi privasi seperti *General Data Protection Regulation* (GDPR) dan ISO/IEC 27018 (*ISO/IEC 27018:2019*, 2019). Kepatuhan terhadap regulasi ini memerlukan kontrol ketat atas bagaimana data dikumpulkan, disimpan, dan digunakan.

3. *Identity and Access Management* (IAM)

Pengelolaan identitas dan akses yang tidak efektif dapat membuka celah bagi pelanggaran keamanan. Kurangnya strategi IAM yang solid dapat menyebabkan akses tidak sah ke sumber daya *cloud*, meningkatkan risiko kebocoran data. Implementasi kontrol akses berbasis peran dan otentikasi multi-faktor adalah langkah penting dalam mengurangi risiko ini.

4. Risiko Berbagi Sumber Daya

Dalam model multi-tenant *cloud*, sumber daya seperti server dan penyimpanan digunakan bersama oleh berbagai pelanggan. Hal ini dapat menimbulkan risiko keamanan,

seperti serangan *side-channel*, di mana penyerang dapat mengeksploitasi kelemahan dalam isolasi sumber daya untuk mengakses data pelanggan lain. *Cloud Security Alliance* (CSA) menyarankan penerapan isolasi yang kuat dan pemantauan terus-menerus untuk mengidentifikasi dan mencegah potensi pelanggaran keamanan.

C. Praktik Terbaik & Proteksi *Workload*

Perlindungan *workload* dalam lingkungan cloud memerlukan pendekatan keamanan yang menyeluruh dan berlapis. Berikut ini beberapa praktik terbaik yang dapat diterapkan untuk meningkatkan keamanan *workload* di cloud.

1. Model Keamanan *Zero Trust*

Model *Zero Trust* mengharuskan verifikasi setiap permintaan akses, baik dari dalam maupun luar jaringan. Pendekatan ini mengurangi risiko akses tidak sah dengan menerapkan prinsip "*never trust, always verify*". Implementasi *Zero Trust* mencakup autentikasi multi-faktor, kontrol akses berbasis peran, dan segmentasi jaringan. Model ini telah terbukti efektif dalam mengurangi serangan siber di lingkungan *cloud*.

2. Enkripsi Data

Melindungi data saat disimpan (*at rest*) dan saat ditransmisikan (*in transit*) adalah langkah krusial. Penggunaan algoritma enkripsi yang kuat, seperti AES-256



untuk data *at rest* dan TLS 1.3 untuk data in transit, memastikan bahwa data tetap aman meskipun terjadi pelanggaran keamanan.

3. *Identity and Access Management* (IAM)

Pengelolaan identitas dan akses yang efektif mencegah akses tidak sah ke sumber daya *cloud*. Praktik terbaik mencakup penggunaan autentikasi multi-faktor, prinsip *least privilege*, dan kontrol akses berbasis peran. Strategi IAM yang solid mengurangi risiko kebocoran data dan pelanggaran keamanan.

4. *Pemantauan* dan Logging Aktivitas

Pemantauan kontinu dan pencatatan aktivitas sistem membantu dalam mendeteksi dan merespons insiden keamanan secara cepat. Implementasi sistem logging yang efektif memungkinkan analisis forensik dan pemulihan setelah insiden. NIST SP 800-92 (Kent and Souppaya, 2006) memberikan panduan dalam pengelolaan log keamanan komputer.

5. Proteksi *Workload* dengan CWPP

Cloud Workload Protection Platforms (CWPP) menyediakan perlindungan khusus untuk workload di *cloud*, termasuk mesin virtual, *container*, dan fungsi *serverless*. CWPP memungkinkan pemantauan ancaman secara *real-time*, deteksi kerentanan, dan penerapan kebijakan keamanan yang konsisten di seluruh lingkungan cloud. Implementasi

CWPP membantu organisasi dalam menjaga integritas dan keamanan *workload* mereka.

6. Pengujian Keamanan Aplikasi

Melakukan pengujian keamanan secara rutin pada aplikasi *cloud-native* membantu dalam mengidentifikasi dan memperbaiki kerentanan sebelum dieksploitasi oleh penyerang. Pengujian ini mencakup analisis kode sumber, pengujian penetrasi, dan evaluasi konfigurasi keamanan. Pendekatan ini memastikan bahwa aplikasi tetap aman sepanjang siklus hidupnya.

7. Kepatuhan terhadap Standar Keamanan

Mematuhi standar keamanan internasional, seperti ISO/IEC 27017 (*ISO/IEC 27017:2015*, 2015) dan ISO/IEC 27018 (*ISO/IEC 27018:2019*, 2019), membantu organisasi dalam mengelola risiko keamanan informasi dan perlindungan data pribadi di cloud. Standar ini menyediakan panduan dalam penerapan kontrol keamanan dan memastikan bahwa organisasi memenuhi persyaratan regulasi yang berlaku.

D. Strategi Pemulihan & Standar Kepatuhan

Dalam era digital saat ini, organisasi menghadapi tantangan dalam memastikan kontinuitas bisnis dan kepatuhan terhadap regulasi yang ketat. Strategi pemulihan bencana *Disaster Recovery* (DR) yang efektif dan kepatuhan terhadap standar keamanan informasi menjadi kunci dalam menjaga integritas dan ketersediaan data di lingkungan *cloud*.





Gambar 3 Sinergi untuk Ketahanan dan Kepercayaan *Cloud Computing*

Strategi Pemulihan Bencana di *Cloud*

Pemulihan bencana berbasis *cloud* menawarkan fleksibilitas dan skalabilitas yang lebih baik dibandingkan dengan solusi tradisional. Berikut ini beberapa praktik terbaik (Roller, 2024) dalam strategi DR di *cloud*.

1. Penetapan RTO dan RPO

Menentukan *Recovery Time Objective* (RTO) dan *Recovery Point Objective* (RPO) yang sesuai dengan kebutuhan bisnis untuk meminimalkan *downtime* dan kehilangan data (Yadavalli, 2022).

2. Automasi dan Orkestrasi

Menggunakan alat otomatisasi untuk proses *backup*, replikasi data, dan *failover* guna mempercepat pemulihan.

3. Pengujian Berkala

Melakukan pengujian rutin terhadap rencana DR untuk memastikan efektivitas dan kesiapan dalam menghadapi bencana.

4. Enkripsi dan Keamanan Data

Menerapkan enkripsi data saat transit dan saat disimpan untuk melindungi informasi sensitif.

5. Pemilihan Penyedia Layanan *Cloud* yang Tepat

Memastikan bahwa penyedia layanan *cloud* memiliki sertifikasi dan kepatuhan terhadap standar keamanan yang relevan.

Standar Kepatuhan dalam Lingkungan *Cloud*

Kepatuhan terhadap standar keamanan informasi merupakan aspek krusial dalam pengelolaan data di *cloud*. Berikut ini beberapa standar internasional yang relevan.

1. ISO/IEC 27001

Standar untuk sistem manajemen keamanan informasi yang menetapkan persyaratan untuk menetapkan, menerapkan, memelihara, dan terus meningkatkan sistem manajemen keamanan informasi.

2. ISO/IEC 27017

Panduan untuk kontrol keamanan informasi berbasis *cloud*, memberikan rekomendasi tambahan untuk penyedia dan pengguna layanan *cloud.*



3. ISO 22301

Standar untuk sistem manajemen kontinuitas bisnis, membantu organisasi dalam merencanakan, menetapkan, menerapkan, mengoperasikan, memantau, meninjau, memelihara, dan meningkatkan sistem manajemen untuk melindungi terhadap, mengurangi kemungkinan terjadinya, mempersiapkan, merespons, dan memulihkan dari insiden yang mengganggu.

4. EU *Cloud Code of Conduct*

Kode etik yang membantu penyedia layanan *cloud* menunjukkan kepatuhan terhadap GDPR dan menyediakan kerangka kerja untuk perlindungan data pribadi di *cloud.*

Implementasi standar-standar ini membantu organisasi dalam membangun kepercayaan dengan pelanggan dan pemangku kepentingan, serta memastikan bahwa data dikelola dengan aman dan sesuai dengan regulasi yang berlaku.

Integrasi Strategi DR dan Kepatuhan

Mengintegrasikan strategi pemulihan bencana dengan kepatuhan terhadap standar keamanan informasi memungkinkan organisasi untuk melakukan beberapa hal berikut ini.

1. Mengurangi Risiko

Dengan memiliki rencana DR yang sesuai dengan standar, organisasi dapat mengurangi risiko kehilangan data dan gangguan operasional (Roller, 2024).

2. Meningkatkan Kepercayaan

Kepatuhan terhadap standar internasional meningkatkan kepercayaan pelanggan dan mitra bisnis terhadap keamanan data organisasi.

3. Memenuhi Persyaratan Regulasi

Organisasi dapat memastikan bahwa mereka memenuhi persyaratan hukum dan regulasi yang berlaku di berbagai yurisdiksi.



Daftar Pustaka

Gorelik, E. (2013) *Cloud computing models*. PhD Thesis. Massachusetts Institute of Technology.

ISO/IEC 27017:2015 (2015) *ISO*. Available at: https://www.iso.org/standard/43757.html (Accessed: 19 May 2025).

ISO/IEC 27018:2019 (2019) *ISO*. Available at: https://www.iso.org/standard/76559.html (Accessed: 19 May 2025).

Kent, K. and Souppaya, M. (2006) *Guide to Computer Security Log Management*. NIST Special Publication (SP) 800-92. National Institute of Standards and Technology. Available at: https://doi.org/10.6028/NIST.SP.800-92.

Mell, P. and Grance, T. (2011) 'The NIST Definition of Cloud Computing'.

Roller, J. (2024) 'Disaster Recovery in the Cloud: Ensuring Business Continuity Across Distributed Systems', *IEEE Computer Society*, 18 October. Available at: https://www.computer.org/publications/tech-news/trends/disaster-recovery-in-the-cloud/ (Accessed: 19 May 2025).

Savu, L. (2011) 'Cloud Computing: Deployment Models, Delivery Models, Risks and Research Challenges', in *2011 International Conference on Computer and Management (CAMAN)*. *2011 International Conference*

on Computer and Management (CAMAN), pp. 1–4. Available at: https://doi.org/10.1109/CAMAN.2011.5778816.

Yadavalli, T. (2022) 'Strategies for Data Backup and Disaster Recovery in Google Cloud Platform', *International Journal of Multidisciplinary Research and Growth Evaluation.*, 3(2), pp. 628–630. Available at: https://doi.org/10.54660/IJMOR.2022.3.2.628-630.



Tentang Penulis



Fitri Wibowo, S.S.T., M.T., M.Sc. adalah seorang dosen di Politeknik Negeri Pontianak. Ia memperoleh gelar master *double degree* pada bidang Teknik Elektro dari Universitas Indonesia dengan spesialisasi Multimedia dan Jaringan Informasi serta di program studi Informatique des Images et des Réseaux, Université Bretagne-Sud, Perancis. Selain sertifikasi di bidang pemrograman *mobile,* ia juga memiliki sertifikasi di bidang *Internet of Things*, *big data*, pemrograman Python, sistem administrasi Linux, hingga pengembangan aplikasi web.

Sebagai praktisi di dunia pendidikan dan penelitian, penulis ingin berbagi pengetahuan tentang teknologi terbaru kepada pembaca melalui tulisan ini. Ia berharap buku yang ditulisnya dapat bermanfaat bagi masyarakat luas. Penulis dapat dihubungi melalui alamat email fitri.wibowo@polnep.ac.id.



BAB 10
SERANGAN SIBER TERBESAR DALAM SEJARAH

Ir. Pujo Hari Saputro, S.Kom., M.T.

A. Pengertian Serangan Siber Berskala Besar

Serangan siber berskala besar merujuk pada aksi peretasan atau gangguan digital yang dilakukan secara terorganisir dengan dampak luas terhadap infrastruktur kritikal, seperti sistem pemerintahan, perbankan, atau layanan publik. Serangan ini tidak hanya menargetkan satu individu atau perusahaan, tetapi melibatkan banyak korban sekaligus, sering kali dengan tujuan politik, ekonomi, atau destabilisasi. Contohnya, termasuk serangan ransomware yang melumpuhkan rumah sakit atau serangan *Distributed Denial of Service* (DDoS) yang membanjiri server hingga layanan penting terganggu (Toledano, 2024) , (Stoddart, 2022).

Ciri khas serangan siber skala besar adalah penggunaan teknik canggih dan sumber daya besar, sering kali melibatkan aktor negara (*state-sponsored*) atau kelompok peretas profesional. Mereka memanfaatkan kerentanan sistem, malware kompleks, atau rekayasa sosial untuk mencapai tujuan.

Mencegah serangan siber berskala besar membutuhkan kolaborasi global, investasi dalam keamanan siber, dan kesadaran masyarakat. Perusahaan dan pemerintah harus memperkuat pertahanan dengan firewall, enkripsi data, dan pelatihan SDM. Di tingkat internasional, kerja sama seperti *Cyber Threat Intelligence Sharing* membantu memitigasi risiko. Dengan meningkatnya

kebergantungan pada teknologi, serangan siber skala besar menjadi ancaman nyata yang harus dihadapi secara serius oleh semua pihak (Mandel, 2017).

B. Dampak Sistemik terhadap Negara, Organisasi, dan Individu

Serangan siber berskala besar dapat menimbulkan dampak sistemik yang sangat merusak bagi suatu negara, terutama jika menargetkan infrastruktur kritikal seperti jaringan listrik, sistem perbankan, atau layanan pemerintahan. Gangguan ini tidak hanya mengancam stabilitas ekonomi, tetapi juga dapat memicu kekacauan sosial dan politik. Misalnya, serangan terhadap sistem energi dapat melumpuhkan aktivitas harian, sementara peretasan data sensitif pemerintah dapat merusak kepercayaan publik dan hubungan internasional. Negara juga harus mengeluarkan biaya besar untuk pemulihan dan peningkatan keamanan siber yang berdampak pada anggaran nasional.

Bagi organisasi, serangan siber dapat menyebabkan kerugian finansial yang masif, mulai dari biaya pemulihan data, tuntutan hukum hingga hilangnya kepercayaan pelanggan. Perusahaan yang menjadi korban ransomware atau kebocoran data mungkin mengalami gangguan operasional dalam waktu lama, bahkan sampai bangkrut. Selain itu, organisasi yang bergerak di bidang kesehatan, transportasi, atau keuangan dapat membahayakan nyawa

manusia jika sistem mereka diretas. Reputasi yang hancur pascaserangan juga membuat investor dan mitra bisnis enggan bekerja sama sehingga memperparah dampak jangka panjang.

Pada tingkat individu, serangan siber dapat mengakibatkan pencurian identitas, kerugian finansial pribadi, dan pelanggaran privasi. Banyak orang yang menjadi korban *phishing* atau malware kehilangan tabungan atau terjerat pinjaman *online* ilegal. Kebocoran data pribadi juga meningkatkan risiko *cyberstalking*, pemerasan, atau penyalahgunaan informasi. Selain kerugian materi, korban sering mengalami tekanan psikologis akibat ketidakamanan digital. Oleh karena itu, literasi keamanan siber menjadi krusial bagi masyarakat agar dapat melindungi diri dari ancaman yang semakin canggih (Lin, 2018).

C. Mengapa Penting untuk Mempelajari Serangan-Serangan Ini

Mempelajari serangan siber berskala besar sangat penting karena ancaman ini memiliki sifat yang dinamis dan terus berkembang seiring dengan kemajuan teknologi. Dari perspektif keamanan siber (*cybersecurity science*), analisis terhadap pola, teknik, dan motivasi di balik serangan-serangan ini memungkinkan pengembangan model pertahanan yang lebih efektif, seperti *intrusion detection systems* (IDS) dan *machine learning-based threat prevention*.

Penelitian empiris menunjukkan bahwa pemahaman mendalam tentang *attack vectors* dan eksploitasi kerentanan dapat mengurangi waktu respons (*response time*) terhadap insiden sehingga meminimalkan dampak kerusakan. Selain itu, pendekatan ilmiah dalam mempelajari serangan siber juga membantu mengidentifikasi tren global, seperti peningkatan ancaman *ransomware-as-a-service* (RaaS) atau serangan berbasis *artificial intelligence* yang memerlukan solusi teknis dan kebijakan yang adaptif.

Dari sudut pandang ilmu sosial dan kebijakan, mempelajari serangan siber berskala besar memberikan wawasan tentang dampak sistemik terhadap stabilitas geopolitik, ekonomi, dan keamanan nasional. Penelitian interdisipliner antara *computer science*, kriminologi, dan hubungan internasional mengungkapkan bagaimana aktor-aktor seperti *state-sponsored hackers* atau kelompok teroris memanfaatkan celah siber untuk mencapai tujuan strategis. Data historis serangan seperti Stuxnet atau SolarWinds menunjukkan bahwa serangan siber tidak hanya bersifat teknis, tetapi juga memiliki dimensi politik dan psikologis. Dengan demikian, pendekatan ilmiah dalam mempelajari fenomena ini tidak hanya memperkuat ketahanan digital, tetapi juga mendorong kerja sama internasional dalam membangun norma-norma siber (*cyber norms*) dan kerangka hukum yang lebih efektif (Stoddart, 2022).



D. Studi Kasus Serangan Siber Terkemuka

Disusun berdasarkan kronologi dan kategori target (negara, perusahaan, individu).

1. Stuxnet (2010)

Stuxnet merupakan malware pertama yang secara spesifik dirancang untuk menyerang sistem kontrol industri (*Industrial Control Systems*/ICS), menandai era baru perang siber berbasis infrastruktur fisik. Analisis *reverse engineering* mengungkap bahwa Stuxnet menggunakan empat *zero-day exploits* pada sistem Windows, termasuk kerentanan dalam shortcut files (LNK) dan print spooler, untuk menyebar melalui USB drives dan jaringan lokal.

Setelah infeksi, malware ini menargetkan *Programmable Logic Controllers* (PLCs) Siemens Step7, memodifikasi kode operasi sentrifugal nuklir Iran sehingga berputar di luar kecepatan aman sebelum akhirnya hancur. Hal yang unik, Stuxnet dilengkapi rootkit tingkat firmware untuk menyembunyikan aktivitasnya dan hanya aktif pada konfigurasi sistem tertentu, menunjukkan tingkat presisi dan kompleksitas yang mengindikasikan pembiayaan dan pengembangan oleh entitas negara (*state-sponsored*).

Serangan Stuxnet tidak hanya menyebabkan kerusakan fisik pada fasilitas nuklir Natanz Iran (diperkirakan menghancurkan 1.000 dari 5.000 sentrifugal), tetapi juga membuka mata dunia akan kerentanan

infrastruktur kritikal terhadap ancaman siber. Dampak sistemiknya sebagai berikut.

a. Gangguan operasional jangka panjang: Pemulihan membutuhkan waktu bulanan karena ketergantungan pada komponen fisik yang rusak.
b. Erosi kepercayaan dalam otomasi industri: Serangan ini memicu skeptisisme global terhadap keandalan sistem ICS, mendorong revisi standar keamanan (IEC 62443).
c. Eskalasi perang siber global: Stuxnet memicu perlombaan senjata siber, dengan negara-negara seperti AS, Rusia, dan China menginvestasikan lebih besar dalam offensive cyber capabilities.

Studi kasus ini menjadi bukti empiris bahwa serangan siber dapat memiliki konsekuensi setara dengan serangan militer konvensional (*kinetic effects*).

Stuxnet juga berpengaruh terhadap kebijakan keamanan siber secara global, Adapun bagaimana Stuxnet mengubah paradigma kebijakan keamanan siber dengan cara berikut.

a. Penegasan konsep "perang siber": Serangan ini membuktikan bahwa operasi siber dapat menjadi alat geopolitik untuk sabotase tanpa *attribution* langsung (*plausible deniability*).
b. Perlunya kerangka hukum baru: Ketidakjelasan hukum internasional (misalnya, apakah Stuxnet melanggar Pasal 2(4) Piagam PBB tentang pelarangan penggunaan



kekuatan) memicu debat tentang perluasan Tallinn Manual ke ranah infrastruktur sipil.

c. Kolaborasi publik-swasta: Kebocoran Stuxnet ke sistem non-target (termasuk Indonesia) menyoroti pentingnya information sharing antara pemerintah, industri, dan peneliti keamanan.

2. Sony Pictures Hack (2014)

Peretasan terhadap Sony Pictures Entertainment pada November 2014 menjadi salah satu insiden keamanan siber paling memalukan dalam sejarah korporasi. Kelompok peretas yang menyebut diri *"Guardians of Peace"* (GOP) merusak sistem perusahaan, mencuri lebih dari 100 terabyte data sensitif—termasuk film yang belum dirilis, email eksekutif, informasi gaji, dan data pribadi karyawan.

Serangan terhadap Sony Pictures Entertainment (SPE) pada November 2014 merupakan contoh klasik *Advanced Persistent Threat* (APT) dengan karakteristik sebagai berikut.

a. Vektor serangan: Analisis forensik digital mengungkap penggunaan *spear-phishing* dan eksploitasi *zero-day vulnerability* dalam sistem SPE. Peretas memanfaatkan malware wiper (e.g., Destover) untuk menghapus data dan melumpuhkan infrastruktur IT.

b. Motif geopolitik: Indikator Kompromi (IoCs) seperti penggunaan IP Korea Utara dan kode bahasa Korea dalam malware mengarah pada keterlibatan Lazarus

Group (aktor yang dikaitkan dengan pemerintah Korea Utara).

c. Dampak teknis: Penghancuran 70% server SPE dan pencurian >100 TB data menunjukkan kegagalan strategi *defense-in-depth* dan *insufficient network segmentation*.

Kasus Sony Pictures Hack mengungkap kelemahan struktural dalam *cyber risk management* perusahaan multinasional, termasuk kegagalan *governance* seperti tidak diterapkannya *encryption* untuk data sensitif dan lemahnya *patch management* yang berujung pada kerugian ekonomi mencapai $200. Insiden ini menjadi *turning point* dalam paradigma keamanan siber global dengan mempercepat adopsi NIST *Cybersecurity Framework* (2014) dan ISO 27001, memicu perkembangan metode *scientific attribution* untuk melacak aktor serangan, serta menetapkan preseden kolaborasi *public-private partnership* antara FBI dan Sony dalam penanganan insiden siber.

3. WannaCry Ransomware (2017)

WannaCry ransomware yang muncul pada Mei 2017 merupakan salah satu serangan siber paling merusak dalam sejarah, menginfeksi lebih dari 300.000 komputer di 150 negara dalam waktu 72 jam. Serangan ini memanfaatkan kerentanan EternalBlue pada protokol SMB Windows yang sebenarnya telah dipatch oleh Microsoft dua bulan sebelumnya melalui update MS17-010. Penyebaran

eksponensial WannaCry dipicu oleh mekanisme *worm-like propagation* yang memungkinkan *self-replication* antarkomputer dalam jaringan yang tidak terproteksi. Analisis forensik mengungkap bahwa ransomware ini menargetkan sistem dengan spesifik, mengenkripsi file pengguna dan meminta pembayaran dalam Bitcoin senilai 300–600. Kasus ini menjadi contoh nyata bagaimana exploit yang dikembangkan badan intelijen (dalam hal ini NSA yang mengembangkan EternalBlue) dapat bocor dan dimanfaatkan oleh aktor jahat (dalam hal ini kelompok hacker Shadow Brokers).

Epidemi WannaCry menyoroti beberapa kegagalan sistemik dalam ekosistem keamanan siber global. Pertama, ketidakpatuhan organisasi terhadap praktik *patch management* dasar, di mana banyak korban (termasuk NHS Inggris dan FedEx) masih menjalankan sistem Windows yang tidak terupdate. Kedua, kebergantungan berlebihan pada perimeter security tanpa implementasi *network segmentation* yang memadai, memungkinkan ransomware menyebar cepat dalam jaringan internal. Ketiga, kurangnya kesiapan *incident response* di banyak organisasi, dengan waktu respons rata-rata mencapai 7 hari menurut laporan Europol. Dampak ekonomi global diperkirakan mencapai $4 miliar oleh Cyence, termasuk biaya downtime, recovery, dan kehilangan produktivitas. Sektor kesehatan menjadi yang

paling parah terdampak, dengan pembatalan lebih dari 19.000 prosedur medis di NHS Inggris.

WannaCry memicu perdebatan penting dalam komunitas keamanan siber mengenai *responsible vulnerability disclosure* dan *stockpiling exploit* oleh pemerintah. Kasus ini mempercepat adopsi framework seperti CIS Controls yang menekankan *patch management* sebagai prioritas utama. Di tingkat kebijakan, WannaCry mendorong pembentukan unit respons insiden nasional di banyak negara dan revisi terhadap regulasi seperti EU NIS Directive. Dari perspektif etika, insiden ini mempertanyakan keseimbangan antara kebutuhan intelijen nasional dan risiko keamanan siber global ketika *exploit weaponized* tidak di-*patch*.

4. SolarWinds Attack (2020)

Serangan SolarWinds pada tahun 2020 merepresentasikan salah satu operasi *Advanced Persistent Threat* (APT) paling canggih dalam sejarah keamanan siber, mengompromikan rantai pasok perangkat lunak melalui injeksi kode berbahaya (Sunburst backdoor) ke dalam sistem update Orion milik SolarWinds. Analisis forensik mengungkapkan bahwa aktor ancaman (dikaitkan dengan kelompok Rusia Cozy Bear/APT29) melakukan *lateral movement* yang sangat terencana, memanfaatkan teknik *living-off-the-land* (LotL) untuk menghindari deteksi dengan menyamar sebagai aktivitas sistem normal. Serangan ini berdampak pada lebih

dari 18.000 organisasi global, termasuk lembaga pemerintah AS, seperti Departemen Keuangan, Departemen Perdagangan, dan bahkan sektor swasta ternama, menunjukkan kerentanan kritis dalam ekosistem keamanan *software supply chain*.

Kompleksitas serangan SolarWinds terletak pada sifatnya yang *low-and-slow*, di mana aktor ancaman mengakses sistem korban selama berbulan-bulan tanpa terdeteksi. Dampaknya melampaui kerugian finansial–diperkirakan mencapai $100 juta hanya untuk biaya investigasi awal–dan mencakup kompromi data sensitif pemerintah serta erosi kepercayaan terhadap produk TI enterprise. Proses *attribution* yang melibatkan analisis *Tactics, Techniques, and Procedures* (TTPs) dan intelijen sinyal (SIGINT) juga memicu perdebatan akademis tentang validitas metode *cyber forensics* dalam konteks geopolitik yang sensitif.

Kasus SolarWinds menjadi katalis bagi transformasi kebijakan keamanan siber global, terutama dalam hal penguatan *Zero Trust Architecture* (ZTA) dan peningkatan pengawasan terhadap *software supply chain*. Respons kebijakan termasuk Executive Order 14028 oleh pemerintahan AS yang mewajibkan penggunaan Software Bill of Materials (SBOM) untuk transparansi komponen perangkat lunak.

Dari perspektif teknis, serangan ini mendorong adopsi *behavioral analytics* dan *machine learning-based anomaly detection* untuk mengidentifikasi aktivitas LotL. SolarWinds Attack menegaskan bahwa keamanan siber abad ke-21 memerlukan pendekatan holistik yang mengintegrasikan *threat intelligence*, *resilience-by-design*, dan kolaborasi

E. Pola Umum dan Evolusi Serangan Besar

Analisis retrospektif terhadap kasus-kasus serangan siber besar (Stuxnet, WannaCry, SolarWinds, dll.) mengungkapkan pola umum yang konsisten dalam evolusi ancaman siber modern. Pertama, terjadi pergeseran dari serangan yang bersifat opportunistic menuju operasi yang sangat terarah (*targeted*) dengan tingkat kecanggihan teknis tinggi, sering kali melibatkan eksploitasi *zero-day vulnerabilities* dan *teknik living-off-the-land* (LotL).

Kedua, aktor ancaman semakin memanfaatkan infrastruktur legit (seperti *cloud services* atau *software supply chain*) sebagai vektor serangan, sebagaimana terlihat pada kasus SolarWinds yang mencapai rasio dwell time 14 bulan sebelum terdeteksi. Ketiga, berkembangnya model *as-a-service* dalam ekosistem kejahatan siber (misalnya *ransomware-as-a-service*) yang memungkinkan aktor dengan kemampuan teknis terbatas untuk melancarkan serangan kompleks.

Perkembangan serangan siber besar menunjukkan evolusi strategis dari tujuan destruksi fisik (Stuxnet) hingga

operasi pengumpulan intelijen jangka panjang (SolarWinds) dan sabotasi ekonomi (NotPetya).

Tren terkini mengarah pada beberapa hal berikut.

1. *Hybrid warfare* di mana serangan siber dikombinasikan dengan operasi informasi (*disinformation campaigns*).
2. Eksploitasi *interconnectivity* dalam ekosistem digital global.
3. Pemanfaatan *artificial intelligence* untuk otomatisasi serangan.

Implikasinya, paradigma keamanan siber tradisional yang berfokus pada perimeter *defense* harus berevolusi menuju pendekatan assumed breach dengan penekanan pada *resilience*, *behavioral analytics*, dan *threat intelligence sharing*. Kerangka kerja seperti MITRE ATT&CK dan NIST CSF 2.0 telah mengintegrasikan pembelajaran dari serangan-serangan besar ini untuk mengembangkan model pertahanan yang lebih adaptif terhadap ancaman yang terus berkembang

F. Pelajaran dari Sejarah

Sejarah serangan siber berskala besar–dari Stuxnet hingga SolarWinds–memberikan pelajaran kritis bahwa keamanan digital tidak lagi sekadar masalah teknis, melainkan konvergensi kompleks antara kerentanan teknologi, kebijakan yang tertinggal, dan faktor manusia.

Pertama, kasus-kasus ini membuktikan bahwa *security by obscurity* sudah tidak relevan, serangan canggih sering memanfaatkan celah dalam sistem yang dianggap aman

(seperti *air-gapped networks* atau *trusted supply chains*) sehingga pendekatan *zero trust* dan *continuous monitoring* menjadi keharusan. Kedua, lambatnya respons terhadap ancaman (seperti *patch management* yang buruk dalam kasus WannaCry atau kegagalan deteksi dini SolarWinds) menunjukkan perlunya peningkatan *cyber hygiene* dasar di semua tingkat organisasi. Ketiga, serangan yang melibatkan aktor negara (seperti APT29 atau Lazarus Group) mengungkap dilema etis dalam *vulnerability disclosure*, di mana eksploit yang dikembangkan untuk keperluan intelijen justru bocor dan digunakan untuk kejahatan.

Hal yang terpenting, sejarah mengajarkan bahwa ketahanan siber memerlukan kolaborasi multidisiplin, mulai dari advokasi kebijakan global (seperti norma *responsible state behavior* di dunia maya) hingga investasi dalam pendidikan kesadaran keamanan (*security awareness*) untuk mengurangi risiko *human error*. Dengan kata lain, masa depan keamanan siber bergantung pada kemampuan kita untuk belajar dari masa lalu, mengintegrasikan teknologi mutakhir dengan tata kelola yang proaktif, dan membangun budaya siber yang tangguh di tingkat individu, organisasi, maupun negara.



Daftar Pustaka

Lin, H. (2018) *Optimizing Cyberdeterrence: A Comprehensive Strategy for Preventing Foreign Cyberattacks*, *Political Science Quarterly*. doi: 10.1002/polq.12807.

Mandel, R. (2017) *optimizing Cyberdeterrence: a Comprehensive strategy for Preventing foreign Cyberattacks.* Georgetown University Press.

Stoddart, K. (2022) *Cyberwarfare: threats to critical infrastructure*. Springer Nature.

Toledano, S. A. (2024) *Critical Infrastructure Security: Cybersecurity lessons learned from real-world breaches*. Packt Publishing Ltd.

Tentang Penulis



Ir. Pujo Hari Saputro, S.Kom., M.T. lahir di Ponorogo, Jawa Timur. Ia menyelesaikan pendidikan hingga jenjang magister di Magister Teknik Informatika (MTF) Universitas Atma Jaya Yogyakarta dengan fokus pada bidang *Deep Learning* dan Jaringan Komputer.

Aktif sebagai akademisi dan peneliti, dengan minat utama pada pengembangan teknologi kecerdasan buatan dan infrastruktur jaringan. Ia terlibat dalam kegiatan pengajaran, praktikum, dan penelitian yang mendukung pemanfaatan teknologi digital di dunia pendidikan. Melalui karya dan kontribusi, ia berupaya mendorong pemahaman teknologi secara lebih luas, khususnya bagi generasi muda dan komunitas akademik di bidang informatika.



BAB 11
PENDIDIKAN DAN KESADARAN KEAMANAN SIBER

Prof. Setiawan Assegaff, ST, MMSI, Ph.D

Peningkatan pendidikan dan kesadaran keamanan siber merupakan aspek krusial dalam upaya melindungi ekosistem digital Indonesia. Peningkatan pendidikan dan kesadaran keamanan siber merupakan aspek krusial dalam upaya melindungi ekosistem digital Indonesia. Bab ini membahas pentingnya literasi keamanan siber di kalangan akademisi, profesional, dan masyarakat umum, mengingat tingginya angka pengguna internet di Indonesia serta meningkatnya ancaman siber setiap tahun.

Pendekatan yang digunakan menggabungkan landasan teoretis–termasuk kerangka literasi siber internasional dan lokal–dengan praktik nyata di lapangan melalui studi kasus dan strategi implementasi. Pembaca akan memperoleh pemahaman menyeluruh mengenai urgensi edukasi keamanan siber, model-model kerangka kerja yang dapat diadaptasi, tantangan yang dihadapi, hingga rekomendasi strategis ke depan.

Dalam dua dekade terakhir, Indonesia telah mengalami lonjakan besar dalam penetrasi internet, menjadikan transformasi digital sebagai bagian yang tidak terpisahkan dari kehidupan sosial dan ekonomi. Namun, laju adopsi teknologi ini belum diimbangi dengan kesiapan keamanan digital yang memadai. Data dari berbagai studi menunjukkan bahwa kurangnya kesadaran dan pendidikan siber masih menjadi penyebab utama dari keberhasilan serangan siber, baik dalam lingkup individu, institusi

pendidikan, maupun organisasi pemerintahan dan swasta (Dash dan Ansari, 2022; Alzubaidi, 2021).

Bab ini membahas pentingnya literasi keamanan siber di kalangan akademisi, profesional, dan masyarakat umum, mengingat tingginya angka pengguna internet di Indonesia serta meningkatnya ancaman siber setiap tahun. Pendekatan yang digunakan menggabungkan landasan teoretis–termasuk kerangka literasi siber internasional dan lokal–dengan praktik nyata di lapangan melalui studi kasus dan strategi implementasi. Pembaca akan memperoleh pemahaman menyeluruh mengenai, urgensi kesadaran keamanan siber, kerangka kerja dan model literasi model-model yang dapat diadaptasi, serta rekomendasi strategis pendidikan keamananan siber untuk semua level ke depan.

A. Urgensi Kesadaran Keamanan Siber di Era Digital

Literasi dan kesadaran keamanan siber sangat mendesak di Indonesia karena perkembangan teknologi digital yang semakin pesat, disertai tingginya risiko ancaman siber. Indonesia memiliki jumlah pengguna internet yang sangat tinggi, mencapai lebih dari 77% populasi, sehingga menjadi salah satu negara dengan jumlah serangan siber tertinggi di kawasan ASEAN (APJII, 2024). Hal ini diperkuat oleh laporan bahwa serangan siber seperti pencurian data, phishing,

ransomware, dan malware terus meningkat setiap tahunnya di Indonesia (BSSN, 2024).

Penelitian menunjukkan bahwa tingkat kesadaran keamanan siber di kalangan pengguna aplikasi penting secara umum masih relatif rendah, di mana sebagian besar pengguna jarang bahkan tidak pernah mengganti password mereka, yang menandakan adanya kesenjangan literasi digital yang signifikan (Faliandy et al., 2023). Hal serupa juga ditemukan dalam penelitian tentang pengguna E-Wallet, di mana meskipun tingkat kesadaran sudah cukup baik secara umum, masih banyak pengguna yang kurang memahami aspek-aspek kritis seperti pentingnya pengaturan PIN/password dan keamanan software yang digunakan (Alif & Pratama, 2022).

Selain itu, analisis sentimen masyarakat Indonesia terkait keamanan siber menunjukkan bahwa sebagian besar sentimen masyarakat masih negatif terhadap isu kebocoran data, yang merefleksikan ketidakpuasan masyarakat terhadap upaya perlindungan data pribadi yang ada (Nurfadlillah, 2023). Hal ini menunjukkan bahwa pemahaman dan literasi digital masyarakat masih perlu ditingkatkan secara signifikan. Di sektor pendidikan tinggi, penelitian menunjukkan bahwa kesadaran mahasiswa terhadap keamanan siber juga masih rendah, terutama dalam hal praktik penggunaan password, update software, dan pengelolaan privasi di media sosial (Tan et al., 2024).



Mahasiswa yang seharusnya menjadi agen perubahan dalam hal literasi digital justru menunjukkan tingkat kewaspadaan yang belum optimal terhadap ancaman siber yang ada.

Lebih lanjut, penelitian yang dilakukan terkait pengukuran keamanan siber di Indonesia menggunakan *Global Cybersecurity Index* (GCI) mengindikasikan bahwa meskipun Indonesia aktif dalam kerjasama internasional untuk keamanan siber, namun dalam praktik di lapangan, masih terdapat berbagai kelemahan yang harus diatasi (Cloramidine & Badaruddin, 2023).

Dengan demikian, urgensi peningkatan literasi dan kesadaran keamanan siber di Indonesia sangat jelas. Perlu ada pendekatan edukasi yang komprehensif dan kolaboratif, melibatkan berbagai pemangku kepentingan, seperti pemerintah, institusi pendidikan, perusahaan teknologi, dan komunitas digital untuk membangun kesadaran dan literasi siber yang lebih kuat dan merata di semua lapisan masyarakat.

B. Kerangka Kerja dan Model-Model Literasi Siber

Pada bagian ini akan diuraikan beberapa kerangka kerja dan model literasi siber yang dapat dijadikan acuan dalam program Pendidikan dan Kesadaran Keamanan Siber

1. Kerangka Kerja NIST untuk Kesadaran Keamanan Siber

Dalam menghadapi lanskap ancaman digital yang terus berkembang, kebutuhan akan pendekatan sistematis dalam pengelolaan keamanan siber semakin penting. Salah satu kerangka yang paling banyak diadopsi secara global adalah *NIST Cybersecurity Framework* yang dikembangkan oleh *National Institute of Standards and Technology* (NIST). Kerangka ini tidak hanya berfungsi sebagai panduan teknis untuk pengamanan infrastruktur informasi, tetapi juga sangat relevan dalam merancang program literasi dan kesadaran keamanan siber di berbagai jenis organisasi.

Struktur dan Fungsi Utama Kerangka NIST

NIST *Cybersecurity Framework* (NIST CSF) dirancang sebagai kerangka sukarela untuk membantu organisasi mengelola dan mengurangi risiko siber berdasarkan standar dan praktik terbaik yang telah terbukti.



Gambar 4 Kerangka Kerja Kemanan Siber NIST

Inti dari kerangka ini adalah lima fungsi utama, yaitu *Identify, Protect, Detect, Respond,* dan *Recover* (NIST, 2018).

a. *Identify*: Fungsi ini mencakup pengembangan pemahaman organisasi terhadap sistem, aset, data, dan kapabilitas yang perlu diamankan. Dalam konteks kesadaran siber, fase ini menekankan pentingnya edukasi tentang risiko dan aset digital yang harus dipahami oleh seluruh pengguna (Chaudhary et al., 2022).
b. *Protect*: Tahap ini melibatkan implementasi kebijakan, pelatihan, dan kontrol akses yang dapat melindungi sistem dari gangguan. Salah satu komponen penting adalah pelatihan keamanan siber kepada karyawan, yang berfungsi membangun budaya literasi keamanan siber di organisasi (Abrahams et al., 2024).
c. *Detect*: Berfokus pada pengembangan aktivitas yang memungkinkan deteksi kejadian siber secara tepat waktu. Ini mengharuskan individu di organisasi untuk mampu mengenali anomali atau aktivitas mencurigakan, suatu keterampilan yang dapat diasah melalui program kesadaran (Erendor dan Yildirim, 2022).
d. *Respond*: Menyediakan pedoman untuk tindakan yang harus diambil setelah insiden terdeteksi, termasuk pelaporan dan mitigasi. Dalam konteks pelatihan, fase ini mengajarkan bagaimana pengguna harus merespons

insiden seperti *phishing* atau serangan malware (Dash dan Ansari, 2022).

e. *Recover*: Mengacu pada aktivitas restorasi layanan dan kapabilitas pasca-insiden. Pengguna perlu memahami bagaimana melanjutkan operasional dan belajar dari insiden yang terjadi—ini memperkuat pemahaman mereka terhadap pentingnya keamanan siber secara berkelanjutan (Rohan et al., 2023).

Relevansi NIST CSF untuk Literasi Siber

Kerangka kerja NIST sangat berguna dalam membentuk landasan program kesadaran siber di organisasi. Dengan menyusun kurikulum pelatihan berdasarkan lima fungsi inti tersebut, organisasi dapat mengedukasi pegawai secara holistik mengenai peran mereka dalam menjaga keamanan informasi.

Misalnya, studi oleh Holik et al. (2024) menunjukkan bahwa pelatihan berbasis simulasi yang mengacu pada fungsi *Detect* dan *Respond* meningkatkan respons karyawan terhadap insiden phishing secara signifikan. Selain itu, NIST CSF membantu organisasi menyesuaikan pendekatan pelatihan sesuai dengan profil risiko dan kebutuhan spesifik sektor mereka (Shillair et al., 2022).

NIST juga menyediakan berbagai *"Implementation Tiers"* dan *"Profile"* yang dapat dimanfaatkan untuk mengevaluasi kesiapan organisasi, termasuk sejauh mana kesadaran siber telah diterapkan sebagai budaya organisasi

(Chaudhary et al., 2022). Dalam praktiknya, *framework* ini memungkinkan integrasi antara teknologi, proses, dan manusia sebagai satu kesatuan sistem pertahanan siber yang efektif.

Kerangka NIST bukan hanya alat teknis, melainkan fondasi konseptual yang dapat digunakan dalam menyusun strategi peningkatan literasi siber. Melalui struktur yang sistematis dan fleksibel, kerangka ini mendukung organisasi dalam membangun kesadaran, meningkatkan kesiapsiagaan, serta menumbuhkan budaya keamanan yang berkelanjutan di era digital.

2. Model Kesadaran Keamanan Siber SANS

Dalam upaya membangun kesadaran keamanan siber yang efektif, pendekatan sistematis sangat diperlukan agar organisasi tidak hanya memulai program pelatihan semata, tetapi juga mengembangkan budaya keamanan jangka panjang. Salah satu pendekatan paling komprehensif yang digunakan secara luas adalah *Security Awareness Maturity Model* dari SANS Institute. Model ini dirancang untuk membantu organisasi mengevaluasi dan meningkatkan kematangan program kesadaran keamanan siber mereka, dari kondisi minim hingga menjadi budaya organisasi yang terintegrasi.

Pendekatan dan Alat dari SANS Institute

SANS Institute adalah salah satu lembaga pelatihan keamanan siber paling berpengaruh di dunia. Salah satu alat

utamanya adalah *SANS Security Awareness Planning Toolkit*, yang membantu organisasi dalam merancang, melaksanakan, dan mengevaluasi strategi pelatihan keamanan siber yang berkelanjutan dan berbasis risiko. Toolkit ini mencakup template komunikasi, penilaian risiko, serta peta jalan untuk pembangunan kesadaran berbasis fase (SANS Institute, 2021).

Namun, pilar utama dari pendekatan SANS adalah *Security Awareness Maturity Model*, yaitu kerangka kerja lima tingkat yang menggambarkan evolusi program kesadaran dari tidak ada sama sekali hingga sepenuhnya terintegrasi dalam budaya organisasi (SANS Institute, 2022).



Gambar 5 Lima Tingkat Security Awareness Model (SANS Institute, 2022

a. Level 1–*Nonexistent*

Tidak ada program kesadaran. Organisasi belum mengakui pentingnya pelatihan keamanan, dan

pelanggaran akibat faktor manusia sering terjadi tanpa ada respons sistemik.

b. **Level 2–*Compliance Focused***

Program pelatihan dilaksanakan hanya untuk memenuhi persyaratan regulasi atau audit. Fokus utamanya adalah *"check-the-box"*, tanpa mempertimbangkan perubahan perilaku.

c. **Level 3–*Promoting Awareness and Behavior Change***

Organisasi mulai menyadari pentingnya perubahan perilaku dan menyusun pelatihan yang ditargetkan berdasarkan risiko nyata. Konten mulai disesuaikan dengan peran pengguna dan dikomunikasikan secara lebih kreatif.

d. **Level 4–*Long-Term Sustainment and Culture Change***

Program difokuskan pada pembentukan budaya keamanan siber jangka panjang. Ada integrasi dengan fungsi bisnis lain seperti SDM dan komunikasi, serta penguatan melalui kampanye berkala dan pelatihan berbasis simulasi.

e. **Level 5–Metrics Framework and Strategic Alignment**

Kesadaran keamanan menjadi bagian dari nilai inti organisasi. Ditenagai oleh metrik yang kuat, program disesuaikan dengan tujuan strategis organisasi, dan budaya keamanan melekat pada seluruh proses operasional.

Relevansi dan Contoh Penerapan

Model ini memungkinkan organisasi untuk tidak hanya mengukur posisi mereka saat ini, tetapi juga menetapkan langkah konkret untuk naik ke tingkat kematangan berikutnya. Misalnya, sebuah universitas yang awalnya berada pada *Level 2* (sekadar memenuhi kewajiban pelatihan) dapat melakukan transisi ke *Level 3* dengan mengembangkan pelatihan berbasis simulasi phishing yang sesuai konteks akademik mereka. Selanjutnya, dengan dukungan kepemimpinan dan kolaborasi lintas departemen, mereka dapat membangun *champion awareness team* internal untuk memperkuat program berkelanjutan hingga mencapai *Level 4* (Abrahams et al., 2024).

Studi menunjukkan bahwa organisasi yang mencapai *Level 4* atau lebih tinggi cenderung mengalami penurunan signifikan dalam insiden berbasis manusia, karena pengguna tidak hanya tahu apa yang harus dilakukan, tetapi juga menginternalisasi pentingnya keamanan siber sebagai bagian dari pekerjaan mereka (Chaudhary et al., 2022).

SANS juga menekankan pentingnya *metrics and measurement* dalam tahap akhir untuk mengevaluasi efektivitas pelatihan, seperti pengurangan tingkat klik pada phishing simulasi, atau peningkatan pelaporan insiden oleh karyawan.

Model SANS memberikan peta jalan yang jelas dan praktis dalam membangun dan mempertahankan kesadaran



keamanan siber yang efektif. Dengan mengintegrasikan pelatihan, budaya organisasi, dan pengukuran berkelanjutan, pendekatan ini memungkinkan transformasi nyata dalam perilaku pengguna dan meningkatkan postur keamanan organisasi secara keseluruhan.

3. Strategi Pendidikan Keamanan Siber di Berbagai Level

Pada bagian ini akan dipaparkan usulan Strategi Pendidikan Keamanan Siber di Berbagai Level Pendidikan untuk dapat diterapkan di Indonesia



Gambar 6 Usulan Strategi Pendidikan Keamanan Siber Diberbagi Level Pendidikan di Indonesia

a. Pendidikan Dasar (Sekolah Dasar)

Pengenalan keamanan siber sejak usia dini sangat penting dalam membentuk pola pikir yang aman di era digital. Anak-anak perlu dikenalkan dengan konsep dasar seperti privasi online, penggunaan kata sandi yang aman, serta bahaya membagikan informasi pribadi.

Pendekatan edukatif harus disesuaikan dengan usia, seperti penggunaan media cerita bergambar, animasi, dan permainan edukatif.

Quayyum et al. (2021) menekankan bahwa pendekatan yang efektif untuk anak-anak melibatkan integrasi nilai-nilai keamanan dalam permainan dan pembelajaran berbasis aktivitas yang menyenangkan, termasuk aplikasi berbasis gamifikasi yang telah terbukti meningkatkan kesadaran siber di kalangan anak.

b. Pendidikan Menengah (SMP/SMA)

Pada tahap ini, siswa sudah dapat diberikan pemahaman lebih dalam tentang ancaman siber seperti phishing, malware, cyberbullying, dan keamanan media sosial. Program *"Cyber Safety"* bisa diintegrasikan ke dalam pelajaran Teknologi Informasi atau sebagai kegiatan ekstrakurikuler.

Metode efektif termasuk simulasi serangan *phishing, roleplay* sosial media hingga diskusi kasus nyata. Dalam praktik internasional, model seperti yang diterapkan di sekolah Hungaria dan Vietnam menunjukkan efektivitas pendekatan berbasis pengalaman dalam membentuk kebiasaan siber yang sehat.



c. Pendidikan Tinggi (Universitas dan Politeknik)

Di tingkat ini, pendidikan keamanan siber dapat dilakukan secara sistematis melalui beberapa hal berikut.

- Mata kuliah wajib atau pilihan dalam program studi TI maupun non-TI.
- Praktikum laboratorium dan simulasi serangan (*Capture The Flag*).
- Kolaborasi riset dan program magang dengan lembaga seperti BSSN.
- Sertifikasi internasional, seperti CEH dan CISSP untuk peningkatan daya saing lulusan.

Sebagaimana dijelaskan oleh Humaira et al. (2024), universitas di Indonesia sudah mulai mengintegrasikan program-program pelatihan praktis, termasuk simulasi insiden nyata, serta kerjasama dengan institusi seperti BSSN untuk pelatihan bersertifikat.

d. Pelatihan Profesional dan Sertifikasi

Untuk sektor publik dan swasta, pelatihan dan sertifikasi menjadi strategi penting dalam meningkatkan resiliensi siber organisasi. Pelatihan dapat berupa kegiatan berikut.

- Workshop reguler tentang kebijakan keamanan dan tanggap insiden.
- Modul *e-learning* interaktif.

- Sertifikasi seperti CompTIA Security+, Certified Ethical Hacker (CEH), hingga ISO 27001.

Rohmah (2022) menjelaskan bahwa pelatihan formal dan pendidikan tinggi terstruktur membentuk level lanjutan dari program kesadaran siber berdasarkan kerangka NIST SP 800-50, yang mencakup awareness, training, education, dan professional development.

e. Pendidikan Masyarakat dan Komunitas

Kesadaran keamanan siber di masyarakat umum sangat penting, terutama karena banyak pengguna awam tidak memiliki latar belakang teknologi. Berikut ini strategi efektif yang dapat dilakukan.

- Webinar atau pelatihan gratis yang diselenggarakan oleh komunitas TI atau NGO.
- Kampanye kesadaran melalui media sosial.
- Penyebaran materi edukasi sederhana dalam bahasa lokal.

Menurut Abrahams et al. (2024), pendekatan yang berhasil di komunitas adalah yang menggabungkan motivasi personal dan bentuk pelatihan interaktif untuk meningkatkan partisipasi dan akuntabilitas pengguna.

Strategi pendidikan keamanan siber harus disesuaikan dengan konteks usia, kebutuhan, dan lingkungan. Penguatan literasi digital di semua tingkatan–mulai dari anak-anak hingga profesional–



menjadi kunci utama dalam menciptakan ekosistem digital yang aman dan tangguh. Pendekatan yang berlapis dan inklusif, yang menggabungkan teori dan praktik, serta didukung kebijakan dan kolaborasi lintas sektor, menjadi pilar kesuksesan program literasi siber nasional.

Secara keseluruhan, bab ini menekankan bahwa pendidikan dan kesadaran keamanan siber adalah pondasi penting bagi terwujudnya ekosistem digital yang aman di Indonesia. Melalui pemahaman definisi dan urgensi, adaptasi kerangka kerja global ke konteks lokal, serta pengenalan tantangan spesifik yang dihadapi, kita dapat merancang solusi pendidikan yang tepat sasaran. Strategi implementasi di berbagai level pendidikan, ditunjang peran aktif pemerintah, institusi, sektor swasta, dan komunitas, perlu dijalankan secara sinergis. Studi kasus yang disajikan menunjukkan bahwa upaya kolaboratif sudah mulai berjalan, namun evaluasi berkala diperlukan untuk memastikan efektivitasnya.

Di akhir bab, berbagai rekomendasi kebijakan dan inovasi masa depan diajukan sebagai panduan menuju peningkatan literasi keamanan siber nasional. Dengan langkah-langkah tersebut, diharapkan Indonesia dapat membangun budaya keamanan siber yang kuat, mengurangi risiko serangan, dan memanfaatkan teknologi digital secara optimal dan aman.

Daftar Pustaka

Abrahams, T.O., Farayola, O.A., Kaggwa, S., Uwaoma, P.U., Hassan, A.O. and Dawodu, S.O. (2024) 'Cybersecurity awareness and education programs: A review of employee engagement and accountability', Computer Science & IT Research Journal, 5(1), pp. 100–119. https://doi.org/10.51594/csitrj.v5i.708

Alif, M.S. and Pratama, A.R. (2023) 'Analisis Kesadaran Keamanan di Kalangan Pengguna E-Wallet di Indonesia', IEEE Conference Series, Universitas Islam Indonesia.

Alzubaidi, A. (2021) 'Measuring the level of cyber-security awareness for cybercrime in Saudi Arabia', Heliyon, 7, e06016. https://doi.org/10.1016/j.heliyon.2021.e06016

BSSN (2020) Peraturan Kepala BSSN No. 4 Tahun 2020 tentang Manajemen Risiko Keamanan Siber. [Online] Available at: https://bssn.go.id [Accessed 21 May 2025].

Chaudhary, S., Gkioulos, V. and Katsikas, S. (2022) 'Developing metrics to assess the effectiveness of cybersecurity awareness programs', Journal of Cybersecurity, 8(1), tyac006.

Cloramidine, F. and Badaruddin, M. (2023) 'Mengukur Keamanan Siber Indonesia melalui Indikator Pilar

Kerjasama dalam Global Cybersecurity Index (GCI)', Populis: Jurnal Sosial dan Humaniora, 8(1), pp. 57–58.

Dash, B. and Ansari, M.F. (2022) 'An effective cybersecurity awareness training model', International Research Journal of Engineering and Technology (IRJET), 9(4), pp. 1–7.

Erendor, M.E. and Yildirim, M. (2022) 'Cybersecurity awareness in online education: A case study analysis', IEEE Access, 10, pp. 52319–52330. https://doi.org/10.1109/ACCESS.2022.3171829

Holik, F., Yayilgan, S.Y. and Olsborg, G.B. (2024) 'Emulation of digital substations communication for cyber security awareness', Electronics, 13(2318).

Humaira, H. et al. (2024) 'Membangun Kesadaran Mahasiswa dalam Menghadapi Tantangan Ciber', IURIS STUDIA: Jurnal Kajian Hukum, 5(3), pp. 847–851.

NIST (2018) Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1. National Institute of Standards and Technology. Available at: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf

Nur Rohmah, R. (2022) 'Upaya Membangun Kesadaran Keamanan Siber pada Konsumen E-commerce di Indonesia', Cendekia Niaga: Journal of Trade Development and Studies, 6(1), pp. 1–11.

Nur Rohmah, R. (2022) 'Upaya Membangun Kesadaran Keamanan Siber pada Konsumen E-commerce di Indonesia', Cendekia Niaga: Journal of Trade Development and Studies, 6(1), pp. 1–11

Quayyum, F., Cruzes, D.S. and Jaccheri, L. (2021) 'Cybersecurity awareness for children: A systematic literature review', International Journal of Child-Computer Interaction, 30, p. 100343. https://doi.org/10.1016/j.ijcci.2021.100343

Rohan, R. et al. (2023) 'A systematic literature review of cybersecurity scales assessing information security awareness', Heliyon, 9, e14234.

SANS Institute (2021) Security Awareness Planning Toolkit. [Online] Available at: https://www.sans.org/security-awareness-training/ [Accessed 21 May 2025].

SANS Institute (2022) Security Awareness Maturity Model. [Online] Available at: https://www.sans.org/blog/security-awareness-maturity-model-2022-update/ [Accessed 21 May 2025].

Shillair, R., Esteve-González, P., Dutton, W.H., Creese, S., Nagyfejeo, E. and Von Solms, B. (2022) 'Cybersecurity education, awareness raising, and training initiatives: National level evidence-based results', Computers & Security, 116, p. 102651.



Tan, T. et al. (2024) ‘Kesadaran Keamanan Siber pada Kalangan Mahasiswa Universitas di Kota Batam’, Jurnal Teknologi dan Informasi (JATI), 14(2).

Tentang Penulis



Setiawan Assegaff lahir di Tanjung Karang, Indonesia. Penulis adalah pemegang Ph.D Sistem Informasi dari Universiti Teknologi Malaysia. Bidang minat penelitian beliau khususnya termasuk Manajemen Pengetahuan, Perilaku Berbagi Pengetahuan, Komunitas Virtual, *Social Media Value, E-Commerce*, dan Adopsi Teknologi. Saat ini penulis adalah Guru Besar (Professor) di bidang Sistem Informasi pada Universitas Dinamika Bangsa di kota jambi. Karya-karya penelitian beliau telah banyak diterbitkan dalam jurnal, konferensi dan buku nasional dan internasional. Selain itu beliau juga aktif sebagai *reviewer* pada jurnal nasional dan internasional bereputasi.



BAB 12
REGULASI DAN KEBIJAKAN KEAMANAN SIBER

Bayu Hananto, S.Kom., M.Kom.

Dalam dunia yang semakin terhubung secara digital, keamanan siber telah menjadi prioritas utama untuk melindungi data dan informasi dari ancaman yang terus berkembang. Dengan meningkatnya kebergantungan pada teknologi informasi, ancaman terhadap keamanan siber juga semakin kompleks dan beragam. Oleh karena itu, regulasi dan kebijakan yang komprehensif diperlukan untuk menjaga integritas, kerahasiaan, dan ketersediaan data.

A. Regulasi Keamanan Siber

1. Undang-undang Perlindungan Data Pribadi (UU PDP)-Indonesia

UU No. 27 Tahun 2022 menetapkan kerangka hukum untuk melindungi Data Pribadi Warga Negara Indonesia (Sekretariat Negara 2022).

2. Peraturan Pemerintah No. 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik (PP PSTE)

Mengatur penyelenggaraan sistem elektronik untuk memastikan keamanan dan kepercayaan dalam transaksi digital (Sekretariat Negara 2019).

3. Peraturan Badan Siber dan Sandi Negara (BSSN)

Pedoman Manajemen Keamanan Informasi Sistem Pemerintahan Berbasis Elektronik dan Standar Teknis dan Prosedur Keamanan Sistem Pemerintahan Berbasis Elektronik. (Peraturan BSSN 2021)



4. *General Data Protection Regulation* (GDPR)-Uni Eropa.

Standar global untuk perlindungan data pribadi dengan sanksi berat bagi pelanggaran (Consulting 2025).

5. *Cybersecurity Act-Uni Eropa European Union Agency for Cybersecurity* (ENISA)

Memberikan panduan untuk keamanan jaringan dan informasi di seluruh Eropa.

6. *Cybersecurity Information Sharing Act* (CISA)-USA

Mendorong berbagi informasi antara pemerintah dan sektor swasta untuk meningkatkan respons terhadap ancaman siber.

7. NIST *Cybersecurity Framework*-Amerika Serikat

Menyediakan kerangka untuk mengelola risiko keamanan siber secara sistematis (Moore 2024).

8. ISO/IEC 27001-Standar internasional untuk manajemen keamanan informasi

Mengatur praktik terbaik untuk melindungi informasi dari berbagai ancaman (ISO 2022).

9. Peraturan tentang *Critical Information Infrastructure* (CII)

Mengatur perlindungan terhadap infrastruktur kritis seperti sektor energi, keuangan, transportasi, dan kesehatan.

10. Kerangka Keamanan Siber ASEAN

Memfasilitasi kerjasama keamanan siber antara negara-negara anggota ASEAN.

B. Mengapa Kebijakan Keamanan Siber Penting

Dalam era digital saat ini, perusahaan menghadapi berbagai risiko terhadap sistem dan data mereka, termasuk ancaman dari serangan siber yang semakin kompleks. Banyak serangan memanfaatkan kelemahan manusia sebagai titik masuk utama, mulai dari kelalaian karyawan hingga manipulasi melalui teknik phishing dan rekayasa sosial (*social engineering*).

Selain itu, tren kerja jarak jauh (*remote working*) memperbesar potensi kerentanan keamanan, terutama akibat penerapan kebijakan *Bring Your Own Device* (BYOD) yang tidak terstandar, dan penggunaan perangkat pribadi yang mungkin tidak memenuhi standar keamanan perusahaan.

Kebijakan keamanan siber menjadi instrumen penting untuk beberapa hal berikut ini.

- Melindungi aset digital dan infrastruktur TI organisasi dari berbagai ancaman siber.
- Meningkatkan kesadaran dan tanggung jawab karyawan terhadap keamanan informasi.
- Menetapkan standar perilaku dan praktik terbaik dalam penggunaan sistem TI.
- Mendukung kepatuhan terhadap peraturan dan perundang-undangan yang berlaku.
- Memungkinkan deteksi dini, pencegahan, dan respons cepat terhadap insiden keamanan.



Dengan menerapkan kebijakan yang jelas dan komprehensif, organisasi dapat mengurangi risiko, meningkatkan ketahanan terhadap serangan siber, serta menjaga kepercayaan pemangku kepentingan terhadap keamanan dan integritas operasionalnya.

C. Kebijakan Keamanan Siber

Kebijakan keamanan siber adalah fondasi penting untuk melindungi data dan sistem organisasi dari berbagai ancaman. Kebijakan ini mencakup berbagai aspek, termasuk manajemen risiko, kontrol akses, dan tanggap darurat. Berikut ini beberapa jenis kebijakan keamanan siber yang umum diterapkan.

1. Kebijakan Sistem Penggunaan Data yang Dapat Diterima (*Acceptable Use Policy*-AUP).

Kebijakan ini bertujuan untuk mengatur penggunaan perangkat komputer, jaringan, dan sistem informasi di lingkungan perusahaan agar sesuai dengan standar keamanan dan etika. Penggunaan yang tidak sah atau menyimpang dapat menimbulkan risiko, seperti infeksi malware, gangguan operasional, serta implikasi hukum. Kebijakan ini melindungi pengguna yang berwenang sekaligus menjaga integritas dan keamanan perusahaan.

2. Kebijakan Manajemen Akun

Kebijakan ini mengatur proses pembuatan, administrasi, penggunaan, dan penghapusan akun pengguna yang memberikan akses ke sistem informasi dan sumber daya teknologi perusahaan. Tujuannya untuk memastikan kontrol akses yang tepat, mencegah penyalahgunaan, dan mendukung audit serta kepatuhan terhadap kebijakan keamanan informasi.

3. Kebijakan Antivirus

Kebijakan ini bertujuan melindungi sistem teknologi informasi perusahaan dari ancaman malware dan kode berbahaya lainnya. Antivirus harus diinstal, diaktifkan, dan diperbarui secara berkala pada semua perangkat. Perangkat lunak antivirus berfungsi untuk mendeteksi, mencegah, dan menghapus ancaman, seperti virus, worm, dan trojan. Fitur pembaruan otomatis harus diaktifkan untuk menghadapi ancaman terbaru secara efektif.

4. Kebijakan *E-Commerce*

Dengan meningkatnya serangan siber terhadap layanan daring, kebijakan ini memberikan pedoman pengelolaan keamanan transaksi elektronik (*e-commerce*). Fokus utama adalah perlindungan terhadap data pelanggan dan sistem bisnis dari risiko keamanan, seperti pencurian data, penipuan, dan serangan siber lainnya. Kebijakan ini juga menjadi rujukan dalam penyusunan prosedur keamanan layanan *e-commerce* perusahaan.



5. Kebijakan Email

Kebijakan ini mengatur penggunaan sistem email perusahaan agar aman dari penyalahgunaan dan serangan siber, seperti *phishing*, spam, dan malware. Pengguna diwajibkan untuk waspada terhadap pesan mencurigakan dan dilarang membuka lampiran atau tautan yang tidak dikenal. Enkripsi email dan autentikasi pengguna menjadi bagian penting untuk menjaga kerahasiaan dan integritas komunikasi elektronik perusahaan.

6. Kebijakan Pembuangan Perangkat Keras dan Media Elektronik

Kebijakan ini menetapkan standar dan prosedur untuk pembuangan perangkat keras dan media elektronik yang tidak lagi digunakan, seperti hard drive, komputer, dan server lama. Proses pembuangan harus dilakukan dengan cara yang aman dan sesuai hukum guna mencegah kebocoran data serta mendukung prinsip efisiensi dan keberlanjutan.

7. Kebijakan Manajemen Insiden Keamanan

Kebijakan ini mengatur proses pelaporan, penanganan, dan dokumentasi insiden keamanan informasi yang terjadi di lingkungan perusahaan. Tujuannya untuk memastikan deteksi dini, respons cepat, dan mitigasi dampak dari insiden yang dapat mengganggu keamanan sistem dan data perusahaan.

8. Kebijakan Keamanan Server

Kebijakan ini menetapkan standar konfigurasi dan pengamanan server perusahaan untuk melindungi data dan layanan yang di-hosting. Ini mencakup pembaruan sistem, pembatasan akses, audit log, serta pemantauan rutin guna mengurangi risiko kerentanan terhadap serangan siber.

9. Kebijakan Penggunaan Media Sosial

Kebijakan ini bertujuan mengelola penggunaan media sosial dalam konteks perusahaan agar tidak menimbulkan risiko keamanan informasi atau merusak reputasi institusi. Pengguna wajib mematuhi etika komunikasi dan tidak membagikan informasi sensitif atau rahasia perusahaan melalui platform media sosial.

10. Virtualisasi Server

Kebijakan ini mengatur penggunaan teknologi virtualisasi server untuk meningkatkan efisiensi sumber daya TI. Pengelolaan virtualisasi harus memperhatikan keamanan, segmentasi jaringan, *backup*, dan pemantauan performa agar tetap andal dan aman dalam mendukung operasional perusahaan.

11. Kebijakan Penggunaan Internet dan Web

Menyediakan panduan penggunaan layanan Internet dan Intranet organisasi secara aman dan bertanggung jawab untuk mendukung produktivitas dan keamanan informasi.



12. Kebijakan Manajemen Log

Mengatur pencatatan, penyimpanan, dan analisis log sistem untuk meningkatkan keamanan, pemantauan performa, audit, dan kepatuhan terhadap peraturan yang berlaku.

13. Kebijakan Penggunaan yang Dapat Diterima untuk Jaringan dan VPN

Menetapkan standar penggunaan jaringan perusahaan, termasuk akses melalui VPN, untuk mencegah akses tidak sah dan melindungi aset informasi dari pencurian atau sabotase.

14. Kebijakan Kata Sandi

Menetapkan pedoman pembuatan kata sandi yang kuat, perlindungan terhadap penggunaan ulang atau pengungkapan kata sandi, serta frekuensi pergantian yang disarankan untuk meningkatkan keamanan akses sistem.

15. Kebijakan Pemantauan dan Audit Sistem

Mengatur kegiatan pemantauan secara *real-time* dan audit pasca-kejadian terhadap aktivitas sistem untuk mendeteksi pelanggaran keamanan dan perilaku abnormal.

16. Kebijakan Konektivitas Nirkabel (*Wireless*)

Menyediakan panduan penggunaan koneksi Wi-Fi, termasuk koneksi publik atau tidak aman, dengan fokus pada perlindungan aset informasi perusahaan dari akses tidak sah melalui jaringan nirkabel.

17. Kebijakan Kerja Jarak Jauh (*Remote Work*)

Mengatur syarat dan ketentuan kerja dari lokasi selain kantor utama, termasuk penggunaan peralatan TI, perlindungan data, dan tanggung jawab pengguna terhadap perangkat dan akses sistem perusahaan.

18. Kebijakan Firewall

Firewall, baik berbasis perangkat lunak maupun perangkat keras, berfungsi sebagai lapisan pertahanan terhadap serangan eksternal. Setiap lalu lintas masuk dan keluar diperiksa oleh firewall untuk memastikan hanya data yang sah yang dapat melewati sistem.

D. Siapa yang Harus Menulis Kebijakan Keamanan Siber?

Strategi keamanan siber memiliki implikasi yang luas di seluruh organisasi dan dapat memengaruhi banyak departemen. Misalnya, staf TI mungkin bertanggung jawab untuk menerapkan sistem, sementara tim hukum atau SDM mungkin bertanggung jawab untuk menegakkannya.

Oleh karena itu, rencana tersebut harus dibentuk dan dikelola oleh tim lintas fungsi yang terdiri dari tim TI, hukum, SDM, dan Manajemen. Hal ini memastikan bahwa rencana tersebut konsisten dengan tujuan strategis lembaga dan hukum yang berlaku, dan bahwa tindakan teknis atau perbaikan yang potensial dapat dilaksanakan secara efektif.



E. Cara Membuat Kebijakan Keamanan Siber

Cara membuat Kebijakan Keamanan Siber (*Cybersecurity Policy*) yang efektif untuk organisasi seperti perusahaan, institusi pendidikan, atau instansi pemerintah perlu mengikuti pendekatan sistematis, berbasis risiko, dan sesuai standar praktik terbaik. Berikut beberapa langkah-langkahnya.

1. Identifikasi Tujuan dan Ruang Lingkup

- Tujuan: Menetapkan prinsip dan aturan untuk melindungi sistem informasi, data, dan aset digital organisasi.
- Ruang lingkup: Tentukan siapa saja yang tercakup (pegawai, mitra, vendor), dan sistem atau data apa yang dilindungi (server, jaringan, cloud, endpoint, dll).

2. Lakukan Penilaian Resiko (*Risk Assessment*)

- Identifikasi aset informasi penting: Seperti data pengguna, sistem akademik, perangkat jaringan.
- Analisis ancaman dan kerentanan: Seperti serangan malware, *phishing, insider threat*.
- Evaluasi dampak dan kemungkinan risiko: gunakan metode *Qualitative Risk Matrix* atau *Quantitative Analysis.*

3. Rujuk pada Kerangka Standar Keamanan

Gunakan acuan standar keamanan siber nasional dan internasional:

- ISO/IEC 27001 (manajemen keamanan informasi)

- NIST *Cybersecurity Framework* (identifikasi, proteksi, deteksi, respons, pemulihan)
- SNI ISO/IEC 27001:2013 (standar nasional)

4. Tentukan Komponen Kebijakan

Beberapa komponen utama yang sebaiknya dimuat:

No	Komponen	Penjelasan
1	Penggunaan yang Dapat Diterima (AUP)	Aturan penggunaan perangkat, internet, email, dll.
2	Manajemen Akses	Pembuatan, penggunaan, dan pencabutan akun.
3	Kata Sandi	Standar kompleksitas dan masa berlaku.
4	Manajemen Insiden	Prosedur pelaporan dan penanganan insiden keamanan.
5	Cadangan dan Pemulihan Data (*Backup & Recovery*)	Frekuensi, metode, dan lokasi backup.
6	Keamanan Jaringan	Penggunaan firewall, VPN, segmentasi.
7	Pemantauan & Audit	Kegiatan log, pemantauan lalu lintas jaringan, audit berkala.
8	Pelatihan Kesadaran Keamanan (Security Awareness)	Program edukasi bagi pengguna.
9	Kebijakan BYOD / Kerja Jarak Jauh	Penggunaan perangkat pribadi dan kebijakan kerja remote.
10	Manajemen Vendor / Pihak Ketiga	Akses vendor ke sistem dan data organisasi.



5. Susun Dokumen Kebijakan

Struktur dokumen kebijakan bisa disusun sebagai berikut.

- Judul Kebijakan
- Tujuan
- Ruang Lingkup
- Definisi Istilah
- Isi Kebijakan (berisi poin-poin utama)
- Peran dan Tanggung Jawab
- Prosedur Pelanggaran
- Tinjauan dan Revisi
- Tanggal Efektif & Persetujuan

6. Libatkan Pimpinan dan Unit Terkait

- Konsultasikan dengan unit IT, legal, SDM, dan manajemen puncak.
- Perlu ada persetujuan resmi dari pimpinan sebagai bentuk komitmen.

7. Sosialisasi dan Pelatihan

- Sampaikan kebijakan kepada seluruh personel.
- Lakukan pelatihan keamanan siber secara berkala.

8. Evaluasi serta Revisi Berkala

- Tinjau ulang setiap 6 atau 12 bulan sekali.
- Perbarui berdasarkan perubahan teknologi, hukum, atau insiden yang pernah terjadi.

Kesimpulannya, strategi keamanan siber yang kuat merupakan fondasi dari strategi keamanan organisasi

secara keseluruhan. Dengan mendefinisikan proses, peran, dan tanggung jawab yang terkait dengan keamanan siber secara jelas, organisasi dapat melindungi diri mereka sendiri dengan lebih baik terhadap ancaman siber yang terus berkembang. Penelitian dan pengembangan berkelanjutan di bidang ini, dan pelatihan staf yang komprehensif, diperlukan untuk mempertahankan postur keamanan yang kuat. Seiring meningkatnya kompleksitas ancaman siber, peran strategi keamanan siber yang dirancang dengan baik menjadi lebih penting dari sebelumnya untuk melindungi aset dan reputasi organisasi.



Daftar Pustaka

Consulting, Intersoft. 2025.“General Data Protection Regulation GDPR.” https://gdpr-info.eu/.

ISO. 2022. “ISO/IEC 27001:2022 Information Security, Cybersecurity and Privacy Protection.” 2022:19.

Moore, Tyler. 2024. “The NIST Cybersecurity.” 32.

Peraturan BSSN. 2021. “Peraturan Badan Siber Dan Sandi Negara 4 Tahun 2021 Manajemen Keamanan Informasi Sistem Pemerintahan Elektronik Dan Standar Teknis Dan Prosedur Keamanan Pemerintahan Berbasis Elektronik.” *Bssn* 1–30.

Sekretariat Negara. 2019. *Peraturan Pemerintah Republik Indonesia Nomor 71 Tahun 2019 Tentang Penyelenggaraan Sistem Dan Transaksi Elektronik*. Vol. 7. Indonesia: LN.2019/NO.185, TLN NO.6400, JDIH.SETNEG.GO.ID : 57 HLM.

Sekretariat Negara. 2022. *Peraturan Pemerintah Republik Indonesia Nomor 27 Tahun 2022 Tentang Perlindungan Data Pribadi*. Indonesia: LN.2022/No.196, TLN No.6820, jdih.setneg.go.id: 34 hlm.

Tentang Penulis



Bayu Hananto, S.Kom., M.Kom. lahir di Kediri, 4 Desember 1986. Penulis memperoleh gelar Sarjana di Universitas Pembangunan Nasional "Veteran" Jakarta (UPNVJ) pada Program Studi Teknik Informatika. Penulis melanjutkan studi Magister Ilmu Komputer di Universitas Budi Luhur. Saat ini penulis merupakan dosen tetap di UPNVJ pada program studi Informatika. Penulis juga aktif dalam Penelitian, Area penelitian meliputi Robotika, *Remote Sensing*, Jaringan, dan *Artificial Intelligence*. Penulis dapat dihubungi melalui email: bayuhananto@upnvj.ac.id



BAB 13
KEAMANAN KOMPUTER TERKINI

Samsinar., S.Kom., MMSI

Keamanan teknologi terus berkembang seiring dengan meningkatnya ancaman siber dan kemajuan teknologi digital. Berikut ini beberapa teknologi keamanan terbaru dan terdepan yang digunakan saat ini yaitu Keamanan Berbasis Kecerdasan Buatan (AI Security). Keamanan Berbasis Identitas & *Multi-Factor Authentication* (MFA). Keamanan *Cloud-native* (*Cloud Security Posture Management*-CSPM). *Extended Detection and Response* (XDR), SASE (*Secure Access Service Edge*), dan *Post-Quantum Cryptography.*

Teknologi informasi semakin berkembang dengan pesat, sehingga teknologi informasi sudah menjadi kebutuhan suatu organisasi (Fauzi, Muhyidin and Singasatia, 2023). Banyak organisasi menggunakan jaringan komputer untuk pertukaran data dan informasi dalam bentuk, suara, video, dan masih banyak lagi (Informatika and Ternete, 2024). Jaringan komputer merupakan kumpulan perangkat komunikasi yang berada di beberapa lokasi yang berbeda terdiri dari lebih satu komputer yang saling terhubung (Marcus, Rosyadi and Pamuji, 2021).

Di tengah pesatnya perkembangan teknologi digital, kebutuhan akan sistem keamanan yang kuat dan andal semakin mendesak. Dokumen digital merupakan setiap informasi elektronik yang dibuat, diteruskan, dikirimkan, diterima, atau disimpan dalam bentuk analog, digital, elektromagnetik, optikal, atau sejenisnya, yang dapat dilihat,

ditampilkan dan/atau didengar melalui komputer atau sistem elektronik (Faisal Syafar, Halimah Hisain, Sutarsih Suhaeb, Putri Ida, 2023). Keamanan komputer merupakan serangkaian praktik, kebijakan dan teknologi yang dirancang untuk melindungi sistem komputer, kebocoran data, kerusakan perangkat lunak, jaringan dan data dari ancaman seperti serangan siber (Agustin *et al.*, 2023).

Ancaman keamanan siber kini tidak hanya datang dari individu peretas biasa, tetapi juga dari kelompok-kelompok kriminal terorganisasi, negara-negara berkedok serangan siber hingga program jahat yang dijalankan oleh kecerdasan buatan (AI). Salah satu serangan siber yang umum dilakukan oleh hacker adalah ransomware, yaitu jenis virus tertentu yang menimbulkan kerusakan pada sistem komputer dan menyebabkan risiko keamanan dengan membatasi akses ke data penting sampai data tersebut dibayar tebusannya (Faisal Syafar, Halimah Hisain, Sutarsih Suhaeb, Putri Ida, 2023).

Serangan seperti ransomware, *phishing*, eksploitasi API, dan manipulasi data melalui perangkat IoT semakin canggih serta sulit dideteksi. Oleh karena itu, industri dan organisasi mulai beralih ke teknologi keamanan terbaru yang lebih proaktif, otomatis, dan mampu menghadapi ancaman generasi baru tersebut. Sistem komputasi masa kini semakin kompleks dan sering kali di-*hosting* pada platform cloud untuk memberikan keandalan yang tinggi,

biaya pemanfaatan sumber daya yang optimal, pemeliharaan yang disederhanakan, dan peningkatan fleksibilitas dalam kapasitas komputasi (Lombardi and Recchia, 2024).

Tidak kalah pentingnya adalah kemajuan dalam *Security Orchestration*, *Automation and Response* (SOAR), yaitu sistem otomatis yang membantu tim keamanan menangani insiden dengan cepat dan efisien. SOAR memungkinkan integrasi antar-alat keamanan, automasi respons terhadap serangan umum, dan penyusunan *workflow* penanganan insiden yang konsisten serta dapat direproduksi. Hal ini sangat penting dalam menghadapi volume ancaman yang terus meningkat setiap hari. Keamanan teknologi terus berkembang seiring dengan meningkatnya ancaman siber dan kemajuan teknologi digital. Berikut ini beberapa teknologi keamanan terbaru dan terdepan yang digunakan saat ini (2024–2025).

A. Keamanan Berbasis Kecerdasan Buatan (AI Security)

Keamanan komputer berhubungan dengan yang perlu dilakukan adalah memberikan batasan akses orang lain yang dapat menggangu sistem (Samsoni, Aprilia Hamdayani, 2023). Teknologi kecerdasan buatan (AI) memberikan kontribusi besar dalam keamanan siber, memberikan akses sistem untuk mendeteksi anomali dan pola serangan secara



real-time (Faisal Syafar, Halimah Hisain, Sutarsih Suhaeb, Putri Ida, 2023). Selain itu, pemanfaatan *Artificial Intelligence* (AI) dan *Machine Learning* (ML) dalam dunia keamanan siber telah membuka babak baru dalam deteksi ancaman. Dengan kemampuan untuk menganalisis jutaan log aktivitas dalam waktu nyata, AI dapat mengidentifikasi pola-pola mencurigakan yang sebelumnya tidak terdeteksi oleh sistem tradisional. Contohnya, UEBA (*User and Entity Behavior Analytics*), yang mampu memprediksi potensi pelanggaran keamanan berdasarkan perilaku abnormal pengguna atau sistem.

B. *Zero Trust Architecture* (ZTA)

Salah satu pendekatan keamanan yang sedang populer adalah *Zero Trust Architecture* (ZTA). *Zero Trust Architecture* (ZTA) merupakan salah satu pendekatan yang berkembang pesat dalam beberapa tahun terakhir yang berbeda dengan model tradisional, ZTA menghilangkan kepercayaan bawaan pada perangkat atau pengguna di dalam jaringan (Kusnanto, Nugroho and Kartadie, 2024).

ZTA membangun prinsip *"Never Trust, Always Verify"* yang berbeda dengan model lama yang mengasumsikan bahwa segala sesuatu di dalam jaringan internal aman. Setiap akses harus diverifikasi secara ketat, baik dari pengguna internal maupun eksternal. Pendekatan ini didukung oleh teknologi seperti *Identity and Access*

Management (IAM), *Multi-Factor Authentication* (MFA), *Network Segmentation*, serta *Secure Access Service Edge* (SASE) yang mengintegrasikan keamanan dan konektivitas jaringan dalam satu platform.

C. Keamanan Berbasis Identitas & *Multi-Factor Authentication* (MFA)

Akses sistem *online* yang menggunakan MFA lebih sulit untuk ditembus secara ilegal dibandingkan situs yang hanya mengautentikasi penggunanya dengan satu faktor seperti kata sandi (Faisal Syafar, Halimah Hisain, Sutarsih Suhaeb, Putri Ida, 2023).

MFA atau *Multi-Factor Authentication* adalah metode keamanan di mana pengguna harus memverifikasi identitas mereka dengan lebih dari satu faktor sebelum diberikan akses ke sistem. Karena kata sandi saja tidak cukup aman. Dengan MFA, meskipun seseorang tahu password, mereka tetap tidak bisa masuk karena butuh verifikasi tambahan. MFA melibatkan penggunaan dua atau lebih faktor untuk mengautentikasi pengguna sebelum memberikan akses ke sistem (Badeges and Fauzi, 2023). Ada 3 jenis faktor autentikasi dalam MFA.

1. *Something you know* (sesuatu yang kamu tahu). Contoh: Kata sandi, PIN

2. *Something you have* (sesuatu yang kamu miliki). Contoh: Aplikasi autentikator (Google Authenticator), token fisik, kartu SIM (SMS OTP)
3. *Something you are* (sesuatu yang kamu miliki secarabiometrik).
   Contoh: Sidik jari, pemindai wajah, retina

D. Keamanan *Cloud-native* (*Cloud Security Posture Management*-CSPM)

CSPM mencakup serangkaian alat dan teknik yang ditujukan untuk mengidentifikasi, menilai, dan memperbaiki risiko keamanan secara terus-menerus dalam lingkungan cloud. Sistem bekerja dengan memindai konfigurasi cloud untuk mendeteksi kerentanan, memberikan wawasan tentang masalah kepatuhan, dan memungkinkan otomatisasi untuk mengurangi kesalahan manusia (FNU Jimmy, 2023).

Dalam konteks infrastruktur digital, keamanan awan (*cloud security*) menjadi fokus utama bagi banyak organisasi yang beralih ke layanan cloud. Fungsi dari *Cloud Security* ini, yaitu memantau, mendeteksi, dan memperbaiki celah keamanan di platform cloud seperti AWS, Azure, dan Google Cloud. Perlindungan data di lingkungan *multi-cloud* dan hybrid cloud membutuhkan solusi yang lebih fleksibel dan terintegrasi, seperti *Cloud Access Security Broker* (CASB), *Secure Workload Protection Platform* (CWPP), dan *Secure Access Service Edge* (SASE). Semua ini bekerja sama untuk

memastikan bahwa data tetap aman, baik saat disimpan, dikirim maupun selama proses pemrosesan.

E. *Extended Detection and Response* (XDR)

XDR adalah platform keamanan yang mengumpulkan dan menghubungkan data dari berbagai infrastruktur digunakan untuk menganalisis, memprioritaskan, mencari, dan memperbaiki ancaman untuk mencegah kehilangan data dan pelanggaran keamanan. XDR menggabungkan beberapa solusi menjadi platform deteksi dan respons insiden keamanan yang kohesif dan terintegrasi, yang mengembangkan solusi deteksi titik akhir dan respons insiden otomatis (Soleman and Soewito, 2024).

Teknologi lain yang patut dicatat adalah XDR (*Extended Detection and Response*), evolusi dari EDR (*Endpoint Detection and Response*) yang memberikan visibilitas menyeluruh atas seluruh aset TI, mulai dari endpoint, jaringan, email hingga aplikasi *cloud*. XDR membantu SOC (*Security Operations Center*) dalam mengidentifikasi serangan kompleks yang melibatkan beberapa titik dalam infrastruktur.

F. SASE (Secure Access Service Edge)

SASE adalah arsitektur *cloud-native modern* yang menggabungkan keamanan jaringan dan kemampuan jaringan area luas (WAN) untuk memberikan akses yang

aman, cepat, dan andal ke sumber daya cloud (Deshmukh, 2024). *Secure Access Service Edge* (SASE) menggabungkan keamanan jaringan dengan layanan cloud untuk mendukung kebutuhan organisasi yang memiliki banyak pengguna remote dan infrastruktur yang tersebar. SASE berfungsi memberikan akses aman ke aplikasi dan data dari mana saja.

Teknologi keamanan saat ini tidak lagi bersifat pasif atau reaktif, melainkan proaktif, prediktif, dan skalabel. Integrasi antara AI, cloud, enkripsi kuat, serta kontrol akses yang ketat menjadi fondasi bagi perlindungan data dan sistem di masa depan. Organisasi yang tidak mengadopsi teknologi keamanan terbaru ini akan rentan terhadap risiko pelanggaran data, kerugian finansial, dan hilangnya kepercayaan publik. Oleh karena itu, pemahaman mendalam tentang teknologi-teknologi ini menjadi penting bagi siapa pun yang ingin menjaga data, sistem, dan bisnis mereka tetap aman di tengah ancaman dunia digital yang terus berkembang.

G. *Post-Quantum Cryptography*

Kriptografi kuantum-ost (PQC) merupakan bidang penelitian penting yang ditujukan untuk mengatasi ancaman komputasi kuantum terhadap sistem kriptografi tradisional. Bidang ini berfokus pada evaluasi efisiensi, keamanan, dan kinerja praktis algoritma PQC melalui analisis eksperimental (Pote and Bansode, 2025). Komputer kuantum mampu

memecahkan masalah-masalah matematika yang mendasari algoritma kriptografi klasik dengan efisiensi yang jauh lebih tinggi dibandingkan komputer konvensional dapat memfaktorkan bilangan besar dalam waktu yang jauh lebih singkat dibandingkan algoritma terbaik yang berjalan pada komputer klasik (Sebastian and Tjahyana, 2024).

Pada aspek perlindungan data, enkripsi tetap menjadi fondasi utama. Namun, dengan munculnya komputasi kuantum yang berpotensi memecahkan algoritma enkripsi konvensional, para ahli mulai mengembangkan teknologi enkripsi generasi baru. Salah satunya adalah *Quantum-Resistant Cryptography* yang dirancang untuk bertahan terhadap serangan komputer kuantum. Selain itu, teknologi seperti Homomorphic Encryption memungkinkan analisis data tanpa harus mendekripsi data tersebut, menjaga kerahasiaannya tetap terjaga meskipun sedang diproses.

Perkembangan teknologi juga memengaruhi cara autentikasi dilakukan. Password, yang selama ini menjadi metode utama identifikasi pengguna, mulai ditinggalkan karena rentan terhadap pencurian dan eksploitasi. Sebagai gantinya, teknologi "autentikasi cerdas dan biometrik" seperti face recognition, sidik jari, voice ID, dan protokol FIDO2/WebAuthn menjadi solusi yang lebih aman dan nyaman. Protokol FIDO2, misalnya, memungkinkan login tanpa password dengan verifikasi kuat menggunakan perangkat fisik atau biometrik.



Daftar Pustaka

Agustin, W.D. *et al.* (2023) 'Studi Perbandingan Antara Memori DRAM dan Memori SRAM Dalam Sistem Keamanan Komputer', *Jurnal Teknik Mesin, Industri, Elektro dan Informatika*, 2(4), pp. 01–10. Available at: https://ejurnal.politeknikpratama.ac.id/index.php/jtmei/article/view/2747.

Badeges, W. and Fauzi, M.N. (2023) 'Implementasi Multi Factor Authentication Pada PHPMyAdmin', *TRIPLE A: Jurnal Pendidikan Teknologi Informasi*, 2(1), pp. 35–39.

Deshmukh, E.H. (2024) 'The Rise of Secure Access Service Edge (SASE) In Cloud Performance and Security', 12(2), pp. 711–716. Available at: https://doi.org/10.15662/IJMSERH.2024.1202014.

Faisal Syafar, Halimah Hisain, Sutarsih Suhaeb, Putri Ida, S. (2023) 'View of Blowfish Advanced CS Untuk Solusi Keamanan Sistem Komputer Sekolah.pdf', pp. 353–361.

Fauzi, R., Muhyidin, Y. and Singasatia, D. (2023) 'Sistem Keamanan Jaringan Komputer Berbasis Teknik Intrusion Detection System (IDS) Untuk Mendeteksi Serangan Distrubuted Denial Of Service (DDOS)', *Jurnal Sains Komputer & Informatika (J-SAKTI*, 7(1), pp. 72–86.

FNU Jimmy (2023) 'View of Cloud security posture management_ tools and techniques.pdf'.

Informatika, J.T. and Ternete, N.K. (2024) ‘J-TIFA’, 2617(2), pp. 7–16.

Kusnanto, Y., Nugroho, M.A. and Kartadie, R. (2024) ‘IMPLEMENTASI ZERO TRUST ARCHITECTURE UNTUK MENINGKATKAN KEAMANAN JARINGAN : PENDEKATAN’, 9(4), pp. 2357–2364.

Lombardi, F. and Recchia, A. (2024) ‘On Abstract Machines Security and Performance’, *Procedia Computer Science*, 231(2018), pp. 111–118. Available at: https://doi.org/10.1016/j.procs.2023.12.182.

Marcus, R.D., Rosyadi, H.E. and Pamuji, F.Y. (2021) ‘Prototype Sistem Administrasi Dan Keamanan Jaringan Komputer Berbasis DHCP Server Mikrotik’, *Briliant: Jurnal Riset dan Konseptual*, 6(3), p. 685. Available at: https://doi.org/10.28926/briliant.v6i3.630.

Pote, P. and Bansode, R. (2025) ‘Performance Evaluation of Post-Quantum Cryptography: A Comprehensive Framework for Experimental Analysis’, *Journal of Information Systems Engineering and Management*, pp. 548–556. Available at: https://doi.org/10.52783/jisem.v10i9s.1253.

Samsoni, Aprilia Hamdayani, E.A. dkk (2023) ‘View of Implementasi Sistem Keamanan Komputer Host Menggunakan Sistem Operasi Fedora Linux.pdf’, pp. 721–736.

Sebastian, K. and Tjahyana, S. (2024) 'Implementasi Algoritma Kriptografi Post-Quantum dalam Sistem Keamanan SSL / TLS', pp. 1–12.

Soleman, D. and Soewito, B. (2024) 'Information Security System Design Using XDR And EDR', *Inform : Jurnal Ilmiah Bidang Teknologi Informasi dan Komunikasi*, pp. 51–57. Available at: https://doi.org/10.25139/inform.v9i1.7331.

Tentang Penulis



Penulis lahir di Kampung Laut pada tanggal 25 Maret 1989. Penulis menamatkan SD dan SMP di Kampung Laut kabupaten Tanjung Jabung Timur. Melanjutkan SMA di kota Jambi dan lulus di tahun 2007. Penulis melanjutkan studi di Universitas Gunadarma Progam Studi Sistem Informasi Fakultas Ilmu Komputer menyelesaikan S1 pada tahun 2011. Setelah selesai S1, penulis melanjutkan S2 di kampus yang sama dengan Program Studi Sistem Informasi Bisnis, alhamdulillah mendapatkan gelar MMSI pada tahun 2014.

Setelah lulus, penulis menjadi dosen di STIKES Garuda putih hingga sekarang. Awalnya tidak pernah bermimpi menjadi seorang dosen, tetapi penulis memiliki motto hidup bisa bermanfaat untuk orang lain. Berharap sesuatu yang dikerjakan bukan hanya untuk dunia, tetapi menjadi ladang pahala sebagai bekal di akhirat kelak.



BAB 14
PERAN AI DALAM KEAMANAN SIBER

Muhammad Razi A., S.T., MMSI.

A. Ancaman Siber yang Semakin Kompleks

Dalam satu dekade terakhir, dunia telah mengalami transformasi digital yang pesat, dengan kebergantungan pada teknologi informasi yang meningkat di sektor pemerintahan, bisnis, dan kehidupan sehari-hari. Namun, pertumbuhan ini diiringi oleh peningkatan jumlah dan kompleksitas ancaman keamanan siber. Serangan seperti ransomware, *phishing*, *Advanced Persistent Threats* (APTs), dan *Distributed Denial of Service* (DDoS) kini menjadi lebih canggih, sering kali memanfaatkan celah dalam sistem yang tidak dapat dideteksi oleh metode keamanan konvensional.

Menurut laporan IBM (2023), rata-rata biaya pelanggaran data pada tahun 2023 mencapai $4,45 juta, meningkat 15% dalam dua tahun terakhir (IBM Security, 2023). Fenomena ini menegaskan bahwa keamanan siber bukan hanya masalah teknis, tetapi juga ekonomi dan strategis yang memerlukan solusi inovatif.

Tradisi pertahanan siber yang bergantung pada alat berbasis aturan (*signature-based detection*) dan intervensi manual, semakin tidak memadai menghadapi serangan yang bersifat dinamis dan skala besar. Misalnya, serangan *zero-day*–yang mengeksploitasi kerentanan yang belum dikenal–tidak dapat dicegah oleh sistem yang hanya mengandalkan database tanda serangan lama. Selain itu, volume data yang dihasilkan oleh sistem modern (seperti *Internet of Things*

atau jaringan cloud) melampaui kapasitas analisis manusia, menciptakan kesenjangan antara deteksi ancaman dan respons yang efektif (Roman et al., 2021).

B. Kecerdasan Buatan sebagai Solusi Revolusioner

Kecerdasan Buatan (AI) telah muncul sebagai teknologi kunci untuk mengatasi tantangan keamanan siber. Dengan kemampuannya untuk memproses data dalam skala besar, mengidentifikasi pola kompleks, dan belajar dari pengalaman, AI menawarkan pendekatan proaktif dan adaptif dalam mendeteksi, mencegah, dan merespons ancaman. Teknik seperti *Machine Learning* (ML) dan *Deep Learning* (DL) memungkinkan sistem keamanan untuk tidak hanya mengenali ancaman yang sudah dikenal, tetapi juga memprediksi serangan baru berdasarkan tren historis. Contohnya, algoritma ML seperti *Random Forest* dan *Support Vector Machines* (SVM) telah digunakan dalam *Intrusion Detection System* (IDS) untuk mengklasifikasikan lalu lintas jaringan mencurigakan dengan akurasi hingga 95% (Roman et al., 2021).

Selain itu, AI mempercepat respons insiden melalui otomatisasi. Sistem seperti *Security Orchestration*, *Automation*, *and Response* (SOAR) menggunakan AI untuk mengisolasi perangkat terinfeksi, memblokir IP malisius, dan memperbaiki kerentanan tanpa keterlibatan manusia. Studi oleh IBM (2023) menunjukkan bahwa organisasi yang

mengadopsi AI dalam keamanan siber mengurangi waktu respons terhadap insiden hingga 60%, menghindari kerugian finansial dan reputasi yang lebih besar (IBM Security, 2023).

C. Tantangan dan Isu Etika

Meskipun AI menawarkan banyak manfaat, penerapannya dalam keamanan siber tidak lepas dari tantangan. Salah satunya adalah risiko *adversarial attacks*, di mana penyerang memanipulasi model AI untuk menghindari deteksi. Misalnya, manipulasi kecil pada payload malware dapat mengelabui sistem ML untuk mengklasifikasinya sebagai file aman (Gondal et al., 2019).

Selain itu, penggunaan AI dalam pemantauan jaringan menimbulkan pertanyaan etis tentang privasi dan keandalan keputusan algoritma. OECD (2021) menekankan pentingnya prinsip transparansi, akuntabilitas, dan keadilan dalam penerapan AI untuk memastikan bahwa teknologi ini tidak menyalahgunakan data pengguna atau memperkuat bias algoritmik (OECD, 2021).

D. AI dalam Deteksi Ancaman

Kecerdasan Buatan (AI) telah menjadi tulang punggung dalam mendeteksi ancaman keamanan siber yang semakin kompleks. Dengan kemampuannya memproses data dalam skala besar, AI mampu mengidentifikasi pola serangan yang



tidak terlihat oleh sistem tradisional. Teknik *Machine Learning* (ML) seperti Random Forest, *Support Vector Machines* (SVM), dan K-Means Clustering digunakan untuk mengklasifikasikan lalu lintas jaringan, mendeteksi malware, atau mengenali anomali dalam log sistem.

Contohnya, sistem *Intrusion Detection System* (IDS) berbasis ML seperti CIC-IDS2017 berhasil mencapai akurasi hingga 95% dalam mendeteksi serangan DDoS dengan menganalisis pola koneksi jaringan secara *real-time*. Selain itu, pendekatan unsupervised learning seperti *Principal Component Analysis* (PCA) efektif dalam menemukan aktivitas mencurigakan tanpa memerlukan dataset yang dilabeli, menjadikannya solusi untuk mendeteksi serangan zero-day yang belum pernah terjadi sebelumnya (Roman et al., 2021; Alazab et al., 2021).

Deep Learning (DL), cabang AI yang menggunakan *neural networks* berlapis, memperluas kemampuan deteksi ancaman dengan menangani data tidak terstruktur seperti teks, citra, atau log berurutan. Model *Convolutional Neural Networks* (CNN) digunakan untuk menganalisis struktur HTML situs web dan mendeteksi *phishing* dengan akurasi hingga 98%, seperti yang diterapkan oleh sistem PhishNet. Sementara itu, *Long Short-Term Memory* (LSTM), varian dari *Recurrent Neural Networks* (RNN), mampu memprediksi fase serangan *Advanced Persistent Threats* (APTs) dengan menganalisis pola aktivitas pengguna dan akses file. Studi

oleh Chen et al. (2021) menunjukkan bahwa LSTM dapat mengidentifikasi fase *"lateral movement"* dalam serangan APT dengan presisi 93%, memberikan waktu respons yang lebih cepat kepada tim keamanan.

Selain teknik tunggal, sistem deteksi modern sering menggabungkan berbagai metode AI untuk meningkatkan akurasi. Model *ensemble* yang menggabungkan hasil dari *Random Forest*, SVM, dan *Neural Networks* telah membuktikan peningkatan deteksi serangan DDoS hingga 99% (Sommestad et al., 2020). Contoh lain adalah *transfer learning*, di mana model pralatih seperti BERT digunakan untuk analisis teks *phishing*, lalu disesuaikan dengan dataset lokal guna meningkatkan sensitivitas terhadap ancaman spesifik organisasi. Penerapan praktis AI dalam deteksi ancaman juga terbukti dalam studi kasus nyata, seperti sistem *Self-Learning* AI dari Darktrace yang berhasil mengidentifikasi serangan ransomware LockBit di jaringan rumah sakit pada 2022, memberikan waktu respons 15 menit sebelum kerusakan terjadi (Darktrace Case Study, 2022).

Namun, penerapan AI dalam deteksi ancaman tidak lepas dari tantangan. Salah satunya adalah risiko adversarial attacks , di mana penyerang memanipulasi model AI dengan mengubah payload malware sehingga tidak terdeteksi (Gondal et al., 2019). Selain itu, kurangnya kualitas data dan bias dalam dataset sering menyebabkan model tidak



representatif. Masalah interpretasi model juga menjadi kendala, karena banyak sistem DL bersifat *"black box"* dan sulit menjelaskan keputusannya kepada analis keamanan.

Untuk mengatasi ini, teknologi seperti Explainable AI (XAI) dan Edge AI sedang dikembangkan. XAI bertujuan meningkatkan transparansi dengan memberikan penjelasan atas keputusan deteksi, sementara Edge AI memungkinkan pemrosesan data di perangkat lokal untuk mengurangi latensi dan risiko kebocoran informasi (Abuadbba et al., 2022; Saxe & Berlin, 2019).

E. Tantangan dan Keterbatasan AI dalam Keamanan Siber

1. Kerentanan terhadap Serangan Adversarial

Salah satu tantangan terbesar dalam penerapan AI di bidang keamanan siber adalah kerentuan sistem terhadap *adversarial attacks*. Serangan ini memanipulasi model AI dengan menambahkan gangguan kecil pada data input sehingga model salah mengklasifikasikan ancaman. Contohnya, penyerang dapat memodifikasi payload malware dengan perubahan minimal (seperti menambahkan karakter acak) untuk mengelabui sistem deteksi berbasis *Machine Learning* (ML).

Studi oleh Gondal et al. (2019) menunjukkan bahwa manipulasi kecil pada dataset dapat mengurangi akurasi deteksi AI hingga 30%, bahkan pada model *deep learning*

yang kompleks. Dalam kasus nyata, serangan adversarial berhasil menghindari deteksi oleh sistem keamanan berbasis AI seperti Darktrace dan CrowdStrike, memanfaatkan celah dalam logika pengambilan keputusan model. Tantangan ini menegaskan bahwa meskipun AI unggul dalam skala dan kecepatan, ia tetap rentan terhadap eksploitasi pola pikir algoritmik yang berbeda dari manusia.

2. Kebergantungan pada Kualitas Data

Kinerja sistem AI sangat bergantung pada kualitas dan representasi data pelatihan. Sayangnya, dataset keamanan siber sering kali tidak seimbang (*imbalanced dataset*), di mana data serangan normal jauh lebih sedikit dibandingkan data benign (non-malicious). Hal ini menyebabkan model AI cenderung bias, gagal mendeteksi ancaman langka seperti *zero-day attacks* atau serangan bertarget (*targeted attacks*).

Selain itu, kurangnya data historis serangan yang relevan membuat model sulit generalisasi pada skenario baru. Contohnya, sistem deteksi *phishing* berbasis *Convolutional Neural Networks* (CNN) yang dilatih pada dataset email korporasi mungkin gagal mendeteksi serangan *spear-phishing* yang menggunakan bahasa atau struktur unik. Studi oleh Roman et al. (2021) menunjukkan bahwa ketidakseimbangan data dapat menurunkan sensitivitas model hingga 50%, menjadikan isu ini sebagai hambatan utama dalam adopsi AI di sektor keamanan siber.



3. Masalah Interpretasi dan Transparansi Model

Banyak model AI, terutama yang berbasis *deep learning*, bersifat *"black box"*, artinya sulit menjelaskan bagaimana keputusan deteksi dibuat. Ketidaktransparan ini menjadi masalah serius dalam keamanan siber, di mana analis keamanan memerlukan penjelasan logis untuk memvalidasi hasil deteksi atau merespons insiden. Misalnya, jika sistem AI mengklasifikasikan file tertentu sebagai malware, tim keamanan harus memahami faktor-faktor yang mendasari keputusan tersebut untuk mengambil tindakan yang tepat.

Kurangnya interpretasi juga memperbesar risiko *false positives* (deteksi salah) yang dapat mengganggu operasi bisnis. Teknologi Explainable AI (XAI), seperti metode *SHapley Additive exPlanations* (SHAP) atau *Local Interpretable Model-agnostic Explanations* (LIME), mulai diterapkan untuk meningkatkan transparansi. Namun, integrasi XAI ke dalam sistem keamanan siber masih dalam tahap awal dan memerlukan kompromi antara akurasi dan kemampuan interpretasi.

4. Keterbatasan Sumber Daya dan Infrastruktur

Penerapan AI dalam skala besar memerlukan infrastruktur komputasi intensif, termasuk GPU/TPU untuk pelatihan model dan penyimpanan data yang besar. Biaya ini menjadi penghalang bagi organisasi kecil atau negara berkembang yang tidak memiliki anggaran untuk investasi teknologi. Selain itu, model AI yang kompleks sering membutuhkan

waktu pelatihan lama, sehingga tidak ideal untuk respons *real-time* terhadap serangan yang berkembang cepat.

Contohnya, pelatihan model *Long Short-Term Memory* (LSTM) untuk mendeteksi serangan *Advanced Persistent Threats* (APTs) memerlukan waktu hingga 72 jam pada server GPU kelas atas, belum termasuk biaya listrik dan pemeliharaan. Solusi seperti Edge AI (AI yang dijalankan di perangkat lokal) dan *transfer learning* (penggunaan model pralatih) telah dikembangkan untuk mengurangi ketergantungan pada infrastruktur pusat, tetapi masih memiliki keterbatasan dalam skalabilitas dan performa.

5. Isu Etika dan Privasi

Penggunaan AI dalam keamanan siber sering kali melibatkan pemrosesan data sensitif, seperti log aktivitas pengguna atau informasi pribadi. Jika tidak dikelola dengan baik, sistem ini berpotensi melanggar hak privasi dan menyalahgunakan data. Contohnya, sistem *User Behavior Analytics* (UBA) yang menggunakan AI untuk memantau aktivitas karyawan dapat secara tidak sengaja melabeli perilaku normal sebagai mencurigakan, menyebabkan diskriminasi atau pelanggaran hak digital.

Regulasi seperti *General Data Protection Regulation* (GDPR) di Eropa dan *California Consumer Privacy Act* (CCPA) di AS mensyaratkan transparansi dan persetujuan pengguna dalam pemrosesan data, tetapi banyak organisasi kesulitan memenuhi standar ini saat mengintegrasikan AI. Selain itu,



ada risiko AI disalahgunakan oleh aktor jahat untuk melancarkan serangan yang lebih canggih, seperti *phishing* berbasis *Natural Language Generation* (NLG) atau *deepfake* untuk *social engineering*. OECD (2021) menyarankan prinsip-prinsip etika seperti akuntabilitas, non-diskriminasi, dan keadilan dalam penerapan AI, tetapi implementasinya masih menjadi tantangan global.

Daftar Pustaka

Abuadbba, A., Alazab, M., Kim, H., Wijaya, S.J., Camtepe, S. & Khalil, I., 2022. PhishNet: A CNN-based phishing detection system. Journal of Cybersecurity Education , 18(1), pp.45–60.

Alazab, M., Venkatesh, S., Tari, Z., Watters, P., Alazab, A. & Gupta, R., 2021. Zero-day attack detection with unsupervised learning. Computers & Security , 101, p.102089.

Darktrace, 2022. Case Study: Ransomware Detection in Healthcare. [Online] Available at: https://www.darktrace.com (Accessed: 10 October 2023).

Gondal, M.F., Wiestler, B., Crowson, M.G., Shit, S., Schmidt, J.-P., Mackowiak, P.A., Obermeyer, Z. & Schölkopf, B., 2019. Adversarial vulnerability in medical imaging systems. Nature Machine Intelligence , 1(12), pp.532–539.

IBM Security, 2023. Cost of a Data Breach Report 2023 . IBM Corporation. Available at: https://www.ibm.com/security/data-breach (Accessed: 10 October 2023).

Kamimoto, K., Shimamura, T., Aramaki, E. & Takasu, A., 2021. DeepExploit: Automated penetration testing using reinforcement learning. Proceedings of the IEEE Conference on Security and Privacy .



Lee, K., Kim, J., Park, H. & Cho, Y., 2023. AI-blockchain integration for cybersecurity: A case study. MIT Technical Review .

NATO Science & Technology Organization, 2023. Quantum Machine Learning for Cyber Defense . NATO STO Publications.

OECD, 2021. Principles on Artificial Intelligence . OECD Publishing. Available at: https://www.oecd.org/ (Accessed: 10 October 2023).

Roman, R., Zhou, J. & Lopez, J., 2021. On the features and challenges of security and privacy in distributed internet of things. IEEE Communications Surveys & Tutorials , 23(1), pp.1–20.

Saxe, J. & Berlin, K., 2019. Deep learning for detecting malicious activity. arXiv preprint arXiv:1903.09248 .

Sommestad, T., Holm, H., Ericson, Å., Johnson, P. & Ekstedt, M., 2020. Ensemble learning for intrusion detection. Information Sciences , 512, pp.1–15.

Symantec, 2022. Vulnerability Management Report . Symantec Corporation.

Zhang, Y., Lin, Z., Liu, X., Zhao, J. & Wang, Y., 2020. DDoS detection using SVM and CIC-IDS2017 dataset. IEEE Transactions on Network and Service Management , 17(3), pp.1234–1245.

Tentang Penulis



Muhammad Razi A. adalah dosen tetap Program Studi Sistem Informasi Universitas Jambi. Ia mengampu mata kuliah Pemrograman Web, Teknologi Informasi dan Konunikasi, Interaksi Manusia dan Komputer, Pemrograman Mobile, Computer Programming dan membimbing skripsi. Selama ini ia terlibat aktif sebagai dosen pembimbing mahasiswa dalam kegiatan MBMK serta PKM yang dilaksanakan oleh kementerian terkait.

E-mail: muhammadrazi@unja.ac.id



BAB 15
MASA DEPAN KEAMANAN SIBER

Renny Afriany. N, S.Kom.,M.S.I

Keamanan siber di masa depan sangat sulit diprediksi. Bagaimanapun, setiap aspek industri berubah secara terus-menerus. Ancaman siber terus berkembang dan perangkat yang digunakan untuk melawannya pun mencerminkan perubahan tersebut yang berevolusi dengan sendirinya untuk melindungi jaringan yang semakin kompleks dengan lebih baik.

Keamanan siber menjadi isu krusial mengingat meningkatnya frekuensi dan skala serangan siber yang dapat menyebabkan kerugian finansial, kehilangan data pribadi, dan ancaman terhadap keamanan nasional (Siber *et al.*, 2024). Analis keamanan siber dimasa depan akan terus diteliti, diselidiki dan diungkap dari ancaman dan taktik serangan yang akan muncul.

Berikut ini ancaman keamanan siber yang akan muncul di masa depan.

1. Ancaman Persisten Tingkat lanjut (APT) merupakan kelompok yang sangat canggih dan didanai dengan baik, sering disponsori oleh negara, menargetkan organisasi atau sektor tertentu untuk mengumpulkan intelijen atau mengganggu operasi.

   APT menunjukkan peningkatan penggunaan metode serangan berbasis kedekatan dan khusus infrastruktur. Misalnya, membobol jaringan Wi-Fi, menargetkan perangkat secara fisik dekat dengan target bernilai tinggi. Organisasi harus mempertimbangkan vector serangan

nondigital dan menerapkan arsitektur *zero-trust* yang meluas ke lingkungan fisik. Pendekatan ini akan sangat penting di sektor-sektor, seperti energi, keuangan dan pemerintahan

2. Pada tahun 2024, Field Effect melaporkan serangan *adversary-in-the-middle* (AiTM) baru yang memungkinkan pelaku ancaman untuk menyadap dan memanipulasi komunikasi antara dua pihak, sering kali tanpa terdeteksi, untuk menangkap kredensial dan token sesi.

   Dalam sebuah penyelidikan, teridentifikasi sebuah kampanye di mana penyerang menggunakan halaman login M365 yang mirip dengan Axios untuk mendapatkan kredensial. Korban diarahkan ke halaman palsu, dengan permintaan pengiriman permintaan autentikasi melalui proxy, mengambil kata sandi dan kode MFA, kemudian penyerang menggunakan klien HTTP Axios untuk login ke akun M365, yang secara efektif melewati MFA.

   Munculnya platform seperti Mamba MFA Phising Kit, sebuah alat *phishing-as-a-service*, memudahkan penjahat siber dapat menangkap token autentikasi, menghindari MFA dan membahayakan akun M365.

3. Pasar asuransi siber banyak menghadapi tantangan, terutama kesulitan dalam menilai dan menentukan harga resiko siber karena kurangnya data historis. Untuk

meringankan beban, penyedia asuransi siber akan mewajibkan atau memberi insentif kepada klien untuk menjalani penilaian keamanan siber sebagai bagian dari proses penjaminan dan ketentuan polis.

Perusahaan asuransi dapat terbantu dalam mengevaluasi profil risiko dan premi klien, serta memberikan rekomendasi dan panduan untuk meningkatkan keamanan siber mereka dimasa depan.

4. Peningkatan penargetan diluar titik akhir ke infrastruktur jaringan penting, seperti router, firewall, dan gateway VPN. Ada beberapa hal alasan mengapa hal tersebut dapat terjadi.
   - Infrastruktur jaringan lebih jarang ditambal daripada titik akhir dan lebih mungkin menjalankan perangkat lunak yang ketinggalan zaman dan rentan.
   - Penyerang mengetahui bahwa banyak organisasi memprioritaskan perlindungan titik akhir mereka lebih dari jaringan, aplikasi cloud, dan area permukaan ancaman lainnya.

   Kampanye ArcaneDoor, pelaku dunia maya yang disponsori negara menargetkan perangkat jaringan perimeter dari beberapa vendor, hanyalah salah satu contoh peningkatan ini. Menargetkan perangkat tepi, seperti firewall, switch, dan router popular di kalangan pelaku ancaman yang mencari akses awal ke target yang diinginkan.

Kontrol terhadap perangkat ini dapat memungkinkan pelaku ancaman untuk memantau dan mengalihkan lalu lintas, memperoleh kredensial yang dapat memberikan akses ke sistem dan akun yang lebih sensitive, atau meluncurkan serangan *Adversary-in-the-Middle*.

5. AI dan masa depan keamanan siber. Dalam waktu kurun 2 tahun terakhir ini (2024–2025) merupakan tahun yang luar biasa bagi kecerdasan buatan dengan peralatan seperti ChatGPT dan DALL E yang semakin banyak digunakan masyarakat umum dengan integrasi ke dalam ekosistem besar seperti Copilot milik Microsoft.

   Penggunaan AI dan *machine learning* dalam keamanan siber menjadi salah satu solusi utama yang diidentifikasi. Teknologi ini mampu mengidentifikasi pola anomaly yang mengindikasikan potensi serangan, memungkinkan respons otomatis yang lebih cepat dan akurat terhadap ancaman (Kristianti *et al.*, 2024). Para pelaku kejahatan siber menggunakan AI dalam serangan siber mereka, tetapi para pembela HAM juga mengandalkan teknologi baru ini.

   Berikut beberapa cara AI meningkatkan keamanan siber di masa mendatang.

- **Deteksi dan Perburuan Ancaman**

  Model AI, yang dibangun dari sejumlah besar data, akan membantu mengidentifikasi pola dan anomali yang terkait dengan ancaman siber. Dengan belajar dari data ini dan informasi serangan historis, AI akan membantu mendeteksi serangan baru dengan cepat dan tepat.

- **Analisis Perilaku**

  Pembela akan menggunakan AI untuk mempelajari perilaku pengguna dan sistem serta menetapkan garis dasar. Penyimpangan dari garis dasar ini akan membantu memicu peringatan keamanan siber, mendeteksi perilaku yang berpotensi berbahaya lebih awal dari sebelumnya.

- **Analisis Prediktif**

  Model AI akan memprediksi potensi kerentanan dan vektor serangan. Dengan menganalisis data historis, model ini akan memperkirakan ancaman yang muncul dan merekomendasikan langkah-langkah keamanan proaktif. Analisis prediktif ini akan membantu dalam penentuan prioritas manajemen patch dan penilaian kerentanan.

- **Pemrosesan Bahasa Alami (NLP)**

  Media sosial sebagai sarana terbanyak pengakses di Indonesia membawa banyak dampak positif, seperti mudahnya bertukar informasi satu sama lain,



melakukan proses bisnis, membentuk opini dan lain sebagainya (Kairupan and Rahman, 2022). Sistem AI berbasis NLP yang menganalisis data tekstual, seperti email, log obrolan, dan media sosial akan membantu mengidentifikasi upaya *phishing*, URL berbahaya, dan konten mencurigakan. Data ini kemudian akan digunakan untuk meningkatkan alat penyaringan email, produk firewall DNS, dan materi kesadaran pengguna.

- **Autentikasi Adaptif**

  Sistem autentikasi berbasis AI akan menilai perilaku pengguna selama upaya login. Jika perilaku tersebut menyimpang dari norma yang berlaku, hal ini akan memicu langkah autentikasi tambahan sehingga meningkatkan keamanan tanpa menimbulkan ketidaknyamanan bagi pengguna yang sah.

- **Deteksi Kerentanan *Zero-Day***

  AI akan membantu mengidentifikasi kerentanan *zero-day* dengan menganalisis kode dan perilaku sistem, belajar dari kerentanan yang diketahui, dan memprediksi potensi kelemahan. Kami berharap efisiensi yang didorong AI dalam pengujian jaminan kualitas dapat membantu menemukan dan memperbaiki kerentanan sebelum perangkat lunak dirilis.

Berikut ini tantangan dan tren keamanan siber di masa depan.

- **Peningkatan Ancaman Siber**

  Ancaman siber akan terus berkembang seiring dengan kemajuan teknologi, seperti *Internet of Things* (IoT), 5G, dan AI, yang menciptakan permukaan serangan yang lebih luas dan kompleks.

- **Serangan yang Lebih Canggih**

  Pelaku siber akan menggunakan metode yang lebih cerdik dan otomatis, termasuk serangan *zero-day* dan penggunaan botnet, untuk mengeksploitasi kerentanan sistem.

- **Kesenjangan Keterampilan**

  Kebutuhan akan tenaga kerja keamanan siber yang terlatih akan terus meningkat, sementara jumlah orang yang memiliki keterampilan yang diperlukan belum mencukupi.

- **Peningkatan Kerjasama Global**

  Ancaman siber yang lintas batas memerlukan kolaborasi yang kuat antara berbagai negara dan organisasi untuk berbagi informasi, koordinasi, dan membangun sistem pertahanan bersama.

- **Integrasi AI dan Blockchain**

  AI dapat digunakan untuk deteksi dan mitigasi ancaman secara *real-time*, sedangkan blockchain



dapat meningkatkan keamanan data dengan memastikan keaslian dan integritas transaksi.

- ***Zero-Trust Architecture***

  Pendekatan keamanan ini, yang menekankan tidak ada pengguna atau perangkat yang dapat dipercaya secara otomatis, akan semakin populer dan menjadi strategi utama untuk melindungi jaringan perusahaan.

- **Pergeseran Menuju Ketahanan Siber**

  Perusahaan harus mulai beralih dari strategi pencegahan semata-mata ke strategi yang lebih berorientasi pada ketahanan, yaitu kemampuan untuk mendeteksi, menanggapi, dan pulih dari serangan siber.

Berikut ini solusi dan langkah-langkah dalam menghadapi tantangan dan ancaman keamanan siber di masa depan.

- **Peningkatan Pelatihan dan Sertifikasi**

  Program pelatihan dan sertifikasi di bidang AI dan keamanan siber harus ditingkatkan untuk memastikan tenaga kerja memiliki keterampilan yang diperlukan.

- **Integrasi AI dan Automasi**

  AI dan automasi dapat digunakan untuk menganalisis data, mendeteksi anomali, dan

memberikan respons yang cepat terhadap ancaman.

- **Penerapan Kebijakan *Least Privilege***

  Memberikan akses hanya kepada pengguna atau sistem yang benar-benar memerlukannya akan mengurangi kemungkinan eksploitasi jika terjadi pelanggaran keamanan.

- **Peningkatan Kesadaran dan Keamanan Manusia**

  Karyawan perlu dilatih untuk mengenali ancaman siber dan mengikuti praktik keamanan yang baik, seperti penggunaan password yang kuat dan menghindari *phishing*.

- **Kolaborasi Global**

  Kerja sama internasional dalam bidang keamanan siber harus ditingkatkan untuk mengatasi tantangan lintas batas.

Prospek pekerjaan di bidang Keamanan Siber di masa yang akan datang antara lain:

- **Pertumbuhan Lapangan Kerja**

  Lapangan kerja di bidang keamanan siber diperkirakan akan tumbuh pesat, dengan pertumbuhan lapangan kerja 33 persen antara tahun 2023 dan 2033.

- **Permintaan yang Tinggi**



Permintaan akan profesional keamanan siber akan terus meningkat, terutama di bidang-bidang seperti AI, blockchain, dan *zero-trust.*

- **Peluang Karier yang Beragam**
  Profesional keamanan siber memiliki berbagai peluang karir di berbagai bidang dan tingkatan, mulai dari analis keamanan, arsitek keamanan hingga manajer keamanan.

Dengan memahami ancaman, tantangan dan tren di masa depan keamanan siber, serta mengambil langkah-langkah yang tepat, organisasi dan individu dapat memperkuat pertahanan siber dalam menghadapi ancaman yang terus berkembang.

Dengan mengintegrasikan teknologi, tata kelola, dan edukasi, keamanan siber masa depan dapat ditingkatkan secara holistik sehingga masyarakat dan organisasi lebih siap menghadapi ancaman yang dinamis dan canggih. Strategi yang komprehensif ini akan menjadi landasan untuk menciptakan sistem yang lebih aman di era digital (Kristianti *et al.*, 2024).

Daftar Pustaka

Kairupan, V.A. and Rahman, A.A. (2022) 'Analisis Kesadaran Cybersecurity Pada Pengguna Media Sosial Di Kalangan Mahasiswa Kota Bandung', *Jurnal Darma Agung*, 30(1), p. 1164. Available at: https://doi.org/10.46930/ojsuda.v30i1.3167.

Kristianti, N. *et al.* (2024) 'Peraturan dan Regulasi Keamanan Siber di Era Digital', *Satya Dharma: Jurnal Ilmu Hukum*, 6055(1), pp. 297–310. Available at: https://ejournal.iahntp.ac.id/index.php/satya-dhamat.

Siber, K. *et al.* (2024) 'YANG DIBUTUHKAN', (November), pp. 1247–1254.

Tentang Penulis



Renny Afriany. N, S.Kom.,M.S.I lahir pada tanggal 28 April 1973 di kota Jambi. Ia adalah dosen dengan NIDN/NIDK 8825701019 yang mengajar sejak tahun 2004 di Sekolah Tinggi Ilmu Kesehatan Garuda Putih, Perguruan Tinggi Swasta ternama di Kota Jambi. Pendidikan terakhir adalah Pascasarjana Magister Sistem Informasi.

Keamanan Siber

Melindungi Data di Dunia Digital

Buku Keamanan Siber: Melindungi Data di Dunia Digital menyajikan pemahaman mendasar hingga lanjutan tentang pentingnya menjaga keamanan informasi di era digital. Di tengah meningkatnya serangan siber dan penyalahgunaan data, buku ini hadir sebagai panduan untuk mengenali risiko dan strategi perlindungan data.

Terdiri dari 15 bab, isi buku mencakup pengantar keamanan siber, jenis ancaman dan kerentanan, kriptografi, keamanan jaringan dan aplikasi, serta manajemen risiko. Pembahasan juga meliputi perlindungan privasi, sistem deteksi insiden, keamanan cloud, hingga tren terbaru seperti peran kecerdasan buatan dalam pertahanan digital.

Ditulis dengan bahasa yang mudah dipahami, buku ini ditujukan bagi pelajar, akademisi, praktisi, maupun masyarakat umum. Harapannya, pembaca dapat meningkatkan kesadaran dan kemampuan dalam menjaga data pribadi dan sistem digital, sekaligus memahami tantangan dan masa depan keamanan siber.

ISBN 978-634-7269-36-2
9 786347 269362

Penamuda.com
PT Penamuda Media
Casa Sidoarum, Ngentak Godean
penamuda_media